



**Cyber Security (CYBER);
CRA;
Cybersecurity requirements for
Virtual Private Networks (VPNs)**

Reference

DEN/CYBER-EUS-005

Keywords

CRA, cybersecurity, VPN

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part of this document may be reproduced in any form, by any means and in any media, without the prior written authorization of ETSI and except as expressly permitted below.

By way of exception and when the document is a normative deliverable (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)), ETSI authorizes to reproduce and incorporate into products, services and technical documentation only those extracts (e.g. templates) that are strictly necessary for the technical implementation of the normative deliverable, to ensure compliance with the latter. Nothing in this notice shall be construed as limiting any mandatory exceptions to copyright provided by applicable law.

© ETSI 2026.
All rights reserved.

Contents

Intellectual Property Rights	19
Foreword.....	19
Modal verbs terminology	20
Introduction	20
1 Scope	21
2 References	21
2.1 Normative references	21
2.2 Informative references	21
3 Definition of terms, symbols, abbreviations and naming conventions	23
3.1 Terms	23
3.2 Symbols	24
3.3 Abbreviations.....	24
3.4 Conventions	25
4 Product context.....	25
4.1 Product Functions	25
4.1.1 Overview	25
4.1.2 Potential functions of a node	26
4.1.2.1 Authentication	26
4.1.2.2 Access control	26
4.1.2.3 Traffic encryption	26
4.1.2.4 Routing	26
4.1.2.5 Filtering	26
4.1.3 Potential roles of nodes	26
4.1.4 Capabilities of nodes	26
4.2 Product Architecture	27
4.2.1 Product overview	27
4.2.2 Network topology and relationship between nodes	27
4.2.3 VPN client.....	28
4.2.4 VPN server, VPN gateway	29
4.2.4.1 Server & gateway responsibilities	29
4.2.4.2 Server & gateway remote data processing.....	29
4.2.5 Management server	29
4.3 Operational Environment.....	29
4.3.1 General description	29
4.3.2 Hardware environment.....	29
4.3.3 Software environment	30
4.3.4 Connectivity aspects.....	31
4.4 Distribution of Security Functions.....	31
4.4.1 Cybersecurity function distribution overview	31
4.4.2 Cybersecurity Functionalities Offered to Integrated Components	32
4.4.3 Cybersecurity functions required from the environment.....	32
4.5 Users	32
4.6 Use Cases.....	33
4.6.1 Introduction to Use Cases	33
4.6.2 UC-1 Individual consumer	33
4.6.3 UC-2 Privacy conscious household.....	33
4.6.4 UC-3 Journalist, activist, legal professionals	33
4.6.5 UC-4 Small enterprise, small not-for-profit organization	34
4.6.6 UC-5 Large enterprise	34
4.6.7 UC-6 Enterprise with independent VPN infrastructure.....	34
4.6.8 UC-7 Mesh Network	34
5 Technical requirements for products	35

5.1	Introduction - Applicability of the requirements	35
5.2	Appropriate level of cybersecurity	37
5.2.1	Overview	37
5.2.1.1	CRA Relevance	37
5.2.1.2	Secure software design and development	37
5.2.2	REQ-SSD-01 Memory access error prevention	37
5.2.2.1	Requirement	37
5.2.2.2	Applicability	37
5.2.3	REQ-SSD-02 Resilience against potentially untrusted inputs	38
5.2.3.1	Requirement	38
5.2.3.2	Applicability	38
5.2.4	REQ-SSD-03 Applicability of Annex R	38
5.2.4.1	Requirement	38
5.2.4.2	Applicability	38
5.2.4.3	Guidance	39
5.2.5	Mapping of requirements to use cases	39
5.3	No known exploitable vulnerabilities	39
5.3.1	Overview	39
5.3.2	REQ-KEV-01 Testing for known exploitable vulnerabilities	39
5.3.2.1	Requirement	39
5.3.2.2	Applicability	39
5.3.2.3	Guidance	40
5.3.3	Mapping of requirements to use cases	40
5.4	Secure by default configuration	40
5.4.1	Overview	40
5.4.2	REQ-SBD-01 Unintentional disabling of cybersecurity features	40
5.4.2.1	Requirement	40
5.4.2.2	Applicability	40
5.4.3	Mapping of requirements to use cases	41
5.5	Security updates	41
5.5.1	Overview	41
5.5.2	REQ-SU-01 Automatic secure update before or during first use	41
5.5.2.1	Requirement	41
5.5.2.2	Applicability	41
5.5.3	REQ-SU-02 Automatic secure update via operational environment before or during first use	41
5.5.3.1	Requirement	41
5.5.3.2	Applicability	41
5.5.4	REQ-SU-03 Secure update via product	42
5.5.4.1	Requirement	42
5.5.4.2	Applicability	42
5.5.5	REQ-SU-04 Automatic secure update via product	42
5.5.5.1	Requirement	42
5.5.5.2	Applicability	42
5.5.6	REQ-SU-05 Secure update provided by operational environment	43
5.5.6.1	Requirement	43
5.5.6.2	Applicability	43
5.5.7	REQ-SU-06 Automatic secure update provided by operational environment	43
5.5.7.1	Requirement	43
5.5.7.2	Applicability	43
5.5.8	REQ-SU-07 Updates are signed and verified before installation	44
5.5.8.1	Requirement	44
5.5.8.2	Applicability	44
5.5.9	REQ-SU-08 Only authorized software updates	44
5.5.9.1	Requirement	44
5.5.9.2	Applicability	44
5.5.10	REQ-SU-09 Secure update has validly signed hash	44
5.5.10.1	Requirement	44
5.5.10.2	Applicability	44
5.5.10.3	Guidance	45
5.5.11	REQ-SU-10 Invalidated update is rejected	45
5.5.11.1	Requirement	45
5.5.11.2	Applicability	45

5.5.11.3	Guidance	45
5.5.12	REQ-SU-11 Signing keys have strictly scoped usage	46
5.5.12.1	Requirement	46
5.5.12.2	Applicability	46
5.5.12.3	Guidance	46
5.5.13	REQ-SU-12 Signing keys have not been revoked or otherwise marked untrusted	46
5.5.13.1	Requirement	46
5.5.13.2	Applicability	46
5.5.13.3	Guidance	47
5.5.14	REQ-SU-13 Reject update to current or previous version	47
5.5.14.1	Requirement	47
5.5.14.2	Applicability	47
5.5.15	REQ-SU-14 Updates not applied from expired sources	48
5.5.15.1	Requirement	48
5.5.15.2	Applicability	48
5.5.16	Mapping of requirements to use cases	48
5.6	Authentication and access control	48
5.6.1	Overview	48
5.6.2	REQ-AAC-01 Authentication of cybersecurity-relevant nodes	49
5.6.2.1	Requirement	49
5.6.2.2	Applicability	49
5.6.2.3	Guidance	49
5.6.3	REQ-AAC-02 Encryption of transmitted credentials	49
5.6.3.1	Requirement	49
5.6.3.2	Applicability	49
5.6.4	REQ-AAC-03 Authentication timeout	49
5.6.4.1	Requirement	49
5.6.4.2	Applicability	50
5.6.5	REQ-AAC-04 Cloned credentials detection	50
5.6.5.1	Requirement	50
5.6.5.2	Applicability	50
5.6.6	REQ-AAC-05 Forced revocation of authorization of endpoints	50
5.6.6.1	Requirement	50
5.6.6.2	Applicability	51
5.6.7	REQ-AAC-06 Brute force protection	51
5.6.7.1	Requirement	51
5.6.7.2	Applicability	51
5.6.8	REQ-AAC-07 Authorization of endpoints	51
5.6.8.1	Requirement	51
5.6.8.2	Applicability	52
5.6.9	REQ-AAC-08 Fine-grain access control	52
5.6.9.1	Requirement	52
5.6.9.2	Applicability	52
5.6.10	Mapping of requirements to use cases	52
5.7	Confidentiality protection	53
5.7.1	Overview	53
5.7.1.1	CRA relevance	53
5.7.1.2	Confidentiality of DNS queries	53
5.7.2	REQ-CON-01 VPN routing stays in effect until VPN connection deactivated	53
5.7.2.1	Requirement	53
5.7.2.2	Applicability	53
5.7.3	REQ-CON-02 VPN routing stays in effect during network-level tunnel failure	54
5.7.3.1	Requirement	54
5.7.3.2	Applicability	54
5.7.4	REQ-CON-03 Tunnel all traffic by default	54
5.7.4.1	Requirement	54
5.7.4.2	Applicability	54
5.7.5	REQ-CON-04 Endpoint to endpoint encryption	54
5.7.5.1	Requirement	54
5.7.5.2	Applicability	55
5.7.6	REQ-CON-05 Inform user of visibility of DNS queries	55
5.7.6.1	Requirement	55

5.7.6.2	Applicability	55
5.7.7	REQ-CON-06 Configurable exclusive DNS routing	55
5.7.7.1	Requirement	55
5.7.7.2	Applicability	56
5.7.8	REQ-CON-07 Exclusive DNS routing by default.....	56
5.7.8.1	Requirement	56
5.7.8.2	Applicability	56
5.7.9	REQ-CON-08 DNS configuration consistency	56
5.7.9.1	Requirement	56
5.7.9.2	Applicability	56
5.7.10	REQ-CON-09 Secure DNS protocols	57
5.7.10.1	Requirement	57
5.7.10.2	Applicability	57
5.7.11	REQ-CON-10 No DNS leaks during network-level tunnel failure	57
5.7.11.1	Requirement	57
5.7.11.2	Applicability	57
5.7.12	REQ-CON-11 Block IPv6 if Unsupported.....	57
5.7.12.1	Requirement	57
5.7.12.2	Applicability	58
5.7.13	REQ-CON-12 Full Support if Claimed	58
5.7.13.1	Requirement	58
5.7.13.2	Applicability	58
5.7.14	REQ-CON-13 Use conformant cryptography	58
5.7.14.1	Requirement	58
5.7.14.2	Applicability	58
5.7.15	REQ-CON-14 Protect confidentiality of data stored on the product.....	59
5.7.15.1	Requirement	59
5.7.15.2	Applicability	59
5.7.16	REQ-CON-15 Inform user of limits of privacy protection	59
5.7.16.1	Requirement	59
5.7.16.2	Applicability	60
5.7.17	Mapping of requirements to use cases.....	60
5.8	Integrity protection	60
5.8.1	Overview	60
5.8.2	REQ-INT-01 VPN client restores any system configuration it changes to its previous state after the VPN connection ends.....	60
5.8.2.1	Requirement	60
5.8.2.2	Applicability	61
5.8.3	REQ-INT-02 VPN client provides a method to restore any system configuration it changes to its previous state.....	61
5.8.3.1	Requirement	61
5.8.3.2	Applicability	61
5.8.4	REQ-INT-03 VPN client does not degrade system security	61
5.8.4.1	Requirement	61
5.8.4.2	Applicability	61
5.8.5	REQ-INT-04 Application protocol validity checks.....	62
5.8.5.1	Requirement	62
5.8.5.2	Applicability	62
5.8.6	REQ-INT-05 Application protocol validity checks by operational environment.....	62
5.8.6.1	Requirement	62
5.8.6.2	Applicability	62
5.8.7	Mapping of requirements to use cases.....	63
5.9	Data minimisation.....	63
5.9.1	Overview	63
5.9.2	REQ-DM-01 Data minimisation across the product	63
5.9.2.1	Requirement	63
5.9.2.2	Applicability	63
5.9.3	REQ-DM-02 No Personal Data sent outside endpoint.....	63
5.9.3.1	Requirement	63
5.9.3.2	Applicability	64
5.9.4	REQ-DM-03 Minimise Personal Data required for service provisioning and payment.....	64
5.9.4.1	Requirement	64

5.9.4.2	Applicability	64
5.9.5	REQ-DM-04 Minimise Personal Data stored.....	64
5.9.5.1	Requirement	64
5.9.5.2	Applicability	64
5.9.6	REQ-DM-05 No data persistence or storage enabled on exit nodes	65
5.9.6.1	Requirement	65
5.9.6.2	Applicability	65
5.9.7	Mapping of requirements to use cases.....	65
5.10	Availability protection	65
5.10.1	Overview	65
5.10.2	REQ-AP-01 Fast packet drop.....	65
5.10.2.1	Requirement	65
5.10.2.2	Applicability	66
5.10.3	REQ-AP-02 Limit memory usage	66
5.10.3.1	Requirement	66
5.10.3.2	Applicability	66
5.10.4	REQ-AP-03 Availability protection provided by operational environment	66
5.10.4.1	Requirement	66
5.10.4.2	Applicability	66
5.10.5	REQ-AP-04 Rate limit unauthenticated traffic	67
5.10.5.1	Requirement	67
5.10.5.2	Applicability	67
5.10.6	Mapping of requirements to use cases.....	67
5.11	Non-interference	67
5.11.1	Overview	67
5.11.2	REQ-IM-01 No route between different endpoints by default	67
5.11.2.1	Requirement	67
5.11.2.2	Applicability	68
5.11.3	REQ-IM-02: Minimise data transmitted to unverified sources	68
5.11.3.1	Requirement	68
5.11.3.2	Applicability	68
5.11.3.3	Guidance.....	68
5.11.4	Mapping of requirements to use cases.....	68
5.12	Attack surface minimisation	69
5.12.1	Overview	69
5.12.2	REQ-MAS-01 Unnecessary VPN client permissions	69
5.12.2.1	Requirement	69
5.12.2.2	Applicability	69
5.12.2.3	Guidance.....	69
5.12.3	Mapping of requirements to use cases.....	69
5.13	Exploit mitigation	69
5.13.1	Overview	69
5.13.2	REQ-EMM-01 Route traffic from other sources/destination disabled by default.....	70
5.13.2.1	Requirement	70
5.13.2.2	Applicability	70
5.13.3	REQ-EMM-02 Notify user if routing traffic from other sources/destination	70
5.13.3.1	Requirement	70
5.13.3.2	Applicability	70
5.13.4	REQ-EMM-03 No routing traffic from other sources/destination if not necessary for services	70
5.13.4.1	Requirement	70
5.13.4.2	Applicability	70
5.13.5	Mapping of requirements to use cases.....	71
5.14	Monitoring	71
5.14.1	Overview	71
5.14.1.1	CRA requirement.....	71
5.14.1.2	Minimum scope	71
5.14.1.3	Monitoring restrictions	71
5.14.2	REQ-LOG-01 Local event logging	72
5.14.2.1	Requirement	72
5.14.2.2	Applicability	72
5.14.3	REQ-LOG-02 Internal event logging.....	72
5.14.3.1	Requirement	72

5.14.3.2	Applicability	72
5.14.4	REQ-LOG-03 Remote Logging to RDPS	73
5.14.4.1	Requirement	73
5.14.4.2	Applicability	73
5.14.4.3	Guidance	73
5.14.5	REQ-LOG-04 Privacy-preserving logs policy and traffic anonymization	73
5.14.5.1	Requirement	73
5.14.5.2	Applicability	73
5.14.6	Mapping of requirements to use cases	74
5.15	Factory reset and data portability	74
5.15.1	Overview	74
5.15.2	REQ-DRT-01 Secure deletion via "factory reset"	74
5.15.2.1	Requirement	74
5.15.2.2	Applicability	74
5.15.3	REQ-DRT-02 Secure deletion via reinstallation	75
5.15.3.1	Requirement	75
5.15.3.2	Applicability	75
5.15.4	REQ-DRT-03 Secure data read from product	75
5.15.4.1	Requirement	75
5.15.4.2	Applicability	75
5.15.5	REQ-DRT-04 Secure data export	75
5.15.5.1	Requirement	75
5.15.5.2	Applicability	76
5.15.6	Mapping of requirements to use cases	76
6	Assessment criteria for compliance with technical requirements	76
6.1	Introduction to the assessment and compliance criteria	76
6.2	Appropriate level of cybersecurity	78
6.2.1	Overview	78
6.2.2	REQ-SSD-01 Memory access error prevention	78
6.2.2.0	Overview	78
6.2.2.1	Objective	78
6.2.2.2	Preparation	78
6.2.2.3	Activities	78
6.2.2.4	Verdict	79
6.2.2.5	Evidence	79
6.2.2.6	Guidance for "risk-based approach"	80
6.2.3	REQ-SSD-02 Resilience against potentially untrusted inputs	80
6.2.3.1	Objective	80
6.2.3.2	Preparation	80
6.2.3.3	Activities	81
6.2.3.4	Verdict	81
6.2.3.5	Evidence	81
6.2.3.6	Guidance	81
6.2.4	REQ-SSD-03 Applicability of Annex R	81
6.3	No known exploitable vulnerabilities	81
6.3.1	Overview	81
6.3.2	REQ-KEV-01 Testing for known exploitable vulnerabilities	82
6.3.2.1	Objective	82
6.3.2.2	Preparation	82
6.3.2.3	Activities	82
6.3.2.4	Verdict	82
6.3.2.5	Evidence	82
6.4	Secure by default configuration	82
6.4.1	Overview	82
6.4.2	REQ-SBD-01 Unintentional disabling of cybersecurity features	82
6.4.2.1	Objective	82
6.4.2.2	Preparation	83
6.4.2.3	Activities	83
6.4.2.4	Verdict	83
6.4.2.5	Evidence	83
6.5	Security updates	83

6.5.1	Overview	83
6.5.2	REQ-SU-01 Automatic secure update before or during first use	83
6.5.2.1	Objective	83
6.5.2.2	Preparation.....	83
6.5.2.3	Activities	83
6.5.2.4	Verdict.....	83
6.5.2.5	Evidence	84
6.5.3	REQ-SU-02 Automatic secure update via operational environment before or during first use	84
6.5.3.1	Objective	84
6.5.3.2	Preparation.....	84
6.5.3.3	Activities	84
6.5.3.4	Verdict.....	84
6.5.3.5	Evidence	84
6.5.4	REQ-SU-03 Secure update via product.....	85
6.5.4.1	Objective	85
6.5.4.2	Preparation.....	85
6.5.4.3	Activities	85
6.5.4.4	Verdict.....	85
6.5.4.5	Evidence	85
6.5.5	REQ-SU-04 Automatic secure update via product.....	85
6.5.5.1	Objective	85
6.5.5.2	Preparation.....	85
6.5.5.3	Activities	85
6.5.5.4	Verdict.....	86
6.5.5.5	Evidence	86
6.5.6	REQ-SU-05 Secure update provided by operational environment.....	86
6.5.6.1	Objective	86
6.5.6.2	Preparation.....	86
6.5.6.3	Activities	86
6.5.6.4	Verdict.....	86
6.5.6.5	Evidence	86
6.5.7	REQ-SU-06 Automatic secure update provided by operational environment.....	86
6.5.7.1	Objective	86
6.5.7.2	Preparation.....	86
6.5.7.3	Activities	86
6.5.7.4	Verdict.....	87
6.5.7.5	Evidence	87
6.5.8	REQ-SU-07 Updates are signed and verified before installation	87
6.5.8.1	Objective	87
6.5.8.2	Preparation.....	87
6.5.8.3	Activities	87
6.5.8.4	Verdict.....	87
6.5.8.5	Evidence	87
6.5.9	REQ-SU-08 Only authorized software updates.....	87
6.5.9.1	Objective	87
6.5.9.2	Preparation.....	87
6.5.9.3	Activities	87
6.5.9.4	Verdict.....	88
6.5.9.5	Evidence	88
6.5.10	REQ-SU-09 Secure update has validly signed hash.....	88
6.5.10.1	Objective	88
6.5.10.2	Preparation.....	88
6.5.10.3	Activities	88
6.5.10.4	Verdict.....	88
6.5.10.5	Evidence	88
6.5.11	REQ-SU-10 Invalidated update is rejected	88
6.5.11.1	Objective	88
6.5.11.2	Preparation.....	88
6.5.11.3	Activities	88
6.5.11.4	Verdict.....	89
6.5.11.5	Evidence	89
6.5.12	REQ-SU-11 Signing keys have strictly scoped usage.....	89

6.5.12.1	Objective	89
6.5.12.2	Preparation.....	89
6.5.12.3	Activities	89
6.5.12.4	Verdict.....	89
6.5.12.5	Evidence	89
6.5.13	REQ-SU-12 Signing keys have not been revoked or otherwise marked untrusted	89
6.5.13.1	Objective	89
6.5.13.2	Preparation.....	89
6.5.13.3	Activities	90
6.5.13.4	Verdict.....	90
6.5.13.5	Evidence	90
6.5.14	REQ-SU-13 Reject update to current or previous version	90
6.5.14.1	Objective	90
6.5.14.2	Preparation.....	90
6.5.14.3	Activities	90
6.5.14.4	Verdict.....	90
6.5.14.5	Evidence	90
6.5.15	REQ-SU-14 Updates not applied from expired sources.....	90
6.5.15.1	Objective	90
6.5.15.2	Preparation.....	91
6.5.15.3	Activities	91
6.5.15.4	Verdict.....	91
6.5.15.5	Evidence	91
6.6	Authentication and access control	91
6.6.1	Overview	91
6.6.2	REQ-AAC-01 Authentication of cybersecurity-relevant nodes	91
6.6.2.1	Objective	91
6.6.2.2	Preparation.....	91
6.6.2.3	Activities	91
6.6.2.4	Verdict.....	91
6.6.2.5	Evidence	91
6.6.3	REQ-AAC-02 Encryption of transmitted credentials.....	92
6.6.3.1	Objective	92
6.6.3.2	Preparation.....	92
6.6.3.3	Activities	92
6.6.3.4	Verdict.....	92
6.6.3.5	Evidence	92
6.6.4	REQ-AAC-03 Authentication timeout.....	92
6.6.4.1	Objective	92
6.6.4.2	Preparation.....	92
6.6.4.3	Activities	92
6.6.4.4	Verdict.....	93
6.6.4.5	Evidence	93
6.6.5	REQ-AAC-04 Cloned credentials detection	93
6.6.5.1	Objective	93
6.6.5.2	Preparation.....	93
6.6.5.3	Activities	93
6.6.5.4	Verdict.....	93
6.6.5.5	Evidence	93
6.6.6	REQ-AAC-05 Forced revocation of authorization of endpoints	93
6.6.6.1	Objective	93
6.6.6.2	Preparation.....	93
6.6.6.3	Activities	93
6.6.6.4	Verdict.....	94
6.6.6.5	Evidence	94
6.6.7	REQ-AAC-06 Brute force protection.....	94
6.6.7.1	Objective	94
6.6.7.2	Preparation.....	94
6.6.7.3	Activities	94
6.6.7.4	Verdict.....	94
6.6.7.5	Evidence	94
6.6.8	REQ-AAC-07 Authorization of endpoints.....	94

6.6.8.1	Objective	94
6.6.8.2	Preparation.....	94
6.6.8.3	Activities	95
6.6.8.4	Verdict.....	95
6.6.8.5	Evidence	95
6.6.9	REQ-AAC-08 Fine-grain access control.....	95
6.6.9.1	Objective	95
6.6.9.2	Preparation.....	95
6.6.9.3	Activities	95
6.6.9.4	Verdict.....	95
6.6.9.5	Evidence	95
6.7	Confidentiality protection	95
6.7.1	Overview	95
6.7.2	REQ-CON-01 VPN routing stays in effect until VPN connection deactivated.....	96
6.7.2.1	Objective	96
6.7.2.2	Preparation.....	96
6.7.2.3	Activities	96
6.7.2.4	Verdict.....	96
6.7.2.5	Evidence	96
6.7.3	REQ-CON-02 VPN routing stays in effect during network-level tunnel failure.....	96
6.7.3.1	Objective	96
6.7.3.2	Preparation.....	96
6.7.3.3	Activities	96
6.7.3.4	Verdict.....	97
6.7.3.5	Evidence	97
6.7.4	REQ-CON-03 Tunnel all traffic by default.....	97
6.7.4.1	Objective	97
6.7.4.2	Preparation.....	97
6.7.4.3	Activities	97
6.7.4.4	Verdict.....	97
6.7.4.5	Evidence	97
6.7.5	REQ-CON-04 Endpoint to endpoint encryption	97
6.7.5.1	Objective	97
6.7.5.2	Preparation.....	98
6.7.5.3	Activities	98
6.7.5.4	Verdict.....	98
6.7.5.5	Evidence	98
6.7.6	REQ-CON-05 Inform user of visibility of DNS queries	98
6.7.6.1	Objective	98
6.7.6.2	Preparation.....	98
6.7.6.3	Activities	98
6.7.6.4	Verdict.....	98
6.7.6.5	Evidence	98
6.7.7	REQ-CON-06 Configurable exclusive DNS routing	99
6.7.7.1	Objective	99
6.7.7.2	Preparation.....	99
6.7.7.3	Activities	99
6.7.7.4	Verdict.....	99
6.7.7.5	Evidence	99
6.7.8	REQ-CON-07 Exclusive DNS routing by default.....	99
6.7.8.1	Objective	99
6.7.8.2	Preparation.....	99
6.7.8.3	Activities	99
6.7.8.4	Verdict.....	99
6.7.8.5	Evidence	99
6.7.9	REQ-CON-08 DNS configuration consistency	100
6.7.9.1	Objective	100
6.7.9.2	Preparation.....	100
6.7.9.3	Activities	100
6.7.9.4	Verdict.....	100
6.7.9.5	Evidence	100
6.7.10	REQ-CON-09 Secure DNS protocols	100

6.7.10.1	Objective	100
6.7.10.2	Preparation.....	100
6.7.10.3	Activities	100
6.7.10.4	Verdict.....	101
6.7.10.5	Evidence	101
6.7.11	REQ-CON-10 No DNS leaks during network-level tunnel failure	101
6.7.11.1	Objective	101
6.7.11.2	Preparation.....	101
6.7.11.3	Activities	101
6.7.11.4	Verdict.....	101
6.7.11.5	Evidence	101
6.7.12	REQ-CON-11 Block IPv6 if Unsupported.....	101
6.7.12.1	Objective	101
6.7.12.2	Preparation.....	102
6.7.12.3	Activities	102
6.7.12.4	Verdict.....	102
6.7.12.5	Evidence	102
6.7.13	REQ-CON-12 Full Support if Claimed.....	102
6.7.13.1	Objective	102
6.7.13.2	Preparation.....	102
6.7.13.3	Activities	102
6.7.13.4	Verdict.....	102
6.7.13.5	Evidence	102
6.7.14	REQ-CON-13 Use conformant cryptography	102
6.7.14.1	Objective	102
6.7.14.2	Preparation.....	103
6.7.14.3	Activities	103
6.7.14.4	Verdict.....	103
6.7.14.5	Evidence	103
6.7.15	REQ-CON-14 Confidentiality of data stored on the product	103
6.7.15.1	Objective	103
6.7.15.2	Preparation.....	103
6.7.15.3	Activities	103
6.7.15.4	Verdict.....	103
6.7.15.5	Evidence	103
6.7.16	REQ-CON-15 Inform user of limits of privacy protection	104
6.7.16.1	Objective	104
6.7.16.2	Preparation.....	104
6.7.16.3	Activities	104
6.7.16.4	Verdict.....	104
6.7.16.5	Evidence	104
6.8	Integrity protection	104
6.8.1	Overview	104
6.8.2	REQ-INT-01 VPN client restores any system configuration it changes to its previous state after the VPN connection ends	104
6.8.2.1	Objective	104
6.8.2.2	Preparation.....	104
6.8.2.3	Activities	104
6.8.2.4	Verdict.....	105
6.8.2.5	Evidence	105
6.8.3	REQ-INT-02 VPN client provides a method to restore any system configuration it changes to its previous state.....	105
6.8.3.1	Objective	105
6.8.3.2	Preparation.....	105
6.8.3.3	Activities	105
6.8.3.4	Verdict.....	105
6.8.3.5	Evidence	105
6.8.4	REQ-INT-03 VPN client does not degrade system security	106
6.8.4.1	Objective	106
6.8.4.2	Preparation.....	106
6.8.4.3	Activities	106
6.8.4.4	Verdict.....	106

6.8.4.5	Evidence	106
6.8.5	REQ-INT-04 Protocol validity checks	106
6.8.5.1	Objective	106
6.8.5.2	Preparation.....	106
6.8.5.3	Activities	106
6.8.5.4	Verdict.....	107
6.8.5.5	Evidence	107
6.8.6	REQ-INT-05 Application protocol validity checks by operational environment	107
6.8.6.1	Objective	107
6.8.6.2	Preparation.....	107
6.8.6.3	Activities	107
6.8.6.4	Verdict.....	107
6.8.6.5	Evidence	107
6.9	Data minimisation.....	107
6.9.1	Overview	107
6.9.2	REQ-DM-01 Data minimisation across the product	107
6.9.2.1	Objective	107
6.9.2.2	Preparation.....	108
6.9.2.3	Activities	108
6.9.2.4	Verdict.....	108
6.9.2.5	Evidence	108
6.9.3	REQ-DM-02 No Personal Data sent outside endpoint	108
6.9.3.1	Objective	108
6.9.3.2	Preparation.....	108
6.9.3.3	Activities	108
6.9.3.4	Verdict.....	109
6.9.3.5	Evidence	109
6.9.4	REQ-DM-03 Minimise Personal Data required service provisioning and payment	109
6.9.4.1	Objective	109
6.9.4.2	Preparation.....	109
6.9.4.3	Activities	109
6.9.4.4	Verdict.....	109
6.9.4.5	Evidence	110
6.9.5	REQ-DM-04 Minimise Personal Data stored.....	110
6.9.5.1	Objective	110
6.9.5.2	Preparation.....	110
6.9.5.3	Activities	110
6.9.5.4	Verdict.....	110
6.9.5.5	Evidence	110
6.9.6	REQ-DM-05 No data persistence or storage enabled on exit nodes	110
6.9.6.1	Objective	110
6.9.6.2	Preparation.....	110
6.9.6.3	Activities	111
6.9.6.4	Verdict.....	111
6.9.6.5	Evidence	111
6.10	Availability protection	111
6.10.1	Overview	111
6.10.2	REQ-AP-01 Fast packet drop.....	111
6.10.2.1	Objective	111
6.10.2.2	Preparation.....	111
6.10.2.3	Activities	111
6.10.2.4	Verdict.....	111
6.10.2.5	Evidence	112
6.10.3	REQ-AP-02 Limit memory usage.....	112
6.10.3.1	Objective	112
6.10.3.2	Preparation.....	112
6.10.3.3	Activities	112
6.10.3.4	Verdict.....	112
6.10.3.5	Evidence	112
6.10.4	REQ-AP-03 Availability protection provided by operational environment	112
6.10.4.1	Objective	112
6.10.4.2	Preparation.....	113

6.10.4.3	Activities	113
6.10.4.4	Verdict	113
6.10.4.5	Evidence	113
6.10.5	REQ-AP-04 Rate limit unauthenticated traffic	113
6.10.5.1	Objective	113
6.10.5.2	Preparation.....	113
6.10.5.3	Activities	113
6.10.5.4	Verdict.....	113
6.10.5.5	Evidence	113
6.11	Non-interference	114
6.11.1	Overview	114
6.11.2	REQ-IM-01 No route between different endpoints by default	114
6.11.2.1	Objective	114
6.11.2.2	Preparation.....	114
6.11.2.3	Activities	114
6.11.2.4	Verdict.....	114
6.11.2.5	Evidence	114
6.11.3	REQ-IM-02 : Minimise data transmitted to unverified sources	114
6.11.3.1	Objective	114
6.11.3.2	Preparation.....	114
6.11.3.3	Activities	114
6.11.3.4	Verdict.....	115
6.11.3.5	Evidence	115
6.12	Attack surface minimisation	115
6.12.1	Overview	115
6.12.2	REQ-MAS-01 Unnecessary VPN client permissions	115
6.12.2.1	Objective	115
6.12.2.2	Preparation.....	115
6.12.2.3	Activities	115
6.12.2.4	Verdict.....	115
6.12.2.5	Evidence	115
6.13	Exploit mitigation	116
6.13.1	Overview	116
6.13.2	REQ-EMM-01 Route traffic from other sources/destination disabled by default	116
6.13.2.1	Objective	116
6.13.2.2	Preparation.....	116
6.13.2.3	Activities	116
6.13.2.4	Verdict.....	116
6.13.2.5	Evidence	116
6.13.3	REQ-EMM-02 Notify user if routing traffic from other sources/destination	116
6.13.3.1	Objective	116
6.13.3.2	Preparation.....	116
6.13.3.3	Activities	116
6.13.3.4	Verdict.....	117
6.13.3.5	Evidence	117
6.13.4	REQ-EMM-03 No routing traffic from other sources/destination if not necessary for services	117
6.13.4.1	Objective	117
6.13.4.2	Preparation.....	117
6.13.4.3	Activities	117
6.13.4.4	Verdict.....	117
6.13.4.5	Evidence	117
6.14	Monitoring	117
6.14.1	Overview	117
6.14.2	REQ-LOG-01 Local event logging	117
6.14.2.1	Objective	117
6.14.2.2	Preparation.....	118
6.14.2.3	Activities	118
6.14.2.4	Verdict.....	118
6.14.2.5	Evidence	118
6.14.3	REQ-LOG-02 Internal event logging	118
6.14.3.1	Objective	118
6.14.3.2	Preparation.....	118

6.14.3.3	Activities	118
6.14.3.4	Verdict	119
6.14.3.5	Evidence	119
6.14.4	REQ-LOG-03 Remote Logging	119
6.14.4.1	Objective	119
6.14.4.2	Preparation	119
6.14.4.3	Activities	119
6.14.4.4	Verdict	119
6.14.4.5	Evidence	119
6.14.5	REQ-LOG-04 Privacy-preserving logs policy and traffic anonymization	120
6.14.5.1	Objective	120
6.14.5.2	Preparation	120
6.14.5.3	Activities	120
6.14.5.4	Verdict	120
6.14.5.5	Evidence	120
6.15	Factory reset and data portability	120
6.15.1	Overview	120
6.15.2	REQ-DRT-01 Secure deletion via "factory reset"	120
6.15.2.1	Objective	120
6.15.2.2	Preparation	120
6.15.2.3	Activities	121
6.15.2.4	Verdict	121
6.15.2.5	Evidence	121
6.15.3	REQ-DRT-02 Secure deletion via reinstallation	121
6.15.3.1	Objective	121
6.15.3.2	Preparation	121
6.15.3.3	Activities	121
6.15.3.4	Verdict	121
6.15.3.5	Evidence	122
6.15.4	REQ-DRT-03 Secure data read from product	122
6.15.4.1	Objective	122
6.15.4.2	Preparation	122
6.15.4.3	Activities	122
6.15.4.4	Verdict	122
6.15.4.5	Evidence	122
6.15.5	REQ-DRT-04 Secure data export	122
6.15.5.1	Objective	122
6.15.5.2	Preparation	122
6.15.5.3	Activities	123
6.15.5.4	Verdict	123
6.15.5.5	Evidence	123

Annex A (informative):	Relationship between the present document and the essential cybersecurity requirements of EU Regulation (EU) 2024/2847	124
-------------------------------	---	------------

Annex B (informative):	Security analysis	127
-------------------------------	--------------------------------	------------

B.0	Overview	127
B.1	Assets	127
B.1.0	Overview	127
B.1.1	Data assets	127
B.1.2	Product functions	127
B.1.3	Digital assets	128
B.1.4	Human-associated assets	128
B.1.5	Hardware assets	128
B.2	Risk factors	128
B.2.1	General	128
B.2.2	RF-CFG: Endpoint configuration	129
B.2.3	RF-AUT: Account management and authentication of endpoints	129
B.2.4	RF-DTX: Sensitivity of data transmitted	129
B.2.5	RF-DST: Sensitivity of data stored	129

B.2.6	RF-FUN: Sensitivity of functions	129
B.2.7	RF-ADM: Availability and skill of administration	130
B.2.8	RF-RDP: Manufacturer infrastructure isolation.....	130
B.2.9	RF-DNC: Difficulty of network configuration	130
B.2.10	RF-COM: Complexity of feature set	130
B.2.11	RF-MSH: Mesh connectivity offered	131
B.2.12	RF-PRI: Consequences of compromise of privacy	131
B.2.13	RF-UAP: Consequences of unauthorized access to private network	131
B.2.14	RF-NUM: Number of nodes in private network	131
B.2.15	RF-NET: Public accessibility of network	132
B.3	Assumptions	132
B.3.0	Overview	132
B.3.1	Platform	132
B.3.2	Proper administrator	132
B.3.3	Attacker has limited physical access to product	132
B.3.4	Attacker has limited resources	132
B.4	Threats and security analysis.....	132
B.4.1	General.....	132
B.4.2	Security analysis methodology	133
B.4.3	TH-UEVU: Unknown exploitable vulnerabilities	133
B.4.4	TH-KEVU: Known exploitable vulnerabilities	134
B.4.5	TH-UEAC: Unauthorized endpoint access	135
B.4.6	TH-DOSA: Denial of service attack	136
B.4.7	TH-MITM: Machine-in-the-middle.....	137
B.4.8	TH-DLEK: Sensitive DNS query leaks	137
B.4.9	TH-PLNS: Transmitting sensitive data in the clear in a single endpoint VPN	139
B.4.10	TH-PLNM: Transmitting sensitive data in the clear in multi-endpoint VPN	140
B.4.11	TH-LDEL: Unknown compromise of endpoint.....	141
B.4.12	TH-CNFS: Access to assets via configuration errors in single endpoint VPN	141
B.4.13	TH-CNFM: Access to assets via configuration errors in a multi-endpoint VPN.....	143
B.4.14	TH-META: Compromise of privacy due to metadata and traffic analysis	144
B.4.15	TH-RCOM: Compromise of privacy via RDPS	144
B.4.16	TH-DSTR: Unauthorized access to data stored on product	145
B.4.17	TH-HINT: Interference with host	146
B.5	Mapping of use cases to risk factors	147
B.6	Risks not treated by the requirements	147
B.7	Mapping of risks to requirements.....	148
B.8	Accounting of requirements for each use case	148
B.8.0	Introduction.....	148
B.8.1	UC-1 Individual consumer.....	148
B.8.2	UC-2 Privacy conscious household	150
B.8.3	UC-3 Journalist, activist, legal professionals.....	152
B.8.4	UC-4 Small enterprise, small not-for-profit organization.....	154
B.8.5	UC-5 Large enterprise	155
B.8.6	UC-6 Enterprise with independent VPN infrastructure	157
B.8.7	UC-7 Mesh Network.....	158

Annexes C to

J:	Void
.....	161

Annex K (normative): Generic requirements and assessment criteria for the use of state of the art cryptography.....162

K.1	Cryptography.....	162
K.1.1	Requirement.....	162
K.1.2	Assessment of product cryptographic configuration.....	163
K.1.2.1	General	163

K.1.2.2	Assessment of ACM-listed cryptographic mechanisms	163
K.1.2.2.1	Objective	163
K.1.2.2.2	Assessment preparation	163
K.1.2.2.3	Assessment activities	163
K.1.2.2.4	Assessment evidence	163
K.1.2.2.5	Assessment verdict	164
K.1.2.3	Assessment of ACM-extended cryptographic mechanisms	164
K.1.2.3.1	Assessment objective	164
K.1.2.3.2	Assessment preparation	164
K.1.2.3.3	Assessment activities	164
K.1.2.3.4	Assessment evidence	164
K.1.2.3.5	Assessment verdict	165
K.2	Crypto agility	165
K.2.1	Requirement	165
K.2.2	Assessment of crypto-agility	166
K.2.2.1	Assessment objective	166
K.2.2.2	Assessment preparation	166
K.2.2.3	Assessment activities	166
K.2.2.4	Assessment evidence	166
K.2.2.5	Assessment verdict	167
K.3	ACM-extended cryptographic mechanisms	167
K.3.1	Requirement	167
K.3.2	List of ACM-extended cryptographic mechanisms	167
K.3.3	Assessment	169
K.4	Interoperability-based cryptographic mechanisms	169

Annexes L to

Q:	Void
.....	170

Annex R (normative): Remote Data Processing Solutions171

R.1	Scope & Applicability	171
R.2	RDPS as a product-boundary extension	171
R.3	Threat Model	172
R.3.1	Introduction	172
R.3.2	Assets	172
R.3.3	Threat catalogue	173
R.3.3.1	Overview	173
R.3.3.2	T-RDPS-01 Loss of data authenticity of interactions across the RDPS boundary	173
R.3.3.3	T-RDPS-02 Loss of integrity of interactions across the RDPS boundary	173
R.3.3.4	T-RDPS-03 Unauthorized disclosure of interactions across the RDPS boundary	174
R.3.3.5	T-RDPS-04 Unavailability, unacceptable delay, or intolerable degradation of interactions across the RDPS boundary	174
R.3.4	Assets to Threats mapping	174
R.4	Security Requirements	174
R.4.1	Applicability of Annex R requirements	174
R.4.2	Local product side requirements	175
R.4.2.1	REQ-RDPS-L-AUTH Data authenticity of interactions received from the RDPS side	175
R.4.2.2	REQ-RDPS-L-INTEG Integrity of interactions received from the RDPS side	175
R.4.2.3	REQ-RDPS-L-CONF Confidentiality of data exchanged with the RDPS side	175
R.4.2.4	REQ-RDPS-L-AVAIL Availability	175
R.4.3	RDPS side requirements	176
R.4.3.1	REQ-RDPS-R-AUTH Data authenticity of interactions received from the local product side	176
R.4.3.2	REQ-RDPS-R-INTEG Integrity of interactions received from the local product side	176
R.4.3.3	REQ-RDPS-R-CONF Confidentiality of data exchanged with the local product side	176
R.4.3.4	REQ-RDPS-R-AVAIL Availability	176
R.4.4	Threats ↔ Requirements mapping	177

R.5	Conformity assessment	177
R.5.1	Overview	177
R.5.2	Local product side assessments	177
R.5.2.1	REQ-RDPS-L-AUTH assessment.....	177
R.5.2.1.1	Objective	177
R.5.2.1.2	Preparation.....	177
R.5.2.1.3	Activities	178
R.5.2.1.4	Verdict.....	178
R.5.2.1.5	Evidence	178
R.5.2.2	REQ-RDPS-L-INTEG assessment.....	178
R.5.2.2.1	Objective	178
R.5.2.2.2	Preparation.....	178
R.5.2.2.3	Activities	178
R.5.2.2.4	Verdict.....	179
R.5.2.2.5	Evidence	179
R.5.2.3	REQ-RDPS-L-CONF assessment	179
R.5.2.3.1	Objective	179
R.5.2.3.2	Preparation.....	179
R.5.2.3.3	Activities	179
R.5.2.3.4	Verdict.....	180
R.5.2.3.5	Evidence	180
R.5.2.4	REQ-RDPS-L-AVAIL assessment	180
R.5.2.4.1	Objective	180
R.5.2.4.2	Preparation.....	180
R.5.2.4.3	Activities	180
R.5.2.4.4	Verdict.....	181
R.5.2.4.5	Evidence	181
R.5.3	RDPS side assessments.....	181
R.5.3.1	REQ-RDPS-R-AUTH assessment	181
R.5.3.1.1	Objective	181
R.5.3.1.2	Preparation.....	181
R.5.3.1.3	Activities	181
R.5.3.1.4	Verdict.....	182
R.5.3.1.5	Evidence	182
R.5.3.2	REQ-RDPS-R-INTEG assessment.....	182
R.5.3.2.1	Objective	182
R.5.3.2.2	Preparation.....	182
R.5.3.2.3	Activities	182
R.5.3.2.4	Verdict.....	182
R.5.3.2.5	Evidence	183
R.5.3.3	REQ-RDPS-R-CONF assessment.....	183
R.5.3.3.1	Objective	183
R.5.3.3.2	Preparation.....	183
R.5.3.3.3	Activities	183
R.5.3.3.4	Verdict.....	183
R.5.3.3.5	Evidence	183
R.5.3.4	REQ-RDPS-R-AVAIL assessment	184
R.5.3.4.1	Objective	184
R.5.3.4.2	Preparation.....	184
R.5.3.4.3	Activities	184
R.5.3.4.4	Verdict.....	184
R.5.3.4.5	Evidence	184
Annex S (informative):	Change history	186
History		187

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)) may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025)618 final [i.3] to provide one voluntary means of conforming to the essential requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Introduction

The present document provides the technical cybersecurity requirements for the products in scope, following a risk-based approach in support of the Cyber Resilience Act (CRA) [i.1]. The technical cybersecurity requirements are thereby proportionate to the intended purpose, reasonably foreseeable use, deployment context, and threat exposure of the products.

[Clause 4](#) does not contain technical requirements; it describes the product context that is considered for the application of this standard.

[Clause 4](#) also defines Use Cases (UCs) that represent the main deployment scenarios reflecting the intended purpose and reasonably foreseeable use of the product, which serve as the basis for identifying relevant cybersecurity risks.

[Clause 5](#) specifies technical cybersecurity requirements for the product to mitigate the identified risks, including their applicability conditions.

[Clause 6](#) specifies the assessment criteria and compliance verification procedures with the requirements of [clause 5](#).

Annex A maps the technical requirements of the present document with the essential requirements of the CRA [i.1] regulation.

Annex B informs about the methodology used to assess the security risks of the products in their context.

Annex K supports the definition of the cryptographic requirements and assessment criteria used by the present document.

Annex R provides supplementary requirements and assessment provisions where a product relies on Remote Data Processing Solutions (RDPS) for the provision or support of one or more product functions.

1 Scope

The present document specifies technical requirements and corresponding assessment criteria for Virtual Private Networks related to cybersecurity. The products with digital elements in scope, thereafter "VPNs":

- are specified within the "technical description" of the "category of product" number "5" by the Commission Implementing Regulation (EU) 2025/2392 [i.2] as: "Products with digital elements that establish an encrypted logical tunnel that is constructed from the system resources of a physical or virtual network".
- are only covered within the product context described in [clause 4](#) and the text of this clause.

In particular, the present document specifies technical characteristics and methods of assessment for:

- 1) Software that operates as a VPN client or endpoint
- 2) Software that operates as a node within a mesh VPN network
- 3) Software that operates as a VPN server
- 4) Remote data processing, specifically VPN server software performing the logical server role, and associated software used for such VPN products

The present document covers those products to demonstrate compliance with essential cybersecurity requirements in the Regulation (EU) 2024/2847 [i.1] Annex I Part I under the conditions identified in Annex A.

VPN hardware or appliances, and control mechanisms for mesh VPNs are excluded from the present document.

VPNs intended for use in the industrial Operational Technology (OT) domain are excluded from the scope of the present document, see prEN 50770 series [i.5].

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- [1] [ENISA Report 1747792503](#) (version 2 - April 2025): "European Cybersecurity Certification Group Sub-group on Cryptography Agreed Cryptographic Mechanisms".

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding, but are not required for conformance to the present document.

- [i.1] [Regulation \(EU\) 2024/2847](#) of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).
 - [i.2] [Commission Implementing Regulation \(EU\) 2025/2392](#) of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council.
 - [i.3] [Standardisation request M/606 - C\(2025\)618](#): "Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (CENELEC) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)".
 - [i.4] prEN 40000-1-1: "Cybersecurity requirements for products with digital elements – Vocabulary" (produced by CEN CENELEC).
- NOTE: Version and date to be added upon its publication by CEN CENELEC.
- [i.5] prEN 50770 series: "Security for operational technologies" (produced by CENELEC).
 - [i.6] [Regulation \(EU\) 2019/881](#) of the European Parliament and of the Council of 17 April 2019 on ENISA (the European Union Agency for Cybersecurity) and on information and communications technology cybersecurity certification and repealing Regulation (EU) No 526/2013 (Cybersecurity Act).
 - [i.7] [IEEE™-ITSO 6100 \(1.0.0\)](#): "Uptane Standard for Design and Implementation". .
 - [i.8] [Recommendation ITU-T X.509](#): "Information technology - Open Systems Interconnection - The Directory: Public-key and attribute certificate frameworks". .
 - [i.9] [Regulation \(EU\) 2016/679](#) of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).
 - [i.10] [ETSI TS 104 103 \(V1.1.1\) \(2025-09\)](#): "Cyber Security (CYBER); Encrypted Traffic Integration (ETI); Problem Statement review and requirements definition". .
 - [i.11] [IRTF RFC 7748](#): "Elliptic Curves for Security".
 - [i.12] [IRTF RFC 8032](#): "Edwards-Curve Digital Signature Algorithm (EdDSA)".
 - [i.13] [NIST FIPS 186-5](#): "Digital Signature Standard (DSS)".
 - [i.14] [IRTF RFC 9106](#): "Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications".
 - [i.15] [BSI TR-02102-1 \(2026-01\)](#): "Cryptographic Mechanisms: Recommendations and Key Lengths".
 - [i.16] [IETF RFC 7914](#): "The scrypt Password-Based Key Derivation Function".
 - [i.17] [IRTF RFC 8439](#): "ChaCha20 and Poly1305 for IETF Protocols".
 - [i.18] [IETF RFC 7693](#): "The BLAKE2 Cryptographic Hash and Message Authentication Code (MAC)".
 - [i.19] [IETF RFC 4418](#): "UMAC: Message Authentication Code using Universal Hashing".
 - [i.20] [IETF draft-irtf-cfrg-aegis-aead-18](#): "The AEGIS Family of Authenticated Encryption Algorithms".

- [i.21] [NIST IR 7896](#): "Third-Round Report of the SHA-3 Cryptographic Hash Algorithm Competition".
- [i.22] EUVD: [EU Vulnerability Database of ENISA](#).
- [i.23] [C2SP BLAKE3](#): "The BLAKE₃ Hashing Framework".
- [i.24] [Commission Recommendation of 6 May 2003](#) concerning the definition of micro, small and medium-sized enterprises.

3 Definition of terms, symbols, abbreviations and naming conventions

3.1 Terms

For the purposes of the present document, the terms given in Regulation (EU) 2024/2847 [i.1], prEN 40000-1-1 [i.4] and the following apply:

cloud: data centre or collection of data centres operated entirely by a third party which rents out space and time on their equipment, as well as providing services for managing infrastructure from outside networks

cryptographic mechanism: security-related procedure using cryptography

NOTE 1: The term "cryptographic mechanism" is used as an umbrella term covering the categories used in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1], including cryptographic algorithms, primitives, schemes, protocols, protocol profiles, cipher suites, modes of operation, constructions and parameter sets.

NOTE 2: The terms "cryptographic primitive", "cryptographic construction", "cryptographic scheme" and "cryptographic protocol" are used consistently with the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1].

NOTE 3: A cryptographic mechanism can be specified at different levels of abstraction. For example, AES is a cryptographic primitive, AES-GCM is a mode of operation / authenticated encryption construction, TLS 1.3 is a protocol, a TLS 1.3 restricted cipher-suite profile is a protocol profile, and TLS_AES_128_GCM_SHA256 is a cipher suite.

cryptographic property: property provided or supported by a cryptographic mechanism

NOTE 1: Cryptographic properties include, for example, confidentiality, integrity, authenticity, entity authentication, message authentication, key establishment, key confirmation, replay protection, collision resistance, second-preimage resistance, pre-image resistance, signature unforgeability, non-repudiation, forward secrecy and password-verifier protection. Where relevant, a cryptographic property can be expressed using a formal cryptographic notion, for example IND-CPA, IND-CCA, IND-CCA2, EUF-CMA, SUF-CMA or authenticated key exchange security.

NOTE 2: A cryptographic property is distinct from a product-level technical requirement, although it can support such a requirement. For example, a secure communication requirement can rely on cryptographic properties such as confidentiality, integrity and authentication.

cybersecurity: "the activities necessary to protect network and information systems, the users of such systems, and other persons affected by cyber threats"

NOTE: See Article 2, point (1), of Regulation (EU) 2019/881 [i.6]

endpoint: node or component within a node at the end of a VPN connection that decrypts and encrypts, rather than merely routing data

NOTE: In VPNs, endpoint is typically used to refer to client devices. In mesh networks, this could be any node.

exit node: VPN server software which routes packets to and from their intended destination

node: member of a VPN topology

personal data: "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person"

NOTE: See (EU) 2016/679 General Data Protection Regulation [i.9]

system configuration: set of settings that a VPN client may modify to establish, maintain, or terminate a VPN connection

NOTE: A complete system configuration can include, but is not limited to, routing tables, DNS configuration, firewall rules, network interfaces, NAT settings and proxy settings.

Virtual Private Network (VPN): "products with digital elements that establish an encrypted logical tunnel that is constructed from the system resources of a physical or virtual network"

NOTE: This includes cases where that product provides access from a restricted-use logical computer network to the public internet.

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

ACM	Agreed Cryptographic Mechanisms
AES	Advanced Encryption Standard
CPU	Central Processing Unit
CRA	Cyber Resilience Act
CRL	Certificate Revocation List
DLEK	DNS Query Leak
DNS	Domain Name Server
DoH	DNS over HTTPS
DoT	DNS over TLS
ECCG	European Cybersecurity Certification Group
EDR	Endpoint Detection and Response
EUVD	EU Vulnerability Database
GCM	Galois/Counter Mode
HINT	Host Interference
HKDF	HMAC-based extract-and-expand Key Derivation Function
HMAC	Hash-based Message Authentication Code
HTTPS	Hypertext Transfer Protocol Secure
IAM	Identity and Access Management
IDP	Identity Provider
IoT	Internet of Things
IP	Internet Protocol
IPC	Inter Process Communication
ISP	Internet Service Provider
IT	Information Technology
MAC	Message Authentication Code
MITM	Machine-In-The-Middle
MSH	Mesh connectivity
NAT	Network Address Translation
NVRAM	Non-Volatile Random-Access Memory
OCSP	Online Certificate Status Protocol
OS	Operating System
OT	Operational Technology
PKI	Public Key Infrastructure
PSK	Pre-Shared Key

PwDE	Products with Digital Elements
RAM	Random Access Memory
RDPS	Remote Data Processing Solution
SaaS	Software as a Service
SBOM	Software Bill Of Materials
SIEM	Security Information and Event Management
SNI	Server Name Indication
TLS	Transport Layer Security
TPM	Trusted Platform Module
TUF	The Update Framework
TV	Television
UI	User Interface
UMAC	Message Authentication Code using Universal hashing
URL	Uniform Resource Locator
VPN	Virtual Private Network

3.4 Naming conventions

For the purposes of the present document, the following naming conventions apply:

AAC	Authentication and Access Control
ADM	Administration
AP	Availability Protection
CFG	Configuration
CON	Confidentiality
DA	Assets
DM	Data Minimisation
DOSA	Denial Of Service Attack
DRT	Data Reset and portability
EMM	Exploitation Mitigation
INT	Integrity
KEV/KEVU	Known Exploitable Vulnerabilities
LOG	Logging
MAS	Minimisation of Attack Surface
NUM	Number
PRI	Loss of Privacy
REQ	Requirement
RF	Risk Factor
SBD	Secure By Default
SSD	Secure Software Design and Development
SU	Security Updates
TH	Threat
UC	Use Case
UEVU	Unknown Exploitable Vulnerabilities

4 Product context

4.1 Product Functions

4.1.1 Overview

The VPN product is a collection of software running on different devices, contextually referred to as nodes. **Each element may have a different set of functionality** and may be more or less trusted than other elements. How the functionality and trust are distributed vary according to the architecture (see [clause 4.4](#)) and use case (see [clause 4.6](#)) of the VPN. For example, a VPN intended to protect the end user devices from surveillance would prefer an architecture that did not trust any node not controlled by that user.

4.1.2 Potential functions of a node

4.1.2.1 Authentication

- Confirms identity and credentials of user, or verifies credentials with third-party identity provider.
- Establishes a tunnel between devices.

4.1.2.2 Access control

- Determines end user devices, VPN servers, and exit nodes to which the user may direct traffic.

4.1.2.3 Traffic encryption

- Hides the contents of traffic sent through the tunnel.

4.1.2.4 Routing

- Obfuscates the source or destination address of traffic sent through the tunnel.
- Routes restricted-use network traffic in or out of specific nodes, or a public network like the internet.

4.1.2.5 Filtering

- Inspects packets to determine which traffic may transit through the node.

4.1.3 Potential roles of nodes

Roles of nodes in VPNs (a node can have some or all):

- Authorization: grant nodes access to the restricted use network
- Encryption: encrypts traffic within the confines of the restricted use network
- Edge: uses a public network to communicate with the restricted use network
- Gateway: provides link between public network and restricted use network
- Router: forwards traffic between nodes in the restricted use network
- Filter: selects which traffic may transit this node in the restricted use network
- Relay: assists nodes in connecting to the restricted use network

4.1.4 Capabilities of nodes

During normal operation, VPN nodes may:

- Authorize other nodes to use the restricted use network
- Request authorization to use the restricted network
- Serve configuration information
- Update their configuration information
- Assist nodes in connecting to the restricted use network
- Send traffic between nodes on the restricted use network
- Send traffic from the restricted use network to the public network

- Send traffic from the public network to the restricted use network
- Filter traffic transiting a node according to complex rules
- Leave the restricted network
- Revoke the access of a node to the restricted use network
- Validate the payload prior to its encryption in VPN [i.10]

4.2 Product Architecture

4.2.1 Product overview

As a complete product, a Virtual Private Network includes, at minimum, software capable of establishing a secure encrypted tunnel between two or more devices.

In consumer deployments, the most common state-of-the-art implementation is a product that provides a secure tunnel to one or more servers - usually operated by the manufacturer as "exit nodes" - which then route traffic to its originally intended destination, typically on a public network like the Internet.

In enterprise wide area deployments, a common state-of-the-art implementation is a product with digital elements that provides a secure overlay network to one or more servers that enable routing of traffic between remote restricted-use enterprise networks.

VPNs also require management capabilities such as user and group management, access control, logging, and monitoring. For large enterprise use cases, these capabilities are usually provided as part of the product's local installation, whereas in consumer and small business use cases management capabilities are usually controlled by the manufacturer as part of the remote data processing aspect of the product. Mesh VPNs may use a fully peer-to-peer approach to management or a remote data processing approach.

The product consists of any client software installed as described above as well as any functionality that processes data on manufacturer-controlled infrastructure that is required for the product to operate as expected.

4.2.2 Network topology and relationship between nodes

Virtual Private Networks can differ in topologies used to transmit data and distribute configuration. Two common distinct topologies are hub-and-spoke networks and mesh networks; in practice, networks can use more complex mixed topologies that fall somewhere in between the two extremes.

In a hub-and-spoke network, multiple clients connect to a single VPN server/gateway, which provides both management and routing capabilities to the clients.

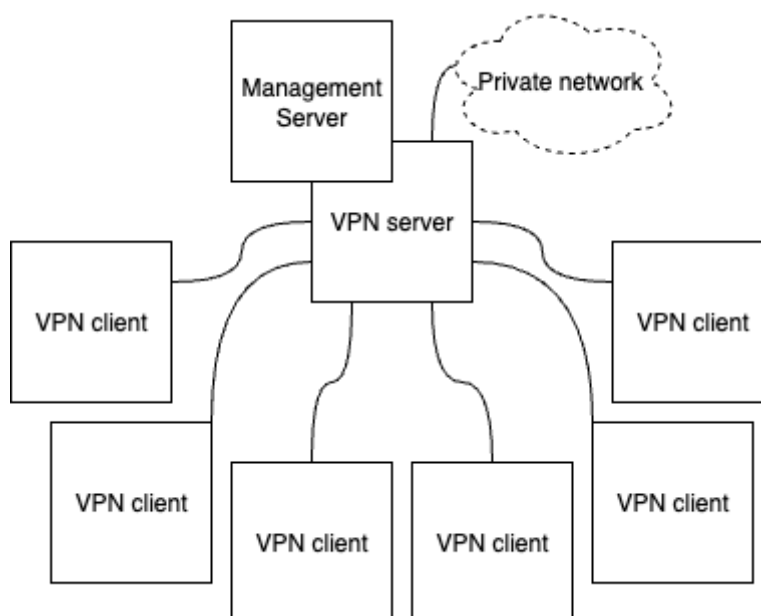


Figure 4.2.2-1: A diagram illustrating a hub-and-spoke network

In a mesh network, clients and gateways establish direct tunnels between each other. A management server is used to authenticate VPN clients and gateways, and to configure nodes.

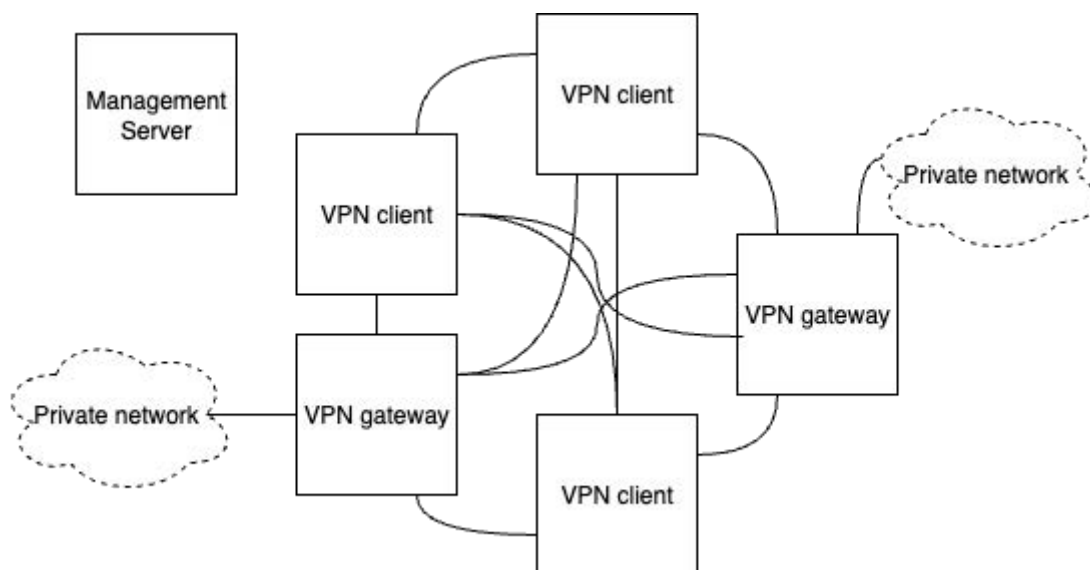


Figure 4.2.2-2: A diagram illustrating a mesh network

4.2.3 VPN client

For the purpose of the current document, a VPN client is a software application responsible for connecting a single endpoint (such as a computing device or home router) to VPN servers, VPN gateways, or peer nodes. A VPN client typically uses authentication credentials provided by the manufacturer or administrator and input by the user to establish secure tunnel(s).

After establishing a tunnel, the VPN client changes configuration of the host device operating system to facilitate connections to the private network - this can include changes to DNS configuration, firewall rules, routing table, etc. This configuration is tailored to the end-user, and may be based on a combination of local user or administrator preferences and policies configured by the VPN manufacturer. A VPN client could have an option to perform traffic validation prior to sending the data through the established secure tunnel [i.10].

4.2.4 VPN server, VPN gateway

4.2.4.1 Server & gateway responsibilities

While [clause 4.1](#) establishes that any node within a VPN network may dynamically fulfill various operational roles, the terms "VPN server" and "VPN gateway" are used to describe nodes primarily dedicated to aggregation, routing, and access control.

A **VPN server** is responsible for maintaining secure tunnels between multiple VPN clients and the traffic destinations the clients are requesting. It typically enforces centralized authentication, authorization, and traffic filtering policies. In decentralized or mesh VPN architectures, a "server" is not necessarily a dedicated, centralized appliance; rather, it is a logical role that any authorized peer node can assume to route traffic or act as an exit node for other peers.

A **VPN gateway** specifically fulfills the gateway role, acting as the secure bridge between the restricted-use VPN network and external networks, such as a private corporate intranet or a public network like the internet.

4.2.4.2 Server & gateway remote data processing

When VPNs are reliant on servers, gateways, or "exit nodes" operated by the manufacturer, those operations make up an important part of the product architecture. These typically serve the same functions as any other server or gateway, but remain entirely under the control of the manufacturer instead of being deployed on customer infrastructure. Where the product relies on a Remote Data Processing Solution (RDPS) for the provision or support of one or more product functions, such reliance introduces a product-facing RDPS boundary between the local product side and the RDPS side. RDPS-side VPN servers and gateways are held to the same requirements as any other VPN server or gateway, in addition to the requirements laid out in Annex R.

4.2.5 Management server

A VPN management server provides a way for network administrators to control configuration and membership of their network and is necessary for the product to operate as expected. This can include:

- Identity and authentication: management of users and groups, authentication credentials.
- Access control: policies that permit or deny certain traffic within the network.
- Monitoring and logging: configuration logs, network logs, telemetry used for troubleshooting.

The management server typically maintains configuration of the whole network and provides configuration to individual clients at the time of connection (authentication, address assignment, routes, etc). In VPNs using a hub-and-spoke topology, management server is often implemented as part of the VPN server. For consumer and small-business use cases as described in [clause 4.6](#), this server is considered remote data processing and fully controlled by the manufacturer. Mesh networks may use a management server operated by the manufacturer as part of their remote data processing solution, or may handle all management in a peer-to-peer fashion.

4.3 Operational Environment

4.3.1 General description

In many cases products get deployed in environments which allow risk transfer as security functions are handled by the operational environment. Such examples might include updates managed through a package manager or application store, or where the denial-of-service protections and package filtering through an external firewall.

4.3.2 Hardware environment

The physical environment a VPN product may be deployed in affects the applicable risks and enables potential risk transfers. VPN products may be deployed in various different environments such as different physical devices as well as different physical networks.

There are various types of devices, but all share that the firewall is managed by the underlying system and outside the control of the VPN product:

- **Network devices:** VPN products are often deployed on network devices to tunnel traffic to remote endpoints. Such network devices (for example a router) are usually located on the edge between a private and public network and thus exposed to internal as well as external attack surfaces. A firewall is usually included by the underlying OS or hardware system for such network devices.
- **Internet of Things, Consumer Gadgets and Appliances:** VPN products could be deployed on IoT devices, consumer gadgets, TVs or other appliances where the product is bound to the security model of the device hardware and operating system. The device might lack proper hardware security modules, firewall support, or enforce a relaxed security model (for example requiring the product to run as root without proper isolation between applications and users). Such devices are usually placed in private networks.
- **Consumer Devices:** VPN products are often deployed on consumer devices such as tablets, computers, mobile devices or laptops of various operating systems. The product is bound to the security model of the hardware and operating system. While such devices usually support firewalls and proper user isolation, the actual security configuration of such systems depends on the security awareness of the operating administrating user and the configuration limitations of the underlying system. Consumer devices are located in private networks.
- **Managed Endpoints:** Managed endpoints are professionally managed instances which are usually located on a physical or virtual server in a data centre. While the firewall configuration is done by the administrating user, this user is assumed to have advanced security knowledge. Further, the server is usually located in an access restricted data centre which transfers physical risk (for example memory snapshotting or injections) to the data centre provider.

Devices might be located in insecure networks, which could include one or even a combination of the following networks:

- **Secure professionally managed environment:** In professionally managed environments usually utilize a securely managed firewall, isolated network and application environments, properly configured and hardened operating systems, as well as proper security event monitoring to detect intruders or malicious activities. Devices are usually located in an access restricted environment such as data centers or private homes.
- **Private network:** Private networks are usually an isolated network which is protected by the router's firewall configuration. Devices deployed inside the private network can freely communicate which imposes a risk if one or many of the devices in the private network is compromised. Network traffic in such environment could be intercepted and inspected on outbound network devices. Physical risks to devices located in a private network are unlikely since most of the devices are located in the private and access restricted environment of the user.
- **Public network:** Public networks usually lack proper security configuration and network traffic might be eavesdropped, tampered or intercepted. The network may contain hostile devices and malicious users since the environment is not access restricted.
- **Restricted/Monitored Networks:** Access to certain content might be restricted in certain networks through deep package inspection. Internet service providers or network administrators might restrict or disallow VPN traffic affecting the availability of the VPN connection.

4.3.3 Software environment

VPNs can be expected to operate in a network environment alongside other Important products such as Identity and Access Management Systems, Network Interfaces, Routers, Firewalls, and SIEM systems. Manufacturers are expected to harden VPN attack surfaces against potential attack vectors from compromised PwDEs, but in particular those considered Important and Critical. See [clause 4.5](#) for further information about the relationship between VPNs and related software.

A VPN requires an existing physical or virtual network whose resources it can use. The underlying network provides the functions necessary to connect to at least one node of the VPN.

Functions the underlying network provides:

- Physical equipment capable of transmitting network traffic

- Routing/forwarding of network traffic

A VPN product runs on a node in the context of an operating system, as an application, a library, a service, a driver, a kernel service, or a combination thereof. The operating system may provide:

- Network stack
- Virtual or physical network interfaces
- Network configuration
- DNS and other network services
- Certificate authority services
- Encryption
- Application support
- Packet filtering
- Denial-of-service protection
- Software installation and update
- Payload traffic validation [i.10]

VPN products often include or are used in concert with:

- Network management systems
- Security information and event monitoring
- Distributed log collection and monitoring
- Firewalls

4.3.4 Connectivity aspects

The main purpose of a VPN is to connect different endpoints together through a secure tunnel. To do so many different connections have to be established, such as connectivity with the manufacturer's RDPS to retrieve credentials, connectivity to the VPN server to establish a secure tunnel, but also routing packages from the endpoint or through the endpoint in case the VPN client is deployed to route network traffics from a whole private network. All these connectivity aspects come with specific risks which are mitigated by the application of cybersecurity controls such as those found in [clause 5](#).

4.4 Distribution of Security Functions

4.4.1 Cybersecurity function distribution overview

This clause describes the two-way relationship where the VPN product both delegates risks and provides cybersecurity functionalities to other components in its ecosystem.

The cybersecurity of a VPN product is dependent on a chain of trust that spans across multiple components in its operational environment. Consequently, the VPN product delegates certain risks to other components while offering cybersecurity functionalities that mitigate different risks for those same components.

4.4.2 Cybersecurity Functionalities Offered to Integrated Components

The VPN product offers the following cybersecurity functionalities to other components in its operational environment:

- **Secure Data Transport:** The primary function of a VPN is to create a secure, encrypted tunnel over an untrusted network. This functionality protects all network traffic originating from the client device or network from eavesdropping and other network-based attacks.
- **Controlled Network Access:** The VPN client acts as a cybersecurity gatekeeper for the remote network. This functionality protects the remote network by only allowing authenticated and authorized traffic to pass through.

4.4.3 Cybersecurity functions required from the environment

The following risks are delegated by the VPN product to other components within its operational environment:

- **Operating System stability and Runtime Environment robustness:** A VPN product relies on a secure and stable underlying Operating System (OS) to function. The risks associated with OS vulnerabilities or a compromised runtime environment are delegated to the OS.
- **Hardware Integrity:** The VPN product depends on the integrity of the physical hardware for the confidentiality of cryptographic keys and data processing. Risks of physical tampering or hardware-based attacks are delegated to the hardware manufacturer.
- **Identity and Authentication:** The VPN product delegates the risks associated with user credential management to a trusted Identity and Access Management (IAM) system. It relies on this external component for secure authentication and authorization of users.

4.5 Users

To ensure that the cybersecurity requirements address the specific threats faced by different market segments, the users of VPN products are categorized into groups based on their operational needs, level of cybersecurity expertise, and risk profiles. This categorization considers both direct end-users and integrators, and prioritizes the privacy, safety, and accessibility of the product for all individuals. These user groups directly correspond to the Use Cases (UC) detailed in [clause 4.6](#):

- **Everyday Consumers and Vulnerable Groups (Refers to UC-1, UC-2):** This group represents the general public, specifically including vulnerable populations such as children and the elderly, as well as individuals with limited cybersecurity knowledge. Their primary needs include securing personal traffic on untrusted networks and obfuscating online activity to avoid tracking. This segment requires highly accessible, secure-by-default configurations that accommodate users with disabilities who may rely on assistive technology to operate the product securely.
- **High-Risk Privacy Seekers (Refers to UC-3):** This group represents individuals at a severe risk of targeted surveillance (e.g. privacy-conscious users operating in hostile environments). Their primary need is advanced privacy preservation to protect their personal safety, health, and human rights against capable adversaries and unsanctioned state actors.
- **Small Organization Users (Refers to UC-4):** This group represents users operating within smaller entities lacking dedicated, full-time network administration. Their primary need is establishing secure remote connections to necessary operational resources, heavily relying on manufacturer-managed services to prevent misconfigurations.
- **Enterprise Integrators and Administrators (Refers to UC-5, UC-6, UC-7):** This group represents professional users, integrators, and administrators with privileged rights and professional cybersecurity training. Their primary needs include securely connecting multiple endpoints to private corporate networks, managing complex VPN infrastructures, and conducting extensive traffic inspection for security purposes.
- **Indirect Users:** Where a VPN product (such as a VPN-enabled router) is deployed in a public space, the product design also is expected to consider the cybersecurity needs, privacy, and safety of indirect users who are impacted by or whose traffic passes through the device.

4.6 Use Cases

4.6.1 Introduction to Use Cases

This list of use cases is an informative resource to the manufacturer to simplify choosing a set of cybersecurity requirements. It is not an exhaustive list, and deployments may cross over more than one use.

See Commission Recommendation of 6 May 2003 [i.24] for formal definitions of micro, small, and medium-sized enterprises.

4.6.2 UC-1 Individual consumer

- **Goal:** Secure personal traffic on untrusted access networks; obfuscate location of origin IP.
- **Description:**
 - **Product type:** Software that operates as a VPN client.
 - **Function:** Tunnels encrypted traffic to avoid tracking and eavesdropping on public or untrusted networks.
 - **Users:** Everyday Consumers and Vulnerable Groups (as defined in [clause 4.5](#)).
 - **Architecture:** Client installed on personal devices (mobile phones, portable or desktop computers) communicating with exit nodes managed by the manufacturer. Does not connect endpoints with other endpoints directly.
 - **Operational environment:** Untrusted access networks.

4.6.3 UC-2 Privacy conscious household

- **Goal:** Obfuscate traffic and IP to avoid tracking by ISPs and data brokers.
- **Description:**
 - **Product type:** Software that operates as a VPN client (and optionally software that operates as a VPN Gateway).
 - **Function:** Tunnels encrypted traffic to user-managed infrastructure, or to manufacturer-managed exit nodes.
 - **Users:** Everyday Consumers (as defined in [clause 4.5](#)).
 - **Architecture:** Client typically installed on a router or other network level to protect the household. The VPN infrastructure may be entirely owned, rented, or managed by the user, or the client may communicate with exit nodes managed by the manufacturer. Does not connect endpoints with other endpoints directly.
 - **Operational environment:** Private home networks.

4.6.4 UC-3 Journalist, activist, legal professionals

- **Goal:** Actively circumvent observation from competitors, hackers, opponents, and unsanctioned state actors.
- **Description:**
 - **Product type:** Software that operates as a VPN client.
 - **Function:** Advanced privacy preservation and surveillance evasion.
 - **Users:** High-Risk Privacy Seekers (as defined in [clause 4.5](#)).

- **Architecture:** Client installed on personal devices. Strict endpoint isolation (does not connect endpoints with other endpoints directly).
- **Operational environment:** Hostile networks with high risk of surveillance.

4.6.5 UC-4 Small enterprise, small not-for-profit organization

- **Goal:** Establish secure remote connections primarily to SaaS products and operational resources.
- **Description:**
 - **Product type:** VPN client and remote data processing software.
 - **Function:** Secure connection to cloud resources with manufacturer-managed configuration.
 - **Users:** Small Organization Users (as defined in [clause 4.5](#)).
 - **Architecture:** Requires managed service for configuration and maintenance. May connect endpoints with other endpoints directly.
 - **Operational environment:** Small enterprise networks with limited or no full-time IT/network administration. Not critical for core business operations.

4.6.6 UC-5 Large enterprise

- **Goal:** Securely connect many endpoints to a private network and inspect traffic extensively for security.
- **Description:**
 - **Product type:** VPN client, gateway, and server software.
 - **Function:** Enterprise-wide secure overlay network.
 - **Users:** Enterprise Integrators and Administrators (as defined in [clause 4.5](#)).
 - **Architecture:** Requires managed service for configuration and maintenance, typically from manufacturer. Connects endpoints with other endpoints directly.
 - **Operational environment:** Critical for business operations, managed by full-time IT/network administration.

4.6.7 UC-6 Enterprise with independent VPN infrastructure

- **Goal:** Provide partial or full-time remote access to an enterprise network.
- **Description:**
 - **Product type:** VPN client, VPN server, and enterprise gateway software.
 - **Function:** Secure remote access to one or some remote networks via an enterprise gateway.
 - **Users:** Enterprise Integrators and Administrators (managing), Everyday Consumers/Enterprise Workers (using).
 - **Architecture:** Configuration pushed via gateway and/or third-party solutions. Device and client lifecycle managed by administrators via dedicated tools.
 - **Operational environment:** Most security is managed by other components (e.g. local EDR for endpoint security).

4.6.8 UC-7 Mesh Network

- **Goal:** Connect multiple endpoint traffic over untrusted access networks without centralized routing.

- **Description:**
 - **Product type:** Software that operates as a node within a mesh VPN network.
 - **Function:** Decentralized routing and tunnelling.
 - **Users:** Enterprise Integrators and Administrators (managing), Everyday Consumers/Enterprise Workers (using).
 - **Architecture:** Client installed on various devices (mobile phones, laptops, servers). Connects endpoints with other endpoints directly. Connection management operated by manufacturer.
 - **Operational environment:** Untrusted access networks.

5 Technical requirements for products

5.1 Introduction - Applicability of the requirements

The technical requirements of the present document apply under the product context described in [clause 4](#), which shall be in accordance with its intended use. The product shall comply with all applicable technical requirements of the present document at all times when operating in such a product context.

Not all requirements are universally applicable: The applicability of requirements may be based on use cases described in [clause 4.6](#) or specific capabilities of the product. Each requirement clearly indicates its applicability, and all requirements are mapped to use cases in Table 5.1. The applicability of requirements is based on the security analysis in Annex B, using the [product assets](#) and [risk factors](#) derived from the characteristics of each use case.

Table 5.1: Requirement to use case mapping

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-SSD-01	x ¹	x ¹	x ¹	x ¹	x ¹	x ¹	x ¹
REQ-SSD-02	x ¹	x ¹	x ¹	x ¹	x ¹	x ¹	x ¹
REQ-SSD-03	x	x	x	x	x		x ²
REQ-KEV-01	x	x	x	x	x	x	x
REQ-SBD-01	x	x	x		x	x	
REQ-SU-01	x	x	x	x	x	x	x
REQ-SU-02	x	x	x	x	x	x	x
REQ-SU-03					x ³		
REQ-SU-04	x	x	x	x	x ³	x	x
REQ-SU-05					x ⁴		
REQ-SU-06	x	x	x	x	x ⁴	x	x
REQ-SU-07	x	x	x	x		x	x
REQ-SU-08	x	x	x	x		x	x
REQ-SU-09	x	x	x	x		x	x
REQ-SU-10	x	x	x	x		x	x
REQ-SU-11	x	x	x	x		x	x
REQ-SU-12	x	x	x	x		x	x
REQ-SU-13	x	x	x	x		x	x
REQ-SU-14	x	x	x	x		x	x
REQ-AAC-01	x	x	x	x	x	x	x
REQ-AAC-02	x	x	x	x	x	x	x
REQ-AAC-03		x	x	x	x	x	x
REQ-AAC-04		x	x	x	x	x	x
REQ-AAC-05				x ⁵	x ⁵	x ⁵	x ⁵
REQ-AAC-06	x	x	x	x	x	x	x
REQ-AAC-07	x	x	x	x	x	x	x
REQ-AAC-08			x ⁶	x ⁶	x ⁶	x ⁶	x ⁶

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-CON-01		x	x	x	x	x	x
REQ-CON-02		x	x		x	x	x
REQ-CON-03			x		x	x	
REQ-CON-04							x
REQ-CON-05		x	x				x
REQ-CON-06		x	x				x
REQ-CON-07			x				
REQ-CON-08			x				
REQ-CON-09			x				
REQ-CON-10			x				
REQ-CON-11	x	x	x	x	x	x	x
REQ-CON-12	x	x	x	x	x	x	x
REQ-CON-13	x	x	x	x	x	x	x
REQ-CON-14	x	x	x	x	x	x	x
REQ-CON-15		x	x				x
REQ-INT-01	x	x	x	x	x	x	x
REQ-INT-02	x	x	x	x	x	x	x
REQ-INT-03	x	x	x	x	x	x	x
REQ-INT-04		x ⁷	x ⁷	x ⁷	x ⁷	x ⁷	x ⁷
REQ-INT-05		x ⁷	x ⁷	x ⁷	x ⁷	x ⁷	x ⁷
REQ-DM-01	x	x	x	x	x	x	x
REQ-DM-02		x	x	x	x		x
REQ-DM-03		x	x	x	x		x
REQ-DM-04		x	x				x
REQ-DM-05	x	x	x	x			x
REQ-AP-01	x ⁸	x ⁸	x ⁹	x ⁸	x ⁹	x ⁹	x ⁸
REQ-AP-02	x ⁸	x ⁸	x ⁹	x ⁸	x ⁹	x ⁹	x ⁸
REQ-AP-03	x ⁸	x ⁸	x ⁹	x ⁸	x ⁹	x ⁹	x ⁸
REQ-AP-04			x ⁹		x ⁹	x ⁹	
REQ-IM-01		x	x				
REQ-IM-02	x	x	x	x	x	x	x
REQ-MAS-01		x	x	x	x	x	x
REQ-EMM-01	x	x	x	x	x	x	x
REQ-EMM-02	x	x	x	x	x	x	x
REQ-EMM-03	x	x	x	x	x	x	x
REQ-LOG-01	x†	x†	x†	x†	x†	x†	x†
REQ-LOG-02	x†	x†	x†	x†	x†	x†	x†
REQ-LOG-03	x				x	x	
REQ-LOG-04		x	x				x
REQ-DRT-01	x	x	x	x	x	x	x
REQ-DRT-02	x		x				
REQ-DRT-03	x	x	x	x	x	x	x
REQ-DRT-04	x	x	x	x	x	x	x

- x¹ REQ-SSD-01 OR REQ-SSD-02
- x² required if product requires RDPS for the provision or support of any product function
- x³ REQ-SU-03 OR REQ-SU-04
- x⁴ REQ-SU-05 OR REQ-SU-06
- x⁵ applies where risk factor [RF-UAP](#) is > 0

- x⁶ applies where risk factor [RF-MSH](#) is 2
- x⁷ REQ-INT-04 OR REQ-INT-05
- x⁸ REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02)
- x⁹ REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02 AND REQ-AP-04)
- x[†] REQ-LOG-01 or REQ-LOG-02 is indicated based on risk factor [RF-PRI](#)

Some risks may be transferred partially or fully to other components of the system or the user of the product. When that is the case, mitigations that transfer the risk will be included as an option to fulfill a cybersecurity requirement, depending on the use case and risk factors.

5.2 Appropriate level of cybersecurity

5.2.1 Overview

5.2.1.1 CRA Relevance

This clause addresses the requirements in the CRA [i.1] Annex I Part I (1).

In alignment with the CRA [i.1] Annex I Part I (1), this clause addresses overarching risks and mitigations regarding the secure design and development of the product that are not specifically treated by other categorical essential requirements (such as confidentiality, access control, or security updates). The requirements herein ensure the final product itself embodies security by design.

5.2.1.2 Secure software design and development

Use cases (as described in [clause 4.6](#) and Annex B) determine which of these controls should be utilized to mitigate threats around secure software design and development. In particular, across all use cases only one - at most - of the following two is called for when applied to a single product: REQ-SSD-01 or REQ-SSD-02. See [clause B.4.3](#) for more information.

5.2.2 REQ-SSD-01 Memory access error prevention

5.2.2.1 Requirement

The product shall be free of *common memory errors* that may pose a cybersecurity risk.

NOTE: Examples of *common memory errors* include, but may not be limited to:

- buffer overflow
- out-of-bounds
- use after free
- double free
- use of uninitialized variables
- dereference of invalid pointer
- race conditions
- integer overflow

5.2.2.2 Applicability

- UC-1: REQ-SSD-01 OR REQ-SSD-02 apply

- UC-2: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-3: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-4: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-5: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-6: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-7: REQ-SSD-01 OR REQ-SSD-02 apply

5.2.3 REQ-SSD-02 Resilience against potentially untrusted inputs

5.2.3.1 Requirement

All cybersecurity-relevant parts of the product shall implement methods to validate untrusted inputs and mitigate the effects thereof.

5.2.3.2 Applicability

- UC-1: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-2: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-3: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-4: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-5: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-6: REQ-SSD-01 OR REQ-SSD-02 apply
- UC-7: REQ-SSD-01 OR REQ-SSD-02 apply

5.2.4 REQ-SSD-03 Applicability of Annex R

5.2.4.1 Requirement

Where the product relies on a Remote Data Processing Solution (RDPS) for the provision or support of one or more product functions, the product shall satisfy the applicable requirements specified in Annex R.

NOTE: Annex R specifies supplementary requirements for the product-facing RDPS *boundary* and does not replace the requirements applicable to the product *function* as such.

5.2.4.2 Applicability

This requirement applies to all products which provide any manner of RDPS, including:

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: not required
- UC-7: required if product requires RDPS for the provision or support of any product function

5.2.4.3 Guidance

This requirement does not apply to UC-6 because by definition that use case does not utilize any RDPS. If a product requires RDPS to fulfill any product function, it does not fall under UC-6.

5.2.5 Mapping of requirements to use cases

Table 5.2.5: Appropriate level of cybersecurity requirements mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-SSD-01	x ¹	x ¹	x ¹	x ¹	x ¹	x ¹	x ¹
REQ-SSD-02	x ¹	x ¹	x ¹	x ¹	x ¹	x ¹	x ¹
REQ-SSD-03	x	x	x	x	x		x ²

- x¹ REQ-SSD-01 OR REQ-SSD-02 apply
- x² required if product requires RDPS for the provision or support of any product function

5.3 No known exploitable vulnerabilities

5.3.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (a).

It's important that products be regularly tested to demonstrate the absence or mitigation of vulnerabilities. Specifically, known *exploitable* vulnerabilities that impact the product's architecture, platform, and the specific software components identified in the product's Software Bill of Materials (SBOM).

To demonstrate compliance, the manufacturer may rely on manual security testing (e.g. penetration testing), automated vulnerability scanners, or a combination of both, depending on what is most comprehensive and technically feasible for the product's technology stack.

5.3.2 REQ-KEV-01 Testing for known exploitable vulnerabilities

5.3.2.1 Requirement

- 1) **REQ-KEV-01-1** The product shall have no known exploitable vulnerabilities discovered during testing, or
- 2) **REQ-KEV-01-2** the product shall not have any known exploitable vulnerabilities discovered during testing that were reported within the previous 14 days, or the time period permitted before public disclosure as described in the vulnerability handling procedure for the product, or
- 3) **REQ-KEV-01-3** the product shall have no known exploitable vulnerabilities discovered during testing that do not have associated publicly-available documentation explaining the risk and how that risk has been mitigated.

5.3.2.2 Applicability

All products and use cases shall fulfill **at least one** of the above sub-requirements, REQ-KEV-01-1, REQ-KEV-01-2, or REQ-KEV-01-3.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required

- UC-6: required
- UC-7: required

5.3.2.3 Guidance

From a practical standpoint, a known exploitable vulnerability is a flaw that has the potential to be effectively used by an adversary under practical operational conditions, particularly those for which there is reliable evidence of active exploitation in the wild by malicious actors and/or is listed on trusted vulnerabilities databases, such as the EUVD [i.22].

5.3.3 Mapping of requirements to use cases

Table 5.3.3: Known exploitable vulnerabilities mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-KEV-01	x	x	x	x	x	x	X

5.4 Secure by default configuration

5.4.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (b).

NOTE: The CRA essential requirement laid out in Annex I Part I (2) (b) foresees an applicability exception to the secure configuration by default in case there is an agreement between manufacturer and business user in relation to a tailor-made product with digital elements.

5.4.2 REQ-SBD-01 Unintentional disabling of cybersecurity features

5.4.2.1 Requirement

User interfaces, especially in regard to settings, shall be designed in a manner that prevents unintentional disabling of default cybersecurity features.

5.4.2.2 Applicability

This requirement applies to the subset of products in the indicated use cases which include a graphical user interface.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: not required
- UC-5: required
- UC-6: required
- UC-7: not required

5.4.3 Mapping of requirements to use cases

Table 5.4.3: Secure by default mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-SBD-01	x	x	x		x	x	

5.5 Security updates

5.5.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (c).

5.5.2 REQ-SU-01 Automatic secure update before or during first use

5.5.2.1 Requirement

The product shall implement automatic secure update before or during first use.

5.5.2.2 Applicability

This requirement applies to the subset of products within the indicated use cases that have the capability to self-update, i.e. not distributed by an "app store" or package distribution platform that manages all updates.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.5.3 REQ-SU-02 Automatic secure update via operational environment before or during first use

5.5.3.1 Requirement

The product shall implement secure update via the operational environment before or during first use.

5.5.3.2 Applicability

This requirement applies to the subset of products within the indicated use cases that have security updates applied via the operational environment, such as the operating system itself, an "app store", or some external platform.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required

- UC-5: required
- UC-6: required
- UC-7: required

5.5.4 REQ-SU-03 Secure update via product

5.5.4.1 Requirement

The product shall provide a method of securely updating any software in the product via the product itself.

5.5.4.2 Applicability

This requirement applies to the subset of products within the indicated use cases that have the capability to self-update, i.e. not distributed by an "app store" or package distribution platform that manages all updates.

- UC-1: not required
- UC-2: not required
- UC-3: not required
- UC-4: not required
- UC-5: REQ-SU-03 OR REQ-SU-04 apply
- UC-6: not required
- UC-7: not required

5.5.5 REQ-SU-04 Automatic secure update via product

5.5.5.1 Requirement

- 1) **REQ-SU-04-1** The product shall provide a method of automatically securely updating any software in the product via the product itself, and
- 2) **REQ-SU-04-2** the product shall provide an option for the administrating user to disable or defer automatic updates.

NOTE: Enterprise customers may have a business need to either delay or force updates to any node with access to a private network.

5.5.5.2 Applicability

This requirement applies to the subset of products within the indicated use cases that have the capability to self-update, i.e. not distributed by an "app store" or package distribution platform that manages all updates.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: REQ-SU-03 OR REQ-SU-04 apply
- UC-6: required
- UC-7: required

5.5.6 REQ-SU-05 Secure update provided by operational environment

5.5.6.1 Requirement

The technical documentation provided with the product shall document that the operational environment provides a method of securely updating the product.

5.5.6.2 Applicability

This requirement applies to the subset of products within the indicated use cases that have security updates applied via the operational environment, such as the operating system itself, an "app store", or some external platform.

- UC-1: not required
- UC-2: not required
- UC-3: not required
- UC-4: not required
- UC-5: REQ-SU-05 OR REQ-SU-06 apply
- UC-6: not required
- UC-7: not required

5.5.7 REQ-SU-06 Automatic secure update provided by operational environment

5.5.7.1 Requirement

The user documentation provided with the product shall document that the operational environment provides a method of automatically securely updating the product with an option for the product to be configured to disable automatic updates.

NOTE: Enterprise customers may have a business need to either delay or force updates to any node with access to a private network.

5.5.7.2 Applicability

This requirement applies to the subset of products within the indicated use cases that have security updates applied via the operational environment, such as the operating system itself, an "app store", or some external platform.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: REQ-SU-05 OR REQ-SU-06 apply
- UC-6: required
- UC-7: required

5.5.8 REQ-SU-07 Updates are signed and verified before installation

5.5.8.1 Requirement

- 1) **REQ-SU-07-1** Updates for the product shall be cryptographically signed as defined in Annex K, and
- 2) **REQ-SU-07-2** the product shall verify the signature before installation in order to mitigate the installation of tampered and/or modified updates.

5.5.8.2 Applicability

This requirement applies to the subset of products within the indicated use cases that have the capability to self-update, i.e. not distributed by an "app store" or package distribution platform that manages all updates.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: not required
- UC-6: required
- UC-7: required

5.5.9 REQ-SU-08 Only authorized software updates

5.5.9.1 Requirement

The product shall reject an update that does not match the expected cryptographic hash as defined in Annex K.

5.5.9.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: not required
- UC-6: required
- UC-7: required

5.5.10 REQ-SU-09 Secure update has validly signed hash

5.5.10.1 Requirement

The product shall reject a hash that is not validly signed by an authorized signing authority.

5.5.10.2 Applicability

- UC-1: required

- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: not required
- UC-6: required
- UC-7: required

5.5.10.3 Guidance

The product needs a method of knowing what specific updates are valid for installation. Because of the requirement REQ-SU-10 (rollback protection), the product also needs a method of knowing also which previously-valid updates are no longer valid. A simple way of doing this is by providing the device with a metadata file listing all updates that are valid along with each update's hash, size, and name. The device downloads this metadata file upon each update check, verifies that it is signed by a valid signing key, and performs other necessary checks (such as checking expiry or replacement).

5.5.11 REQ-SU-10 Invalidated update is rejected

5.5.11.1 Requirement

The product shall reject an update file that has been indicated to no longer be valid, even if that update file was valid at some point in the past.

5.5.11.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: not required
- UC-6: required
- UC-7: required

5.5.11.3 Guidance

This requirement should not be interpreted to mean that update systems should always have exactly one valid version, and prevent rollbacks to anything but the most current version. However, it is important that products have a way of determining whether a particular update, that was issued at some point in the past and was trusted at the instant it was issued, should still be trusted.

The exact parameters and criteria by which software releases are considered to be trusted are defined by the manufacturer, determined by the product, its cybersecurity needs, and its intended and reasonably foreseeable uses. Examples of when a software update might be considered to no longer be valid include:

- An old software release is determined to have a critical and remotely-exploitable vulnerability; if that version of software is installed and connected to a network, it is very likely to be compromised.
- An attacker manages to execute a targeted software supply chain attack, and releases a compromised version of a package.

- A product is used in a safety-critical context, and needs to constantly be updated to the latest released version of its firmware to remain in contractual or regulatory compliance for its specific industrial context. The manufacturer therefore repudiates/revokes all previous software versions as soon as a new version is released.

If the update system makes use of a signed metadata file as suggested in the guidance for REQ-SU-09, revoking a particular update is simply a matter of removing it from the metadata file, updating the metadata file's version number, and signing the new version. The product can then download and check the metadata file from the repository.

NOTE: Multiple different versions of software that are *simultaneously* endorsed/trusted for installation do not constitute a "rollback attack". This mitigation specifically applies to the scenario where the software updater on the product/device can be tricked into trusting a software package that is *no longer* valid, or tricked into thinking that an older software version is actually a new update.

5.5.12 REQ-SU-11 Signing keys have strictly scoped usage

5.5.12.1 Requirement

- 1) **REQ-SU-11-1** The key or keys authorized to sign Repository Metadata shall be keys restricted to this specific purpose, and
- 2) **REQ-SU-11-2** update clients shall verify that the key or keys that sign the Repository Metadata are keys authorized for that specific purpose.

5.5.12.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: not required
- UC-6: required
- UC-7: required

5.5.12.3 Guidance

Signing software updates is a very sensitive role. As such, the software update system needs effective controls to ensure that the key used to sign repository metadata is the key intended for that role. This can be accomplished via specifying roles in root metadata as defined in Uptane/TUF (IEEE-ISTO 6100.1.00) [i.7], or can be specified using a PKI system, for example via extended role attributes in an X.509 [i.8] software signing certificate.

5.5.13 REQ-SU-12 Signing keys have not been revoked or otherwise marked untrusted

5.5.13.1 Requirement

The update client shall check for signing key revocation and any other cybersecurity-relevant changes to the chain of trust, each time it checks for an update.

5.5.13.2 Applicability

- UC-1: required
- UC-2: required

- UC-3: required
- UC-4: required
- UC-5: not required
- UC-6: required
- UC-7: required

5.5.13.3 Guidance

If keys are compromised, it is critical that said keys are revoked as soon as possible, and that the revocation reaches each client of the update system. Therefore, the update system needs to check revocation information as part of the update check, and fail closed if revocation information is not available. Uptane/TUF checks would meet this requirement. If using X.509 CRLs, it is important to fail closed if the CRL cannot be fetched. OCSP stapling is possible here as well, but due care should be taken in designing the validity period of the OCSP response. An OCSP response with an extended validity period provides a long attack window in the case of compromised keys.

Some possible reasons (non-exhaustive) the information in a signature envelope could be discovered to be invalid or insufficient for attesting the validity of the signed content at time of update check:

- X.509 cert for one of the signing keys has expired
- X.509 cert for one of the signing keys has been revoked by its issuing authority
- Authority that issued the X.509 cert for one of the signing keys has been revoked
- Signing key has been removed from the set of valid signing keys in TUF/Uptane root metadata

5.5.14 REQ-SU-13 Reject update to current or previous version

5.5.14.1 Requirement

The product shall reject Repository Metadata if its version number is equal to or less than the highest version number the update client has seen.

NOTE: This requirement is about repository metadata. Repository metadata should never be permitted to roll back; it merely communicates the attested validity of a set of software. Software itself can often be permitted to roll back; see also the guidance on **REQ-SU-10** (The product should reject an update file that has been indicated to no longer be valid).

5.5.14.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: not required
- UC-6: required
- UC-7: required

5.5.15 REQ-SU-14 Updates not applied from expired sources

5.5.15.1 Requirement

- 1) **REQ-SU-14-1** Repository Metadata shall have an expiry date included in the signed portion of the metadata, and
- 2) **REQ-SU-14-2** the update client shall verify that repository metadata is not expired before using it.

5.5.15.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: not required
- UC-6: required
- UC-7: required

5.5.16 Mapping of requirements to use cases

Table 5.5.16: Security updates mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-SU-01	x	x	x	x	x	x	x
REQ-SU-02	x	x	x	x	x	x	x
REQ-SU-03					x ³		
REQ-SU-04	x	x	x	x	x ³	x	x
REQ-SU-05					x ⁴		
REQ-SU-06	x	x	x	x	x ⁴	x	x
REQ-SU-07	x	x	x	x		x	x
REQ-SU-08	x	x	x	x		x	x
REQ-SU-09	x	x	x	x		x	x
REQ-SU-10	x	x	x	x		x	x
REQ-SU-11	x	x	x	x		x	x
REQ-SU-12	x	x	x	x		x	x
REQ-SU-13	x	x	x	x		x	x
REQ-SU-14	x	x	x	x		x	x

- x³ REQ-SU-03 OR REQ-SU-04 apply
- x⁴ REQ-SU-05 OR REQ-SU-06 apply

5.6 Authentication and access control

5.6.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (d).

All elements of the product that connect to nodes providing cybersecurity-relevant services shall authenticate the node before using any services from the node.

5.6.2 REQ-AAC-01 Authentication of cybersecurity-relevant nodes

5.6.2.1 Requirement

The VPN client shall require the use of pre-shared secrets, certificates, or fingerprints to authenticate the identity of any cybersecurity-relevant node involved in the VPN connection and establish an initial secure connection.

5.6.2.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.6.2.3 Guidance

When enforcing pre-shared secrets, certificates, or fingerprints, some options may be: TLS certificates already installed on the platform, configuration files containing secrets, credentials provided as part of the product or distributed remotely via an authenticated connection, fingerprints of keys that are distributed on a website or in accompanying documentation, along with instructions to the user on how to verify.

5.6.3 REQ-AAC-02 Encryption of transmitted credentials

5.6.3.1 Requirement

The VPN client shall encrypt all transmitted user credentials or sensitive authentication material used for any supported authentication method or transport protocol.

5.6.3.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.6.4 REQ-AAC-03 Authentication timeout

5.6.4.1 Requirement

The VPN client, server, or other nodes by default shall not use session credentials with indefinite validity.

5.6.4.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.6.5 REQ-AAC-04 Cloned credentials detection

5.6.5.1 Requirement

VPN server or mesh node shall detect when multiple VPN clients are using credentials that should be unique to a VPN client and notify the users of both VPN clients or only allow one connection per credential.

5.6.5.2 Applicability

This requirement applies to the subset of products within the indicated use cases that handle credentials and function in such a way that client credentials can be duplicated.

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.6.6 REQ-AAC-05 Forced revocation of authorization of endpoints

5.6.6.1 Requirement

- 1) **REQ-AAC-05-1** The VPN shall provide a method to force revocation, temporary or permanent, of authorization of an endpoint by an authorized user, and
- 2) **REQ-AAC-05-2** the revocation of authorization of the VPN client shall end the VPN connection for that client by the time the revocation indicates it has completed.

NOTE: In scenarios where credential revocation is a globally distributed process, it may be beneficial to inform the user of a successful submitted credential revocation in addition to informing the user once the process has been completed. For use cases where endpoints are already restricted from being connected to each other, this might be a non-blocking background operation that occurs while the user continues their activities.

5.6.6.2 Applicability

This requirement applies to the subset of products within the indicated use cases where risk factor [RF-UAP](#) is > 0 .

- UC-1: not required
- UC-2: not required
- UC-3: not required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.6.7 REQ-AAC-06 Brute force protection

5.6.7.1 Requirement

The product shall use credentials with at least 128 bit of entropy, or rate-limit authentication attempts.

NOTE: Rate limiting can be implemented in various layers on the application layer or the network layer. If implemented on the application layer, the product is responsible for enforcing appropriate rate limiting in relation to the expected entropy of the credential. If implemented on the network layer, the mitigation may be transferred to the operational environment, in case the operational environment offers sufficient protections, such as firewalls that enforce brute-force protections.

5.6.7.2 Applicability

This requirement applies to the subset of products within the indicated use cases which do not transfer responsibility for rate-limiting to the operating environment.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.6.8 REQ-AAC-07 Authorization of endpoints

5.6.8.1 Requirement

A node shall only allow connections from authorized endpoints.

NOTE 1: Authorized endpoints are those that are explicitly authorized by the user, remote data processing servers, or VPN manufacturer to connect to the endpoint in question.

NOTE 2: Examples where nodes require special authorization are (non-exhaustive list): dedicated IP, dedicated gateways or VPN servers, VPN servers offering additional features, or Mesh nodes.

NOTE 3: Authorization may be provided by the operational environment, such as a VPN only physically accessible from a laboratory or workspace with physical access control.

5.6.8.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.6.9 REQ-AAC-08 Fine-grain access control

5.6.9.1 Requirement

The VPN client shall support fine grant access control configuration to configure the permissions of authorized endpoints.

5.6.9.2 Applicability

This requirement applies to the subset of products within the indicated use cases where risk factor [RF-MSH](#) is > 0.

- UC-1: not required
- UC-2: not required
- UC-3: required if [RF-MSH](#) is 2
- UC-4: required if [RF-MSH](#) is 2
- UC-5: required if [RF-MSH](#) is 2
- UC-6: required if [RF-MSH](#) is 2
- UC-7: required if [RF-MSH](#) is 2

5.6.10 Mapping of requirements to use cases

Table 5.6.10: Authentication and access control mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-AAC-01	x	x	x	x	x	x	x
REQ-AAC-02	x	x	x	x	x	x	x
REQ-AAC-03		x	x	x	x	x	x
REQ-AAC-04		x	x	x	x	x	x
REQ-AAC-05				x ⁵	x ⁵	x ⁵	x ⁵
REQ-AAC-06	x	x	x	x	x	x	x
REQ-AAC-07	x	x	x	x	x	x	x
REQ-AAC-08			x ⁶	x ⁶	x ⁶	x ⁶	x ⁶

- x⁵ applies where risk factor [RF-UAP](#) is > 0
- x⁶ applies where risk factor [RF-MSH](#) is 2

5.7 Confidentiality protection

5.7.1 Overview

5.7.1.1 CRA relevance

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (e).

As confidentiality protection is a fundamental aspect of any VPN's functionality regardless of use case, the requirements in this clause are extensive.

5.7.1.2 Confidentiality of DNS queries

Special attention to DNS queries is required because DNS requests are usually transmitted in plaintext. These requests could be eavesdropped on by an attacker on the wire or the DNS server itself, which could disclose the domains to which the user is trying to connect.

For the purpose of the present clause's requirements, a DNS server is authorized if:

- 1) the DNS server is configured by administrating user, or
- 2) the DNS server is provided by the VPN manufacturer.

NOTE 1: Networks and devices are evolving away from plaintext DNS to "secure DNS", with platforms, browsers, and applications increasingly making DNS queries via TLS or HTTPS requests. Unlike cleartext DNS that uses port 53, use of secure DNS can be harder to identify, inhibiting the enforcement of specific policies to use a specifically configured DNS server.

NOTE 2: The network configuration of a system is frequently changed by multiple different pieces of software, many of which the VPN client has no control over or insight into.

5.7.2 REQ-CON-01 VPN routing stays in effect until VPN connection deactivated

5.7.2.1 Requirement

The product shall only report that the VPN connection is established after it has configured the system in such a way that all traffic intended to be routed through the VPN connection will only exit through the VPN connection until the user or administrator knowingly deactivates the VPN connection.

5.7.2.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.7.3 REQ-CON-02 VPN routing stays in effect during network-level tunnel failure

5.7.3.1 Requirement

The product shall ensure that when the connection to the VPN server is lost at the network level (e.g. due to firewall rules or network outage), no traffic intended for the VPN connection can exit the endpoint outside of the tunnel.

5.7.3.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: not required
- UC-5: required
- UC-6: required
- UC-7: required

5.7.4 REQ-CON-03 Tunnel all traffic by default

5.7.4.1 Requirement

- 1) **REQ-CON-03-1** The VPN client shall by default be configured to route all validated network traffic from the endpoint through the VPN connection, and
- 2) **REQ-CON-03-2** the VPN client shall not offer a configuration that only tunnels traffic from specific applications (e.g. "split tunnelling" or "browser-only mode") as a default setting, and
- 3) **REQ-CON-03-3** the administrating user shall be clearly informed of tunnel policy before enabling it.

5.7.4.2 Applicability

- UC-1: not required
- UC-2: not required
- UC-3: required
- UC-4: not required
- UC-5: required
- UC-6: required
- UC-7: not required

5.7.5 REQ-CON-04 Endpoint to endpoint encryption

5.7.5.1 Requirement

The VPN traffic shall be encrypted using session keys generated and held only by the communicating endpoints; intermediary nodes shall not possess keys capable of decrypting such transitory traffic.

NOTE: In consumer or enterprise VPN scenarios which offer multiple VPN servers, remote data processing usually generates the VPN credentials and populates this to the respective VPN client. This allows the remote data processing service to eavesdrop on the VPN connection since it administers the VPN credentials. In a mesh scenario, the credentials have to be generated and maintained by the endpoint itself to ensure no intermediate party can eavesdrop on the connection.

5.7.5.2 Applicability

- UC-1: not required
- UC-2: not required
- UC-3: not required
- UC-4: not required
- UC-5: not required
- UC-6: not required
- UC-7: required

5.7.6 REQ-CON-05 Inform user of visibility of DNS queries

5.7.6.1 Requirement

- 1) **REQ-CON-05-1** The VPN client shall prominently inform the user of the visibility of DNS queries outside the tunnel under the current configuration and the consequences in simple plain language, focusing on the potential risk and impact to the user of such handling and, where applicable, potential steps to resolve this risk, and
- 2) **REQ-CON-05-2** the product shall require the user to actively confirm having read the information before being able to use the VPN connection.

5.7.6.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required
- UC-7: required

5.7.7 REQ-CON-06 Configurable exclusive DNS routing

5.7.7.1 Requirement

- 1) **REQ-CON-06-1** The VPN client shall offer a configuration option to route all DNS queries that use well-known ports through the VPN connection, or
- 2) **REQ-CON-06-2** the VPN client shall route DNS queries exclusively through the VPN at all times.

5.7.7.2 Applicability

Products within the indicated use cases shall fulfill **at least one** of the above sub-requirements, REQ-CON-06-1, **or** REQ-CON-06-2.

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required
- UC-7: required

5.7.8 REQ-CON-07 Exclusive DNS routing by default

5.7.8.1 Requirement

The VPN client shall route all requests that use well-known DNS query ports through the VPN connection.

5.7.8.2 Applicability

- UC-1: not required
- UC-2: not required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required
- UC-7: not required

5.7.9 REQ-CON-08 DNS configuration consistency

5.7.9.1 Requirement

The VPN client shall respond in a timely manner to changes to local configuration which result in DNS query routing that conflicts with the configured setting. By default, the response shall be to prevent DNS queries from being routed in ways which would violate that configuration.

5.7.9.2 Applicability

This requirement is applicable to products within the indicated use cases where changes in the local DNS configuration would affect the plaintext DNS query visibility outside the tunnel to third parties of the system.

- UC-1: not required
- UC-2: not required
- UC-3: required
- UC-4: not required

- UC-5: not required
- UC-6: not required
- UC-7: not required

5.7.10 REQ-CON-09 Secure DNS protocols

5.7.10.1 Requirement

The VPN client shall block or notify users of potential VPN bypass via encrypted DNS protocols, including requests which use the dedicated port for DNS over TLS (DoT), if the traffic is routed via the VPN connection based on DNS policies.

5.7.10.2 Applicability

- UC-1: not required
- UC-2: not required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required
- UC-7: not required

5.7.11 REQ-CON-10 No DNS leaks during network-level tunnel failure

5.7.11.1 Requirement

The VPN client shall ensure that DNS queries using well-known ports intended for the VPN tunnel are not sent to non-authorized DNS servers when the connection to the VPN server is lost at the network level.

5.7.11.2 Applicability

- UC-1: not required
- UC-2: not required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required
- UC-7: not required

5.7.12 REQ-CON-11 Block IPv6 if Unsupported

5.7.12.1 Requirement

If the VPN does not support IPv6, the VPN client shall block all IPv6 traffic to prevent it from leaking outside the VPN tunnel.

5.7.12.2 Applicability

This requirement applies to all products which do not provide IPv6 support.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.7.13 REQ-CON-12 Full Support if Claimed

5.7.13.1 Requirement

If the VPN claims to support IPv6, it shall provide full support and all cybersecurity requirements in the present document shall apply to IPv6 traffic.

5.7.13.2 Applicability

This requirement applies to the subset of products within the indicated use cases which support IPv6.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.7.14 REQ-CON-13 Use conformant cryptography

5.7.14.1 Requirement

The product shall enforce cryptographic primitives and parameters as defined in Annex K.

NOTE: VPN protocols such as IPSec, Wireguard, OpenVPN and IKEv2 are approved VPN protocols if state-of-the-art cryptography as defined in Annex K is used.

5.7.14.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required

- UC-5: required
- UC-6: required
- UC-7: required

5.7.15 REQ-CON-14 Protect confidentiality of data stored on the product

5.7.15.1 Requirement

The product shall protect the confidentiality of stored data, whether personal or other, from unauthorized access by encrypting relevant data at rest using state-of-the-art mechanisms as defined in Annex K and by using other appropriate technical access controls.

To ensure testability, the product shall explicitly implement protection mechanisms for confidential data stored locally on the endpoint or on remote nodes.

Elements that shall be considered confidential and require protection are, including but not limited to:

- Cryptographic Material & Credentials: Private keys, pre-shared keys (PSK), certificates, user passwords, and authentication tokens.
- Local Logs & Telemetry: Cybersecurity-relevant internal event logs (as defined in REQ-LOG-02), troubleshooting/support logs prepared for transmission to the manufacturer, network configuration audit logs, and network flow logs.
- Configuration & User Data: VPN configuration files containing endpoint details, routing policies, and any stored Personal Data.

Depending on the data type and operational environment, the product shall protect these elements using one or more of the following methods:

- State-of-the-art encryption as defined in Annex K at rest.
- Hardware-backed secrets storage (e.g. Trusted Platform Module (TPM), Secure Enclaves).
- Cryptographic salting and hashing (specifically for stored passwords/secrets).
- Strict environment and file-system permissions restricting read/write access exclusively to the VPN client software and authorized administrators or users.

5.7.15.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.7.16 REQ-CON-15 Inform user of limits of privacy protection

5.7.16.1 Requirement

The product shall inform the user of the limitations of any privacy protection.

5.7.16.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required
- UC-7: required

5.7.17 Mapping of requirements to use cases

Table 5.7.17: Confidentiality mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-CON-01		x	x	x	x	x	x
REQ-CON-02		x	x		x	x	x
REQ-CON-03			x		x	x	
REQ-CON-04							x
REQ-CON-05		x	x				x
REQ-CON-06		x	x				x
REQ-CON-07			x				
REQ-CON-08			x				
REQ-CON-09			x				
REQ-CON-10			x				
REQ-CON-11	x	x	x	x	x	x	x
REQ-CON-12	x	x	x	x	x	x	x
REQ-CON-13	x	x	x	x	x	x	x
REQ-CON-14	x	x	x	x	x	x	x
REQ-CON-15		x	x				x

5.8 Integrity protection

5.8.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (f).

The establishment and ending of a VPN connection should not result in functional changes to the system configuration unless explicitly authorized by the user or administrator.

NOTE: For the purpose of the present document, "system configuration" refers to system configuration details that are strictly relevant to the VPN client's operation.

5.8.2 REQ-INT-01 VPN client restores any system configuration it changes to its previous state after the VPN connection ends

5.8.2.1 Requirement

The VPN client shall restore any system configuration it modified to its state prior to activating the VPN connection after the user or administrator knowingly deactivates the VPN connection.

5.8.2.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.8.3 REQ-INT-02 VPN client provides a method to restore any system configuration it changes to its previous state

5.8.3.1 Requirement

The VPN client shall provide a user or administrator documentation to restore any system configuration it has changed to a state that is functionally equivalent to the state it was in before the VPN connection began, regardless of whether a previous VPN connection was able to complete connection shutdown tasks.

5.8.3.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.8.4 REQ-INT-03 VPN client does not degrade system security

5.8.4.1 Requirement

The VPN client shall not reduce system security after the end of the VPN connection, even if normal connection shutdown tasks have not completed.

NOTE: This is a "fail-closed" requirement - if the VPN connection experiences an unexpected failure, it is better to end with a more restricted/secure network configuration than the configuration before the VPN connection started, than a less restricted network configuration.

5.8.4.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required

- UC-5: required
- UC-6: required
- UC-7: required

5.8.5 REQ-INT-04 Application protocol validity checks

5.8.5.1 Requirement

The VPN client and server shall implement data validity checks on all incoming packets to ensure the packets conform to the expected format and protocol of the restricted network.

5.8.5.2 Applicability

- UC-1: not required
- UC-2: REQ-INT-04 OR REQ-INT-05 apply
- UC-3: REQ-INT-04 OR REQ-INT-05 apply
- UC-4: REQ-INT-04 OR REQ-INT-05 apply
- UC-5: REQ-INT-04 OR REQ-INT-05 apply
- UC-6: REQ-INT-04 OR REQ-INT-05 apply
- UC-7: REQ-INT-04 OR REQ-INT-05 apply

5.8.6 REQ-INT-05 Application protocol validity checks by operational environment

5.8.6.1 Requirement

The product shall provide a method to implement data validity checks on all incoming packets to ensure the packets conform to the expected format and protocol of the restricted network.

5.8.6.2 Applicability

- UC-1: not required
- UC-2: REQ-INT-04 OR REQ-INT-05 apply
- UC-3: REQ-INT-04 OR REQ-INT-05 apply
- UC-4: REQ-INT-04 OR REQ-INT-05 apply
- UC-5: REQ-INT-04 OR REQ-INT-05 apply
- UC-6: REQ-INT-04 OR REQ-INT-05 apply
- UC-7: REQ-INT-04 OR REQ-INT-05 apply

5.8.7 Mapping of requirements to use cases

Table 5.8.7: Integrity protection mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-INT-01	x	x	x	x	x	x	x
REQ-INT-02	x	x	x	x	x	x	x
REQ-INT-03	x	x	x	x	x	x	x
REQ-INT-04		x ⁷	x ⁷	x ⁷	x ⁷	x ⁷	x ⁷
REQ-INT-05		x ⁷	x ⁷	x ⁷	x ⁷	x ⁷	x ⁷

- x⁷ REQ-INT-04 OR REQ-INT-05 apply

5.9 Data minimisation

5.9.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (g).

The product shall not collect data unnecessary for the operation of the product.

5.9.2 REQ-DM-01 Data minimisation across the product

5.9.2.1 Requirement

The product shall not collect Personal Data unless the collection is necessary for an intended purpose of the product, or the user has explicitly authorized it.

5.9.2.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.9.3 REQ-DM-02 No Personal Data sent outside endpoint

5.9.3.1 Requirement

The VPN shall not send or store Personal Data related to its use outside of the endpoint, except for the minimum data strictly necessary in relation to the intended purpose of the product, such as for the confidentiality and availability of the service provision (e.g. unique identifiers, IP addresses meant to ensure the security of the service) user authentication, access control (e.g. endpoint identification, IDP/OIDC integration) and subscription management. No Personal Data shall be collected as part of the core VPN tunnelling and routing functionality.

5.9.3.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: not required
- UC-7: required

5.9.4 REQ-DM-03 Minimise Personal Data required for service provisioning and payment

5.9.4.1 Requirement

- 1) **REQ-DM-03-1** The VPN shall minimise the required Personal Data, and
- 2) **REQ-DM-03-2** the VPN shall collect only the Personal Data strictly necessary to process the payment, manage the subscription, fulfil contractual obligations or other legitimate purposes.

5.9.4.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: not required
- UC-7: required

5.9.5 REQ-DM-04 Minimise Personal Data stored

5.9.5.1 Requirement

The VPN shall not store any Personal Data of the user on the VPN server, gateway or exit node.

5.9.5.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required

- UC-7: required

5.9.6 REQ-DM-05 No data persistence or storage enabled on exit nodes

5.9.6.1 Requirement

- 1) **REQ-DM-05-1** The VPN server, gateway or exit nodes shall utilize an ephemeral infrastructure architecture to technically prevent the persistent storage of user data, traffic metadata, or system logs at the hardware and operating system level, and
- 2) **REQ-DM-05-2** VPN server, gateway or exit nodes shall operate exclusively using volatile memory (e.g. RAM disks or NVRAM) for temporary processing and system logs, without writing to non-volatile disk-based storage. To satisfy cybersecurity monitoring requirements, any non-Personal Data cybersecurity-relevant events shall be logged in volatile memory or securely transmitted to a remote logging system in accordance with REQ-LOG-03.

5.9.6.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: not required
- UC-6: not required
- UC-7: required

5.9.7 Mapping of requirements to use cases

Table 5.9.7: Data minimisation mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-DM-01	x	x	x	x	x	x	x
REQ-DM-02		x	x	x	x		x
REQ-DM-03		x	x	x	x		x
REQ-DM-04		x	x				x
REQ-DM-05	x	x	x	x			x

5.10 Availability protection

5.10.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (h).

VPNs should be designed in a matter that the end product by its very nature protects the availability of essential functions.

5.10.2 REQ-AP-01 Fast packet drop

5.10.2.1 Requirement

The product shall check network traffic from untrusted sources for validity and discard it efficiently, using reasonable efforts to minimise use of system resources on invalid packets.

NOTE: One method of minimising resource use on invalid packets is to do the least resource-intensive validity checks first, and to do validity checks before using system resources based on possibly invalid data. For example, verifying that the length of a packet is valid should be done before verifying that the source address is valid, and both should be done before allocating memory necessary to process a packet of that length.

5.10.2.2 Applicability

- UC-1: REQ-AP-01 OR REQ-AP-03 apply
- UC-2: REQ-AP-01 OR REQ-AP-03 apply
- UC-3: REQ-AP-01 OR REQ-AP-03 apply
- UC-4: REQ-AP-01 OR REQ-AP-03 apply
- UC-5: REQ-AP-01 OR REQ-AP-03 apply
- UC-6: REQ-AP-01 OR REQ-AP-03 apply
- UC-7: REQ-AP-01 OR REQ-AP-03 apply

5.10.3 REQ-AP-02 Limit memory usage

5.10.3.1 Requirement

The product shall limit and fairly allocate memory usage triggered by untrusted input to maintain availability of product functions and the functions of the underlying platform and other products sharing system resources.

NOTE: The product should range-check untrusted input fields that trigger memory allocations and rate-limit or drop input that would allocate enough memory to impair the functions of any part of the system.

5.10.3.2 Applicability

- UC-1: REQ-AP-02 OR REQ-AP-03 apply
- UC-2: REQ-AP-02 OR REQ-AP-03 apply
- UC-3: REQ-AP-02 OR REQ-AP-03 apply
- UC-4: REQ-AP-02 OR REQ-AP-03 apply
- UC-5: REQ-AP-02 OR REQ-AP-03 apply
- UC-6: REQ-AP-02 OR REQ-AP-03 apply
- UC-7: REQ-AP-02 OR REQ-AP-03 apply

5.10.4 REQ-AP-03 Availability protection provided by operational environment

5.10.4.1 Requirement

The product shall provide a method of protecting the availability of the product via the operational environment.

5.10.4.2 Applicability

- UC-1: REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02) apply
- UC-2: REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02) apply

- UC-3: REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02 AND REQ-AP-04) apply
- UC-4: REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02) apply
- UC-5: REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02 AND REQ-AP-04) apply
- UC-6: REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02 AND REQ-AP-04) apply
- UC-7: REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02) apply

5.10.5 REQ-AP-04 Rate limit unauthenticated traffic

5.10.5.1 Requirement

The product shall rate limit traffic from unauthenticated endpoints to nodes.

5.10.5.2 Applicability

- UC-1: not required
- UC-2: not required
- UC-3: REQ-AP-03 OR REQ-AP-04 apply
- UC-4: not required
- UC-5: REQ-AP-03 OR REQ-AP-04 apply
- UC-6: REQ-AP-03 OR REQ-AP-04 apply
- UC-7: not required

5.10.6 Mapping of requirements to use cases

Table 5.10.6: Availability protection mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-AP-01	x ⁸	x ⁸	x ⁹	x ⁸	x ⁹	x ⁹	x ⁸
REQ-AP-02	x ⁸	x ⁸	x ⁹	x ⁸	x ⁹	x ⁹	x ⁸
REQ-AP-03	x ⁸	x ⁸	x ⁹	x ⁸	x ⁹	x ⁹	x ⁸
REQ-AP-04			x ⁹		x ⁹	x ⁹	

- x⁸ REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02) apply
- x⁹ REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02 AND REQ-AP-04) apply

5.11 Non-interference

5.11.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (i).

5.11.2 REQ-IM-01 No route between different endpoints by default

5.11.2.1 Requirement

The VPN shall by default not establish routes between different client endpoints.

5.11.2.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required
- UC-7: not required

5.11.3 REQ-IM-02: Minimise data transmitted to unverified sources

5.11.3.1 Requirement

The product shall minimise the data originating from the product itself that is transmitted to an address that has not been verified as requesting the transmitting data.

5.11.3.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.11.3.3 Guidance

Denial of service attacks over the network often use traffic reflection or amplification techniques, in which the threat actor sends packet to third party devices with a spoofed source address. The third party then sends a response packet to the spoofed source destination - a reflection attack. If the response is larger than the packet it is responding to, then it is an amplification attack. By minimising or rate-limiting the data sent to potentially spoofed source addresses, a product can reduce its interference with other devices.

5.11.4 Mapping of requirements to use cases

Table 5.11.4: Non-interference mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-IM-01		x	x				
REQ-IM-02	x	x	x	x	x	x	x

5.12 Attack surface minimisation

5.12.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (j).

The VPN product should be able to operate without a wide set of permissions - eg, an end-user VPN client does not require access to files/folders (like ~/Downloads) nor would it need access to the local network.

5.12.2 REQ-MAS-01 Unnecessary VPN client permissions

5.12.2.1 Requirement

VPN clients shall not require unnecessary permissions.

5.12.2.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.12.2.3 Guidance

The VPN product should be able to operate without a wide set of permissions - eg, a VPN does not require access to files/folders (like ~/Downloads) nor would it need access to the local network.

5.12.3 Mapping of requirements to use cases

Table 5.12.3: Attack surface minimisation mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-MAS-01		x	x	x	x	x	x

5.13 Exploit mitigation

5.13.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (k).

In addition to protecting data transiting the VPN from typical attacks, it is important that the collection of data via RDPS is not also an attack vector. In the event of a successful breach of a VPN manufacturer, attackers cannot exfiltrate data that does not exist.

5.13.2 REQ-EMM-01 Route traffic from other sources/destination disabled by default

5.13.2.1 Requirement

The VPN client shall not route traffic through the endpoint from sources/destinations other than the endpoint without the user's explicit informed consent, and such routing shall not be necessary for the use of any unrelated function.

5.13.2.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.13.3 REQ-EMM-02 Notify user if routing traffic from other sources/destination

5.13.3.1 Requirement

The VPN client shall alert the user if the endpoint is allowing traffic from sources/destinations other than the endpoint to be routed through the endpoint.

5.13.3.2 Applicability

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: not required
- UC-5: required
- UC-6: required
- UC-7: not required

5.13.4 REQ-EMM-03 No routing traffic from other sources/destination if not necessary for services

5.13.4.1 Requirement

The VPN client shall not require routing of traffic from sources/destinations other than the endpoint to use services that do not require such routing.

5.13.4.2 Applicability

- UC-1: required

- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.13.5 Mapping of requirements to use cases

Table 5.13.5: Exploit mitigation mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-EMM-01	x	x	x	x	x	x	x
REQ-EMM-02	x	x	x	x	x	x	x
REQ-EMM-03	x	x	x	x	x	x	x

5.14 Monitoring

5.14.1 Overview

5.14.1.1 CRA requirement

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (l).

5.14.1.2 Minimum scope

The minimum scope of cybersecurity-relevant events logged by the VPN client may include, but are not limited to:

- modifications to the VPN client's configuration or security settings,
- changes applied by the VPN client to the host system's network configuration technically relevant for the VPN service provision, or
- software update successes or failures.

5.14.1.3 Monitoring restrictions

Products with the capability to transmit logs to remote data processing solutions are expected to exclude from cybersecurity-relevant logs confidential information such as network traffic content, connection metadata (e.g. destination IPs, DNS queries), secrets, or credentials. Cybersecurity-relevant logs are to be retained locally on the endpoint; to comply with data minimisation requirements, cybersecurity-relevant logs are not to be transmitted to the product's remote data processing solutions by default. Transmission of cybersecurity-relevant local logs to remote data processing solutions (e.g. for technical support or troubleshooting) is unacceptable without explicit, informed user authorization (e.g. explicit opt-in).

NOTE 1: For the purpose of the present clause, "cybersecurity-relevant logs" refers to security related information logged locally on the VPN client.

NOTE 2: Certain cybersecurity-relevant events might still be transferred to the VPN manufacturer without explicit authorization from the user, if the event transmissions are required to fulfill the intended purpose of the product.

NOTE 3: If not absolutely necessary, free text inputs should be omitted from log entries. Not only does this protect against log injection attacks, but also against accidentally logging sensitive data the user mistakenly entered.

5.14.2 REQ-LOG-01 Local event logging

5.14.2.1 Requirement

- 1) **REQ-LOG-01-1** The product shall record log messages indicating specific cybersecurity-relevant events (as described in clause 5.14.1.2) in an internal log, and
- 2) **REQ-LOG-01-2** those log messages shall not include any of the information described in clause 5.14.1.3, and
- 3) **REQ-LOG-01-3** those log messages shall not be transmitted to the manufacturer without explicit user authorization unless required to fulfill the intended purpose of the product.

5.14.2.2 Applicability

This requirement is exclusive to products with a risk factor [RF-PRI](#) > 0.

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required
- UC-7: required

5.14.3 REQ-LOG-02 Internal event logging

5.14.3.1 Requirement

- 1) **REQ-LOG-02-1** The product shall record log messages indicating specific cybersecurity-relevant events (as described in clause 5.14.1.2) in an internal log, and
- 2) **REQ-LOG-02-2** those log messages shall not include any confidential information such as secrets, or credentials.

5.14.3.2 Applicability

This requirement is exclusive to products with a risk factor [RF-PRI](#) of 0.

- UC-1: required
- UC-2: not required
- UC-3: not required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: not required

5.14.4 REQ-LOG-03 Remote Logging to RDPS

5.14.4.1 Requirement

- 1) **REQ-LOG-03-1** The product shall transfer log messages indicating cybersecurity-relevant events to a remote logging server, and
- 2) **REQ-LOG-03-2** the log messages shall not include any confidential information such as secrets, or credentials.

5.14.4.2 Applicability

This requirement applies to the subset of products within the indicated use cases where centralized log management is a standard security expectation.

- UC-1: required
- UC-2: not required
- UC-3: not required
- UC-4: not required
- UC-5: required
- UC-6: required
- UC-7: not required

5.14.4.3 Guidance

Logging output is expected to take care to not accidentally include a secret as a result of failed password authentication attempts. Since users often type a password into the username field, including the username field in the log message may result in including a secret in the log message.

5.14.5 REQ-LOG-04 Privacy-preserving logs policy and traffic anonymization

5.14.5.1 Requirement

- 1) **REQ-LOG-04-1** The product's remote data processing solutions shall technically enforce a strict "no-logs" policy, and
- 2) **REQ-LOG-04-2** the remote data processing solutions shall ensure that no information about the user's network traffic is persistently stored; this includes Personal Data, the client's source IP, or connection metadata, such as destination IPs and other plaintext connection information (e.g. DNS queries, Ports or SNI Headers).

5.14.5.2 Applicability

- UC-1: not required
- UC-2: required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required

- UC-7: required

5.14.6 Mapping of requirements to use cases

Table 5.14.6: Monitoring mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-LOG-01	x†	x†	x†	x†	x†	x†	x†
REQ-LOG-02	x†	x†	x†	x†	x†	x†	x†
REQ-LOG-03	x				x	x	
REQ-LOG-04		x	x				x

- x† REQ-LOG-01 or REQ-LOG-02 is indicated based on risk factor [RF-PRI](#)

5.15 Factory reset and data portability

5.15.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (m).

VPNs are expected to provide the ability to securely delete data and settings, and where applicable securely transfer data and settings to another product.

NOTE: Overwriting all user-writable storage or encrypting all user data and deleting the key are two secure deletion mechanisms.

5.15.2 REQ-DRT-01 Secure deletion via "factory reset"

5.15.2.1 Requirement

- 1) **REQ-DRT-01-1** The product shall provide a secure deletion or "factory reset" functionality, and
- 2) **REQ-DRT-01-2** the product shall remove all data and settings and reset to its secure-by-default state after the secure deletion or "factory reset" functionality is used.

5.15.2.2 Applicability

This requirement applies to the subset of products within the indicated use cases with the capability for the user to write data and/or settings.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.15.3 REQ-DRT-02 Secure deletion via reinstallation

5.15.3.1 Requirement

The product shall provide an option to restore its secure-by-default state during reinstallation that securely deletes all previous user data or settings.

5.15.3.2 Applicability

This requirement applies to the subset of products within the indicated use cases with the capability for the user to write data and/or settings.

- UC-1: required
- UC-2: not required
- UC-3: required
- UC-4: not required
- UC-5: not required
- UC-6: not required
- UC-7: not required

5.15.4 REQ-DRT-03 Secure data read from product

5.15.4.1 Requirement

The VPN client shall provide a method by which an authorized user can securely read all data and settings from the VPN client.

5.15.4.2 Applicability

This requirement applies to the subset of products within the indicated use cases with the capability for the user to write data and/or settings.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.15.5 REQ-DRT-04 Secure data export

5.15.5.1 Requirement

NOTE: Depending on use case, export of user data and settings may or may not be a desirable security feature for a VPN product, or indeed even possible. For example, enterprise users likely wish to export and independently back up configurations, while users of consumer VPNs may have bespoke clients installed that could not re-use configuration data.

- 1) **REQ-DRT-04-1** The product shall provide a method to export configuration data to a local file or external medium, and
- 2) **REQ-DRT-04-2** the product shall by default warn users if the export will include private keys or other sensitive data in plain text.

5.15.5.2 Applicability

This requirement applies to the subset of products within the indicated use cases with the capability for the user to write data and/or settings, and the capability to export that data to an external file. This requirement is strictly applicable to use cases where an IT professional or advanced user can reasonably be expected to administer the product.

- UC-1: required
- UC-2: required
- UC-3: required
- UC-4: required
- UC-5: required
- UC-6: required
- UC-7: required

5.15.6 Mapping of requirements to use cases

Table 5.15.6: Factory reset mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4	UC-5	UC-6	UC-7
REQ-DRT-01	x	x	x	x	x	x	x
REQ-DRT-02	x		x				
REQ-DRT-03	x	x	x	x	x	x	x
REQ-DRT-04	x	x	x	x	x	x	x

6 Assessment criteria for compliance with technical requirements

6.1 Introduction to the assessment and compliance criteria

This clause provides objective and reproducible assessment criteria to determine whether a product complies with the technical security requirements of [clause 5](#).

For each cybersecurity requirements defined in [clause 5](#), the following clauses specify assessment criteria to determine if the technical requirement is met.

For all assessment criteria specific to networking, products which support IPv6 only pass their assessments if all verdict criterion are fulfilled both using IPv4 and IPv6.

The assessment criteria for each security requirements are described in a structured manner, as follows:

- **Assessment reference:** Refers to the identifier of the concerned technical requirement.
- **Assessment objective:** Defines the security property or capability that shall be verified, ensuring that the assessment remains focused on the intent of the requirement.

- **Assessment preparation:** Describes the environment, setup, and preconditions required before executing the test with a view to guaranteeing consistent evaluation results. It includes the following elements as applicable:
 - Test environment: Describe the hardware, software, and network setup used for the assessment, including versions, topology, and any relevant dependencies.
 - Preconditions: Specify any configurations, credentials, or operational states that should be established before the test (e.g. product initialized, certificates loaded, user roles created).
 - Required tools: Identify the tools or software necessary to perform the assessment (e.g. vulnerability scanners, protocol fuzzers, traffic analysers, static code analysers, cryptographic test suites).
 - Required information/documentation for the assessment: Specify all information that is necessary to perform the assessment.
 - Reference any vendor-provided setup guides, configuration instructions, or operational manuals, as well as any relevant standards or technical notes, that define how the product shall be configured or operated for the assessment.
- **Assessment activities:** Provides execution steps to be performed such that the same assessment verdict would be reached when repeating these steps now or at a later point in time. Assessment activities may include, as applicable:
 - Review information/documentation for the assessment to confirm that the described implementation matches the requirement (e.g. verify that the security architecture document specifies TLS 1.2 or higher for all external interfaces, or that the password policy aligns with the defined threshold).
 - Perform security functional tests to verify the completeness and correctness of the information/documentation for the assessment.
 - Perform security functional or penetration tests to verify that implemented controls are correctly implemented e.g. to prevent unauthorized access or data modification (e.g. via attempting to log in with invalid credentials to test lockout enforcement or trying to modify protected configuration files without administrative privileges).
 - Analyse code or binaries to identify potential security weaknesses or misconfigurations (e.g. perform static analysis to detect hardcoded credentials or use dynamic analysis tools to identify buffer overflow or injection vulnerabilities).
 - Inspect configurations to ensure that required security parameters are correctly applied (e.g. check that weak cipher suites are disabled, two-factor authentication is enabled, and least-privilege access controls are configured in the system).
 - Observe runtime behaviour to confirm that protections such as encryption, authentication, and integrity verification operate as intended (e.g. monitor network traffic to ensure data in transit is encrypted or observe system logs to verify successful validation of digital signatures during startup).
- **Assessment verdict:** Defines the pass/fail criteria.
 - **Pass:** The assessment is considered passed if the product demonstrably fulfils the requirement and meets the defined security thresholds. Examples of such thresholds include:
 - Minimum cryptographic strength;
 - Password policy limits;
 - Login protection mechanisms;
 - Resistance to a specified attack potential.
 - **Fail:** The assessment is considered failed if the requirement is not fulfilled, or if the defined security thresholds are not achieved (e.g. insufficient key length, missing authentication enforcement, or inadequate resistance to the required attack potential).

- **Assessment evidence:** Defines the artefacts and documentation collected to demonstrate that the requirement has been assessed and fulfilled. The evidence shall be sufficient to enable independent verification of the assessment results and to demonstrate compliance with the relevant CRA essential requirements. The supporting evidence include, where applicable:
 - Test or assessment reports showing the steps performed and results obtained;
 - Logs, configuration files, or audit traces demonstrating the implementation of the requirement;
 - Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
 - Relevant vendor or design documentation describing the applied security measures;

6.2 Appropriate level of cybersecurity

6.2.1 Overview

This clause provides assessment for the requirements in [clause 5.2](#) relating to CRA [i.1] Annex I Part I (1).

6.2.2 [REQ-SSD-01](#) Memory access error prevention

6.2.2.0 Overview

This requirement can be satisfied by using one of several methods identified by unique numbers. After selecting one method, carry out the corresponding numbered step within each section of this assessment. Only one method is necessary to complete the assessment.

6.2.2.1 Objective

Prevent unauthorized memory access.

6.2.2.2 Preparation

None.

6.2.2.3 Activities

Carry out one of the following methods. Only one method is necessary to complete the assessment.

- Method 1: For all cybersecurity-relevant executables that may have memory errors, run the executable in an environment that allows measurement of code coverage and detection of common memory errors. While running the executable, vary the inputs to the product's interfaces that are normally accessible in the product's intended use. Use the code coverage tool to determine which lines of code have been exercised. Continue this process until each line of code that can reasonably be exercised deterministically by providing specific input values has been executed. For each memory error detected, provide documentation demonstrating that it does not constitute an unacceptable risk.
- Method 2: For all cybersecurity-relevant executables that may have memory errors, run the executable in an environment that allows measurement of code coverage and detection of common memory errors. While running the executable, vary the inputs to the product's interfaces that are normally accessible in the product's intended use. Use the code coverage tool to determine which lines of code have been exercised. Use a risk-based approach and the output of the code coverage measurements to decide when testing is complete. For each memory error detected, provide documentation demonstrating that it does not constitute an unacceptable risk.
- Method 3: Run a tool that tests the boundaries of the input values (minimum valid, maximum valid, minimum possible, maximum possible, off-by-one, etc.) while monitoring for memory errors. For each memory error detected, provide documentation demonstrating that it does not constitute an unacceptable risk.

- Method 4: Review source code to determine its language and what exceptions to memory safety exist. For each use of memory-unsafe features or code, provide documentation demonstrating that it does not constitute an unacceptable risk.

6.2.2.4 Verdict

Choose the method with the same number as the method used to carry out the Activities. Only one method is necessary to complete the assessment.

Method 1: PASS if **all** of the following are fulfilled:

- All code that could be deterministically exercised by varying the inputs has been executed, and
- all reported memory errors have corresponding documentation demonstrating that each does not constitute an unacceptable cybersecurity risk.

Otherwise FAIL

Method 2: PASS if **all** of the following are fulfilled:

- The interfaces have been properly covered from a risk perspective, and
- all reported memory errors have corresponding documentation demonstrating that each does not constitute an unacceptable cybersecurity risk.

Otherwise FAIL

Method 3:

PASS if **all** of the following are fulfilled:

- All boundary values tested, and
- all detected memory errors have corresponding documentation demonstrating that each does not constitute an unacceptable cybersecurity risk.

Otherwise FAIL

Method 4:

PASS if **all** of the following are fulfilled:

- Source code is in a memory-safe language, and
- all uses of unsafe memory features have corresponding documentation demonstrating that each does not constitute an unacceptable cybersecurity risk.

Otherwise FAIL

6.2.2.5 Evidence

Choose the method with the same number as the method used to carry out the Activities. Only one method is necessary to complete the assessment.

Method 1:

- Logs of code coverage tool
- Memory error report
- Documentation of any memory errors

Method 2:

- Documentation of decision on how much to test using a risk-based approach

- Logs of code coverage tool
- Memory error report
- Documentation of any memory errors

Method 3:

- Logs of boundary testing tool
- Memory error report
- Documentation of any memory errors

Method 4:

- Source code
- Documentation of unsafe memory features

6.2.2.6 Guidance for "risk-based approach"

The test scope should be selected based on a risk-based approach. This includes considering the product's intended use and prioritizing functions and interfaces that process untrusted inputs, provide access to security-relevant assets, or execute critical operations, since memory access errors in such areas may have a greater cybersecurity impact.

6.2.3 [REQ-SSD-02](#) Resilience against potentially untrusted inputs

6.2.3.1 Objective

Prevent unauthorized memory access.

6.2.3.2 Preparation

Identify all sources of untrusted input to the product. For each source of untrusted input, review for fields in the format, values, or input sequences that could affect:

- calculation of memory accesses (length, index, hash table lookup values, packet reassembly, etc.)
- availability of product resources (buffer length, number of packet descriptors, fragmented packets, CPU-intensive operations, etc.)
- incrementing or decrementing of internal counters (packet counters, event counters, etc.)
- consistency or validity of internal data structures

For each input, construct a series of inputs that tests, if technically possible:

- maximum and minimum valid input values and the next above and below
- maximum and minimum possible input values and next possible above and below
- a representative selection of other valid and invalid values
- potential overflow or underflow of internal counters
- values that are inconsistent with other values in the input
- indexes that are inconsistent or invalid with the data indexed
- values that, if used, would harm product availability

Identify the acceptable behaviour(s) of the product in response to the input that would protect its cybersecurity. Identify a method of sending these inputs to the product and recording the responses. Set up this testing environment.

6.2.3.3 Activities

For every input, send the input to the product and record its response.

6.2.3.4 Verdict

PASS if **all** of the following are fulfilled:

For every identified input:

- All values tested, and
- all detected errors have corresponding documentation demonstrating that each does not constitute an unacceptable cybersecurity risk.

Otherwise FAIL

6.2.3.5 Evidence

- List of sources of untrusted input
- Analysis of sources of untrusted input for specified inputs
- Sufficient analysis of untrusted inputs
- List of test inputs
- Logs of testing inputs and recording behaviour
- Sufficient analysis of testing logs

6.2.3.6 Guidance

Assessment can often be done with minimal effort using commonly available fuzzer or security testing tools. It can also be done manually.

Acceptable behaviours might include:

- Crashing and restarting
- Terminating a thread
- Rejection of input and returning an error
- Silent discard of input
- Correction of input
- Dropping a packet and incrementing an error counter
- Emitting a notification when a counter rolls over

6.2.4 [REQ-SSD-03](#) Applicability of Annex R

See clause R.5 for full assessment criteria.

6.3 No known exploitable vulnerabilities

6.3.1 Overview

This clause provides assessment for the requirements in [clause 5.3](#) relating to CRA [i.1] Annex I Part I (2) (a).

6.3.2 [REQ-KEV-01](#) Testing for known exploitable vulnerabilities

6.3.2.1 Objective

Prevent exploitation of known exploitable vulnerabilities.

6.3.2.2 Preparation

Using the product's SBOM and relevant publicly accessible vulnerability databases (e.g. [GCVE](#), [EUVD](#) [i.22]), compile a list of target components and potential known exploitable vulnerabilities. Select the appropriate testing methodology (e.g. the most comprehensive automated scanners available, or a manual penetration test plan) to verify the mitigation of these vulnerabilities.

6.3.2.3 Activities

On a new product, carry out a security update, run the tests, and compare the results with the generated list of known exploitable vulnerabilities.

6.3.2.4 Verdict

PASS if **any** of the following are fulfilled:

- No vulnerabilities found, or
- all reported vulnerabilities satisfy either the elapsed time since discovery or mitigation requirement.

Otherwise FAIL

6.3.2.5 Evidence

- Documented vulnerability handling policy
- Product SBOM
- List of testing tools used or manual test plan
- Test reports/scan results
- Correlation of discovered vulnerabilities with:
 - documentation of mitigation, or
 - elapsed time since discovery of vulnerability

6.4 Secure by default configuration

6.4.1 Overview

This clause provides assessment for the requirements in [clause 5.4](#) relating to CRA [i.1] Annex I Part I (2) (b).

6.4.2 [REQ-SBD-01](#) Unintentional disabling of cybersecurity features

6.4.2.1 Objective

Prevent attack exposure from misconfigured VPN software.

6.4.2.2 Preparation

Access preferences or settings of VPN client.

6.4.2.3 Activities

Attempt to configure the software in a way which exposes the user or the user's traffic to an attacker.

6.4.2.4 Verdict

PASS if **any** of the following are fulfilled:

- the VPN client does not permit reduced cybersecurity via configuration, or
- the VPN provides a clear, recallable warning about the impact of the user's configuration actions.

Otherwise FAIL

6.4.2.5 Evidence

- Recorded configuration options
- Annotation of settings which provided warning

6.5 Security updates

6.5.1 Overview

This clause provides assessment for the requirements in [clause 5.5](#) relating to CRA [i.1] Annex I Part I (2) (c).

6.5.2 [REQ-SU-01](#) Automatic secure update before or during first use

6.5.2.1 Objective

Prevent exploitation of known exploitable vulnerabilities at first use.

6.5.2.2 Preparation

Examine public or private vulnerability information sources and select a recently fixed vulnerability. Filter candidates to ensure each vulnerability specifically affects the platform, architecture, or software components used by the product. Then, prioritize those candidates based on the existence of publicly available exploit code (e.g. Proof of Concept), evidence of active exploitation in the wild, the severity of the vulnerability, and the potential impact its exploitation would have on the product.

6.5.2.3 Activities

Follow the instructions to install and use the product for the first time, scan the product to see if a recently fixed vulnerability has been fixed on the product, and examine the documentation for the required info.

6.5.2.4 Verdict

PASS if **all** of the following are fulfilled:

- The secure update completes successfully, and
- the most recently fixed vulnerability is fixed, and
- the documentation includes all the required information.

6.5.2.5 Evidence

- Documentation of vulnerability handling
- Documentation of how to securely update the product
- The report for the selected vulnerability
- Description of how to scan for the vulnerability
- Log of vulnerability scan results

6.5.3 [REQ-SU-02](#) Automatic secure update via operational environment before or during first use

6.5.3.1 Objective

Prevent exploitation of known exploitable vulnerabilities at first use.

6.5.3.2 Preparation

Examine public or private vulnerability information sources and select a fixed vulnerability. Filter candidates to ensure each vulnerability specifically affect the platform, architecture, or software components used by the product. Then, prioritize those candidates based on the existence of publicly available exploit code (e.g. Proof of Concept), evidence of active exploitation in the wild, the severity of the vulnerability, and the potential impact its exploitation would have on the product.

6.5.3.3 Activities

Follow the instructions for the administrator to receive and install the latest release, use the product for the first time, scan the product to see if a recently fixed vulnerability has been fixed on the product, and examine the documentation for the required info.

6.5.3.4 Verdict

PASS if **all** of the following are fulfilled:

- The secure update completes successfully, and
- the most recently fixed vulnerability is fixed, and
- the documentation includes all the required information.

Otherwise FAIL

6.5.3.5 Evidence

- Documentation of vulnerability handling
- Documentation of how to securely update the product
- The report for the selected vulnerability
- Description of how to scan for the vulnerability
- Log of vulnerability scan results

6.5.4 [REQ-SU-03](#) Secure update via product

6.5.4.1 Objective

Prevent exploitation of known vulnerabilities.

6.5.4.2 Preparation

Prepare an update for each part of the product that can be updated with a different version number from the currently installed product version.

6.5.4.3 Activities

Check the versions of all parts of the product that can be updated, install the new update, and check the versions again.

6.5.4.4 Verdict

PASS if **all** of the following are fulfilled:

- The second versions read are that of the new product update.

Otherwise FAIL

6.5.4.5 Evidence

- New update version numbers
- Log of querying the product parts' versions
- Installing the update
- Querying the versions again

6.5.5 [REQ-SU-04](#) Automatic secure update via product

6.5.5.1 Objective

Prevent exploitation of known vulnerabilities.

6.5.5.2 Preparation

Prepare an update for each part of the product that can be updated with a different version number from the currently installed product version.

6.5.5.3 Activities

Check the versions of all parts of the product that can be updated, create the conditions that allow automatic secure update to occur. Then execute the same setup for all the tests:

- 1) install the update, record the version again,
- 2) defer the update, wait the deferral period, relaunch the product, observe any update popups, install the update, record the version again,
- 3) disabling automatic updates, record the product version.

6.5.5.4 Verdict

PASS if **all** of the following are fulfilled:

- 1) For the first test, the second versions read are that of the new product update, and
- 2) for the second test, after deferral of the update, the product reads the same product version. After the deferral period, the update is prompted again. Once installed, versions read are that of the new product update, and
- 3) for the third test with automatic updates disabled, the versions read are the same as the first versions.

Otherwise FAIL

6.5.5.5 Evidence

New update version numbers, and log of querying the product parts' versions, installing the update, and querying the versions again.

6.5.6 [REQ-SU-05](#) Secure update provided by operational environment

6.5.6.1 Objective

Prevent exploitation of known vulnerabilities.

6.5.6.2 Preparation

None.

6.5.6.3 Activities

Assess the documentation provided with the product.

6.5.6.4 Verdict

PASS if **all** of the following are fulfilled:

- Documentation describes requirements for the secure updates provided by the operational environment.

Otherwise FAIL

6.5.6.5 Evidence

- Documentation and analysis of completeness

6.5.7 [REQ-SU-06](#) Automatic secure update provided by operational environment

6.5.7.1 Objective

Prevent exploitation of known vulnerabilities.

6.5.7.2 Preparation

None.

6.5.7.3 Activities

Assess the documentation provided with the product.

6.5.7.4 Verdict

PASS if **all** of the following are fulfilled:

- Documentation describes requirements for automatic secure updates provided by the operational environment.

Otherwise FAIL

6.5.7.5 Evidence

- Documentation and analysis of completeness

6.5.8 [REQ-SU-07](#) Updates are signed and verified before installation

6.5.8.1 Objective

Prevent the installation of modified updates.

6.5.8.2 Preparation

None.

6.5.8.3 Activities

For each part of the product that can be updated, attempt installation of:

- an update with missing signature,
- an update with an invalid signature.

6.5.8.4 Verdict

PASS if **all** of the following are fulfilled:

- The installation fails, and
- the installer warns the user about an invalid signature and possible tampering.

Otherwise FAIL

6.5.8.5 Evidence

New update version numbers, and installation log containing mention of a signature mismatch.

6.5.9 [REQ-SU-08](#) Only authorized software updates

6.5.9.1 Objective

Secure updates.

6.5.9.2 Preparation

Create an update with an invalid hash.

6.5.9.3 Activities

Attempt to install the update.

6.5.9.4 Verdict

PASS if **all** of the following are fulfilled:

- Update is not installed.

Otherwise FAIL

6.5.9.5 Evidence

- Update and invalid hash
- Error message
- Before and after comparison of any data that would have been altered if it had been installed

6.5.10 [REQ-SU-09](#) Secure update has validly signed hash

6.5.10.1 Objective

Secure updates.

6.5.10.2 Preparation

Create updates with signature signed by an untrusted key.

6.5.10.3 Activities

For each part of the product that can be updated, attempt installation of an update signed by an untrusted key.

6.5.10.4 Verdict

PASS if **all** of the following are fulfilled:

- All updates are not installed.

Otherwise FAIL

6.5.10.5 Evidence

- Updates and invalid hashes and file sizes
- Error message
- Before and after comparison of any data that would have been altered if it had been installed

6.5.11 [REQ-SU-10](#) Invalidated update is rejected

6.5.11.1 Objective

Prevent "rollback attacks" by rejecting previously-valid packages that contain vulnerabilities.

6.5.11.2 Preparation

Create an update image that was formerly valid but has been revoked from the repository metadata.

6.5.11.3 Activities

Attempt to install the revoked update.

6.5.11.4 Verdict

PASS if **all** of the following are fulfilled:

- Update is not installed.

Otherwise FAIL

6.5.11.5 Evidence

- Revoked update image
- Error message
- Before and after comparison of any data that would have been altered if it had been installed

6.5.12 [REQ-SU-11](#) Signing keys have strictly scoped usage

6.5.12.1 Objective

Ensure keys are only used for their designated roles and prevent role confusion attacks.

6.5.12.2 Preparation

Create Repository Metadata signed with a valid key that is intended for a different role.

6.5.12.3 Activities

Send the incorrectly-signed Repository Metadata to the device during an update check.

6.5.12.4 Verdict

PASS if **all** of the following are fulfilled:

- Update check fails, and
- error is reported.

Otherwise FAIL

6.5.12.5 Evidence

- Error message
- Before and after comparison showing local metadata is not changed

6.5.13 [REQ-SU-12](#) Signing keys have not been revoked or otherwise marked untrusted

6.5.13.1 Objective

Ensure keys have not been revoked and are still valid, including their complete chain of trust.

6.5.13.2 Preparation

Create Repository Metadata signed with a formerly valid key that has been revoked.

6.5.13.3 Activities

Send the Repository Metadata signed with the revoked key to the device during an update check.

6.5.13.4 Verdict

PASS if **all** of the following are fulfilled:

- Update check fails, and
- error is reported.

Otherwise FAIL

6.5.13.5 Evidence

- Error message
- Before and after comparison showing local metadata is not changed

6.5.14 [REQ-SU-13](#) Reject update to current or previous version

6.5.14.1 Objective

Prevent rollback attacks by rejecting older versions of Repository Metadata.

6.5.14.2 Preparation

Have the device perform an update check to obtain the latest Repository Metadata, then prepare an older version of Repository Metadata.

6.5.14.3 Activities

Send the older version of Repository Metadata to the device during another update check.

6.5.14.4 Verdict

PASS if **all** of the following are fulfilled:

- Update check fails, and
- error is reported.

Otherwise FAIL

6.5.14.5 Evidence

- Error message
- Before and after comparison showing update metadata is not changed

6.5.15 [REQ-SU-14](#) Updates not applied from expired sources

6.5.15.1 Objective

Prevent use of expired metadata that could enable rollback attacks.

6.5.15.2 Preparation

Create expired Repository Metadata and configure the update server to provide it.

6.5.15.3 Activities

Have the device perform an update check with the expired metadata.

6.5.15.4 Verdict

PASS if **all** of the following are fulfilled:

- Update check fails, and
- error is reported.

Otherwise FAIL

6.5.15.5 Evidence

- Error message
- Before and after comparison showing update metadata is not changed

6.6 Authentication and access control

6.6.1 Overview

This clause provides assessment for the requirements in [clause 5.6](#) relating to CRA [i.1] Annex I Part I (2) (d).

6.6.2 [REQ-AAC-01](#) Authentication of cybersecurity-relevant nodes

6.6.2.1 Objective

Prevent client trusting a masquerading node.

6.6.2.2 Preparation

For each method of authenticating the cybersecurity-relevant node's identity, set up a test node that provides invalid secrets, certificates, or fingerprints.

6.6.2.3 Activities

For each method of authentication, make the VPN client to attempt to connect to the test node using this method of authentication, and follow user instructions on how to approve authentication, if any.

6.6.2.4 Verdict

PASS if **all** of the following are fulfilled:

- VPN client does not connect to node.

Otherwise FAIL

6.6.2.5 Evidence

- Invalid authentication materials

- Log messages for connection attempt
- Packet capture
- Log of user actions, if any

6.6.3 [REQ-AAC-02](#) Encryption of transmitted credentials

6.6.3.1 Objective

Confidentiality of credentials.

6.6.3.2 Preparation

None

6.6.3.3 Activities

For each supported authentication and transport method:

- 1) Authenticate a user while capturing the network traffic for the entire authentication process, then
- 2) search captured traffic for a plaintext string matching the user's credential, then
- 3) search captured traffic for common reversible encodings of the credentials, including but not limited to Base64, hexadecimal encoding and URL encoding.

6.6.3.4 Verdict

PASS if **all** of the following are fulfilled:

- Credentials or authentication material are not observable in plaintext or in trivially reversible encodings.

Otherwise FAIL

6.6.3.5 Evidence

- The authentication method and transport used
- A packet capture
- The plain text of the user's credential
- The output of a search for the credential in the packet capture

6.6.4 [REQ-AAC-03](#) Authentication timeout

6.6.4.1 Objective

Protect VPN connection from unauthorized use.

6.6.4.2 Preparation

Inspect, obtain or configure the session lifetime.

6.6.4.3 Activities

- 1) Obtain a session credential.
- 2) After the configured session credential validity period, attempt to connect to the VPN server.

6.6.4.4 Verdict

PASS if **all** of the following are fulfilled:

- Connection is rejected.

Otherwise FAIL

6.6.4.5 Evidence

- Log messages showing VPN connection establishment
- Authentication timeout or rejection
- Packet capture with timestamps synchronized with log messages

6.6.5 [REQ-AAC-04](#) Cloned credentials detection

6.6.5.1 Objective

Protect VPN connection from unauthorized use.

6.6.5.2 Preparation

Configure two VPN clients with identical credentials that should be unique to a VPN client.

6.6.5.3 Activities

Connect to the VPN with both VPN clients.

6.6.5.4 Verdict

PASS if **any** of the following are fulfilled:

- Notification of both VPN clients, or
- only one connection is active at a time.

Otherwise FAIL

6.6.5.5 Evidence

- Configuration of clients
- Log messages showing notifications and/or connection status

6.6.6 [REQ-AAC-05](#) Forced revocation of authorization of endpoints

6.6.6.1 Objective

Protect VPN connection from unauthorized use.

6.6.6.2 Preparation

None.

6.6.6.3 Activities

- 1) Authorize an endpoint to connect to the VPN,

- 2) connect the endpoint to the VPN,
- 3) revoke the endpoint's authorization, then
- 4) attempt to access the VPN connection from the revoked client.

6.6.6.4 Verdict

PASS if **all** of the following are fulfilled:

- Revoked client cannot access the VPN connection.

Otherwise FAIL

6.6.6.5 Evidence

- Logs or screenshots of authorization and revocation
- Packet capture

6.6.7 [REQ-AAC-06](#) Brute force protection

6.6.7.1 Objective

Protect VPN connection from unauthorized use.

6.6.7.2 Preparation

For each supported VPN protocol, reference the documentation to assess the entropy of the credentials.

6.6.7.3 Activities

- 1) If credentials are low entropy credentials (below 128 bits) conduct a brute-force of credentials.
- 2) Observe network responses.

6.6.7.4 Verdict

PASS if **all** of the following are fulfilled:

- Appropriate rate limiting is enforced.

Otherwise FAIL

6.6.7.5 Evidence

- Network logs and package capture
- Documentation

6.6.8 [REQ-AAC-07](#) Authorization of endpoints

6.6.8.1 Objective

Prevent unauthorized connections.

6.6.8.2 Preparation

Set up a node which requires selective authorization.

6.6.8.3 Activities

As an unauthorized, but authenticated node attempt to connect to the node.

6.6.8.4 Verdict

PASS if **all** of the following are fulfilled:

- The unauthorized node is rejected.

Otherwise FAIL

6.6.8.5 Evidence

- Logs
- Screenshots of error message

6.6.9 [REQ-AAC-08](#) Fine-grain access control

6.6.9.1 Objective

Prevent excessive network access to endpoints.

6.6.9.2 Preparation

Create three mesh endpoints (endpoint A, endpoint B and endpoint C).

6.6.9.3 Activities

- 1) Start the VPN client (endpoint A).
- 2) Configure endpoint A to only allows traffic routing from endpoint B.
- 3) On endpoint C attempt to route traffic though endpoint A.
- 4) Observe client behaviour.

6.6.9.4 Verdict

PASS if **all** of the following are fulfilled:

- Traffic routing is rejected on endpoint C.

Otherwise FAIL

6.6.9.5 Evidence

- Screenshots of error messages
- Logs

6.7 Confidentiality protection

6.7.1 Overview

This clause provides assessment for the requirements in [clause 5.7](#) relating to CRA [i.1] Annex I Part I (2) (e).

6.7.2 [REQ-CON-01](#) VPN routing stays in effect until VPN connection deactivated

6.7.2.1 Objective

Prevent VPN traffic leaks.

6.7.2.2 Preparation

None.

6.7.2.3 Activities

- 1) Start the VPN connection.
- 2) After it reports that it is connected, force the VPN connection to end in a way that does not allow it to execute any VPN connection shutdown tasks.
- 3) Attempt to transmit data that should only go through the VPN connection.

6.7.2.4 Verdict

PASS if **all** of the following are fulfilled:

- No network traffic intended for the VPN exits the host.

Otherwise FAIL

6.7.2.5 Evidence

- Configuration of VPN client
- Method used to force connection to end without allowing shutdown tasks to run
- Network configuration
- Log of actions
- Error messages
- Packet capture with annotations

6.7.3 [REQ-CON-02](#) VPN routing stays in effect during network-level tunnel failure

6.7.3.1 Objective

Prevent VPN traffic leaks during tunnel failure.

6.7.3.2 Preparation

None.

6.7.3.3 Activities

- 1) Start the VPN connection
- 2) After it reports that it is connected, induce a network-level tunnel failure by blocking traffic to the VPN server's IP address using a host-based firewall

- 3) Attempt to transmit data that should only go through the VPN connection

6.7.3.4 Verdict

PASS if **all** of the following are fulfilled:

- No network traffic intended for the VPN exits the host via a non-VPN interface.

Otherwise FAIL

6.7.3.5 Evidence

- Method used to induce tunnel failure
- Network configuration
- Log of actions
- Error messages
- Packet capture with annotations

6.7.4 [REQ-CON-03](#) Tunnel all traffic by default

6.7.4.1 Objective

Prevent user confusion and unexpected traffic leaks from non-tunnelled applications.

6.7.4.2 Preparation

Perform a factory reset or new installation of the VPN client.

6.7.4.3 Activities

- 1) Start the VPN connection using the default configuration.
- 2) Generate traffic from multiple applications (e.g. a web browser and a separate command-line tool).
- 3) Capture traffic on all interfaces.

6.7.4.4 Verdict

PASS if **all** of the following are fulfilled:

- All traffic from all applications is routed through the VPN connection.

Otherwise FAIL

6.7.4.5 Evidence

- Packet capture showing traffic from multiple applications going through the VPN interface.

6.7.5 [REQ-CON-04](#) Endpoint to endpoint encryption

6.7.5.1 Objective

Prevent network observers from eavesdropping on VPN traffic.

6.7.5.2 Preparation

Attach a network package capture tool.

6.7.5.3 Activities

- 1) From a fresh installation of the client, start the VPN connection using the default configuration.
- 2) Capture traffic on all interfaces.

6.7.5.4 Verdict

PASS if **all** of the following are fulfilled:

- Private keys of the endpoint are not found in the network dump.

Otherwise FAIL

6.7.5.5 Evidence

- Packet capture showing traffic from one endpoint to another

6.7.6 [REQ-CON-05](#) Inform user of visibility of DNS queries

6.7.6.1 Objective

Consent to and transfer of risk of loss of confidentiality to the user.

6.7.6.2 Preparation

None

6.7.6.3 Activities

- 1) Start the VPN client.
- 2) Configure the VPN in such a way that DNS queries are not routed exclusively through the VPN and read any information displayed.
- 3) Attempt to use the VPN connection before confirming that the user has read the information.

6.7.6.4 Verdict

PASS if **all** of the following are fulfilled:

- Information is displayed is clear and complete, and
- VPN connection is not usable until the user confirms.

Otherwise FAIL

6.7.6.5 Evidence

- Logs
- Screenshots
- Screen recordings
- Packet captures

6.7.7 [REQ-CON-06](#) Configurable exclusive DNS routing

6.7.7.1 Objective

Prevent plaintext DNS query leaks outside of VPN connection.

6.7.7.2 Preparation

Configure the VPN to route all DNS queries using well-known ports through the VPN connection.

6.7.7.3 Activities

- 1) Start the VPN connection, and
- 2) perform a DNS lookup while capturing traffic on all network interfaces.

6.7.7.4 Verdict

PASS if **all** of the following are fulfilled:

- All plaintext DNS traffic is routed exclusively through the VPN connection.

Otherwise FAIL

NOTE: Excluded from this verdict are DNS queries which are transmitted using DoH, DoT or other DNS query hiding techniques.

6.7.7.5 Evidence

- VPN client configuration
- A packet capture showing the destination of all DNS queries using well-known ports

6.7.8 [REQ-CON-07](#) Exclusive DNS routing by default

6.7.8.1 Objective

Prevent DNS query leaks using well-known ports outside of VPN connection.

6.7.8.2 Preparation

None.

6.7.8.3 Activities

Start the VPN connection and perform a DNS lookup while capturing traffic on all network interfaces.

6.7.8.4 Verdict

PASS if **all** of the following are fulfilled:

- All plaintext DNS traffic is routed exclusively through the VPN connection.

Otherwise FAIL

6.7.8.5 Evidence

A packet capture showing that no DNS query using well-known ports is transmitted outside the VPN tunnel.

6.7.9 [REQ-CON-08](#) DNS configuration consistency

6.7.9.1 Objective

Prevent unintended plaintext DNS query leaks outside of VPN connection.

6.7.9.2 Preparation

Configure the VPN client to use exclusive DNS routing to authorized DNS servers.

6.7.9.3 Activities

- 1) Start the VPN client and capture network packages on all interfaces, then
- 2) alter the DNS configuration to stop using the authorized DNS servers.

6.7.9.4 Verdict

PASS if **any** of the following are fulfilled:

- no DNS packets are leaked, or
- networking is disabled within 30 seconds of the configuration change.

Otherwise FAIL

6.7.9.5 Evidence

- Logs
- Before and after configuration files
- Packet captures

6.7.10 [REQ-CON-09](#) Secure DNS protocols

6.7.10.1 Objective

Prevent DNS query leaks outside of VPN connection.

6.7.10.2 Preparation

None.

6.7.10.3 Activities

- 1) Start the VPN connection, then
- 2) configure DNS-based policy routing, then
- 3) configure the operating system or an application to use a well-known public DNS provider for DNS over TLS (DoT) using the well-known port 853, then
- 4) generate DNS requests while capturing traffic on all network interfaces.
- 5) If using notifications rather than blocking, observe the client UI or documentation for static warnings regarding encrypted DNS protocols.

6.7.10.4 Verdict

PASS if **any** of the following are fulfilled for **each** test:

- DNS connections to well-known public DNS providers are blocked, or
- the user is notified that some software on the operating system could be using encrypted DNS protocols which conflict with the product's DNS-based routing configuration.

Otherwise FAIL

6.7.10.5 Evidence

- A description of the method used to prevent or notify the user about DNS over TLS (DoT) leaks
- A list of authorized DNS server IP addresses
- A packet capture showing the destination of all DNS queries, or a copy of the static notification provided to the user

6.7.11 [REQ-CON-10](#) No DNS leaks during network-level tunnel failure

6.7.11.1 Objective

Prevent DNS query leaks during tunnel failure.

6.7.11.2 Preparation

Start the VPN connection with exclusive DNS routing enabled.

6.7.11.3 Activities

- 1) Induce a network-level tunnel failure by blocking traffic to the VPN server's IP address using a host-based firewall.
- 2) Attempt to resolve a domain name while capturing traffic on all network interfaces.

6.7.11.4 Verdict

PASS if **all** of the following are fulfilled:

- No DNS queries using well-known ports are sent to DNS servers outside the VPN connection.

Otherwise FAIL

6.7.11.5 Evidence

- Method used to induce tunnel failure
- Packet capture
- Log messages

6.7.12 [REQ-CON-11](#) Block IPv6 if Unsupported

6.7.12.1 Objective

Prevent IPv6 traffic leaks.

6.7.12.2 Preparation

None.

6.7.12.3 Activities

- On a network with IPv6 connectivity, connect to the VPN and attempt to access an IPv6-only service.

6.7.12.4 Verdict

PASS if **all** of the following are fulfilled:

- The connection to the IPv6-only service fails.

Otherwise FAIL

6.7.12.5 Evidence

*Packet capture showing that no IPv6 traffic is leaving the device.

6.7.13 [REQ-CON-12](#) Full Support if Claimed

6.7.13.1 Objective

Ensure full IPv6 support if claimed.

6.7.13.2 Preparation

None.

6.7.13.3 Activities

On a network with IPv6 connectivity, connect to the VPN and verify that the client has a globally routable IPv6 address assigned by the VPN. All tests in this standard should be repeated over the IPv6 connection.

6.7.13.4 Verdict

PASS if **all** of the following are fulfilled:

- the client has a globally routable IPv6 address, and
- all tests in the present document pass over IPv6.

Otherwise FAIL

6.7.13.5 Evidence

- Network configuration details
- Packet captures
- Test results for all requirements over IPv6

6.7.14 [REQ-CON-13](#) Use conformant cryptography

6.7.14.1 Objective

Confidentiality.

6.7.14.2 Preparation

Perform a factory reset or new installation of the VPN client.

6.7.14.3 Activities

- 1) Start the VPN connection using the default configuration.
- 2) Capture traffic on all interfaces.

6.7.14.4 Verdict

PASS if **all** of the following are fulfilled:

- The traffic pertaining to the VPN connection uses the primitives and parameters as described in [Annex K](#).

Otherwise FAIL

6.7.14.5 Evidence

- Packet capture showing the encryption headers

6.7.15 [REQ-CON-14](#) Confidentiality of data stored on the product

6.7.15.1 Objective

Confidentiality of data

6.7.15.2 Preparation

Identify all specific locations (files, databases, registries, secure enclaves) where the product stores the "Confidential Elements in Scope". Document the accepted protection method applied to each location.

6.7.15.3 Activities

For each identified storage location:

- 1) Attempt to access, read, or extract the data using an unauthorized user account or a third-party application on the host system.
- 2) Where encryption or hashing is used, verify that the cryptographic algorithms conform to state-of-the-art standards (e.g. [Annex K](#) of the present document).

6.7.15.4 Verdict

PASS if **all** of the following are fulfilled:

- All methods of ensuring confidentiality match the type of the data stored, and
- all the attempts to read confidential data without authorization fail.

Otherwise FAIL

6.7.15.5 Evidence

- List of identified stored data types and the applied protection methods
- Logs or screenshots demonstrating the failure to read the data without authorization
- Documentation validating the encryption/hashing algorithms used

6.7.16 [REQ-CON-15](#) Inform user of limits of privacy protection

6.7.16.1 Objective

Privacy protection.

6.7.16.2 Preparation

Perform first install of product.

6.7.16.3 Activities

Launch product.

6.7.16.4 Verdict

PASS if **all** of the following are fulfilled:

- Initial onboarding provides information regarding boundaries of privacy protection.

Otherwise FAIL

6.7.16.5 Evidence

- Screenshots

6.8 Integrity protection

6.8.1 Overview

This clause provides assessment for the requirements in [clause 5.8](#) relating to CRA [i.1] Annex I Part I (2) (f).

6.8.2 [REQ-INT-01](#) VPN client restores any system configuration it changes to its previous state after the VPN connection ends

6.8.2.1 Objective

Preserve integrity of system configuration.

6.8.2.2 Preparation

List all items of system configuration that the VPN client may alter.

6.8.2.3 Activities

- 1) For each item of system configuration that the VPN client may alter, configure the VPN in a way that would alter that item.
- 2) Collect the state of all system configuration the product may alter.
- 3) Start the VPN connection. After it reports that it is connected, stop the VPN connection.
- 4) Collect the system configuration again and compare with previous version.

6.8.2.4 Verdict

PASS if **all** of the following are fulfilled:

- System configuration modified by VPN matches its state prior to VPN connection.

Otherwise FAIL

6.8.2.5 Evidence

- Collected system configuration
- Annotations of any configuration changes detailing how those changes are not functional
- Log messages from tests

6.8.3 [REQ-INT-02](#) VPN client provides a method to restore any system configuration it changes to its previous state

6.8.3.1 Objective

Preserve integrity of system configuration.

6.8.3.2 Preparation

List all items of system configuration that the VPN client may alter.

6.8.3.3 Activities

- 1) For each item of system configuration that the VPN client may alter, configure the VPN in a way that would alter that item.
- 2) Collect the state of all system configuration the product may alter.
- 3) Start the VPN connection.
- 4) After the VPN reports that it is connected, force the VPN connection to end in a way that does not allow it to execute any VPN connection shutdown tasks.
- 5) Execute the method to restore system configuration.
- 6) Collect the system configuration again and compare with previous version.

6.8.3.4 Verdict

PASS if **all** of the following are fulfilled:

- all system configuration collected is functionally the same before and after the VPN connection starts, and
- the system configuration restoration method completes.

Otherwise FAIL

6.8.3.5 Evidence

- Collected system configuration
- Annotations of any configuration changes detailing how those changes are not functional
- Log messages from tests

- Method used to force connection to end without allowing shutdown tasks to run
- Method used to restore system configuration

6.8.4 [REQ-INT-03](#) VPN client does not degrade system security

6.8.4.1 Objective

Preserve cybersecurity of system.

6.8.4.2 Preparation

List all items of system configuration that the VPN client may alter.

6.8.4.3 Activities

- 1) For each item of system configuration that the VPN client may alter, configure the VPN in a way that would alter that item.
- 2) Collect the state of all system configuration the product may alter.
- 3) Start the VPN connection.
- 4) After the VPN reports that it is connected, force the VPN connection to end in a way that does not allow it to execute any VPN connection shutdown tasks.
- 5) Collect the system configuration again and compare with previous version.

6.8.4.4 Verdict

PASS if **all** of the following are fulfilled:

- All system configuration collected is at least as secure/restricted as before the VPN connection started.

Otherwise FAIL

6.8.4.5 Evidence

- Collected system configuration
- Annotations of any configuration changes detailing how those changes are more restricted/secure
- Log messages from tests
- Method used to force connection to end without allowing shutdown tasks to run

6.8.5 [REQ-INT-04](#) Protocol validity checks

6.8.5.1 Objective

Prevent unauthorized and/or malicious traffic in the VPN connection.

6.8.5.2 Preparation

Create packets for each protocol supported by the traffic policy engine that have invalid or malformed packets designed to bypass the traffic policy.

6.8.5.3 Activities

For each malformed packet, inject the packet into the receiving interface of the VPN client or server.

6.8.5.4 Verdict

PASS if **all** of the following are fulfilled:

- Packet does not exit the VPN interface.

Otherwise FAIL

6.8.5.5 Evidence

- Malformed packets
- Packet capture
- Any log messages showing packet was dropped

6.8.6 [REQ-INT-05](#) Application protocol validity checks by operational environment

6.8.6.1 Objective

Prevent unauthorized and/or malicious traffic in the VPN connection.

6.8.6.2 Preparation

None.

6.8.6.3 Activities

Assess the technical documentation provided with the product.

6.8.6.4 Verdict

PASS if the technical documentation describes how the protocol checks can be provided by the operational environment.

Otherwise FAIL

6.8.6.5 Evidence

- Documentation
- Analysis of documentation
- Documentation of intended purpose

6.9 Data minimisation

6.9.1 Overview

This clause provides assessment for the requirements in [clause 5.9](#) relating to CRA [i.1] Annex I Part I (2) (g).

6.9.2 [REQ-DM-01](#) Data minimisation across the product

6.9.2.1 Objective

Data minimisation.

6.9.2.2 Preparation

None.

6.9.2.3 Activities

- 1) Capture all packets during a typical hour of use.
- 2) Document all data sent to the product's RDPS.
- 3) Label all data as Personal Data or not.
- 4) Document for all Personal Data:
 - if it is kept,
 - for how long,
 - with whom it is shared,
 - how it is stored,
 - whether the user consented to it or the data collection is required for the product's intended purpose, and
 - record of user consent.

6.9.2.4 Verdict

PASS if **all** of the following are fulfilled:

- All Personal Data collected has a record of authorization by the user or is required for the product's intended purpose.

Otherwise FAIL

6.9.2.5 Evidence

- Packet capture
- Documentation of Personal Data
- Authorization
- Documentation of necessity for product's intended purpose

6.9.3 [REQ-DM-02](#) No Personal Data sent outside endpoint

6.9.3.1 Objective

Data minimisation.

6.9.3.2 Preparation

Retrieve internal policy from VPN manufacturer.

6.9.3.3 Activities

- 1) Capture all packets during a typical hour of use.
- 2) Document all data sent to the product's RDPS.
- 3) Label any Personal Data included in packet capture.

6.9.3.4 Verdict

PASS if **all** of the following are fulfilled:

- All labelled Personal Data collected is either:
 - strictly necessary for the confidentiality or availability of the product as outlined in the internal policy and intended use of the VPN manufacturer, or
 - Personal Data collected is explicitly necessary for authentication, access control, or subscription management.
- No personal data is collected from the user's VPN tunnelling and routing functionality which is not intended for the VPN manufacturer.

Otherwise FAIL

6.9.3.5 Evidence

- Packet capture
- Technical documentation demonstrating the necessity of any transmitted data

6.9.4 [REQ-DM-03](#) Minimise Personal Data required service provisioning and payment

6.9.4.1 Objective

Data minimisation.

6.9.4.2 Preparation

Obtain a fresh installation of the VPN product.

6.9.4.3 Activities

- 1) Follow the instructions to use the product and start a VPN connection.
- 2) Select the options that require the least Personal Data.
- 3) Recording all data entered.
- 4) Examine the data entered looking for Personal Data.
- 5) Review the provided documentation demonstrating the necessity of this data in relation to providing the service, processing payment or managing the subscription.

6.9.4.4 Verdict

PASS if **any** of the following are fulfilled:

- There is no Personal Data recorded, or
- Personal Data recorded has a documentation providing the legal or operational reason it is essential for the delivery of the service or payment processing.

Otherwise FAIL

6.9.4.5 Evidence

- The record of data entered with a short description indicating whether the particular data element alone or in combination with other data elements allows for singling out the individual in accordance with the definition of Personal Data under the applicable law. Where this is the case, the reason the data element is required should also be documented.

6.9.5 [REQ-DM-04](#) Minimise Personal Data stored

6.9.5.1 Objective

Confidentiality.

6.9.5.2 Preparation

None.

6.9.5.3 Activities

Gather any data stored on the VPN server, gateway or exit node during a typical hour of use or simulate usage. Label any present Personal Data as such.

6.9.5.4 Verdict

PASS if **any** of the following are fulfilled:

- There is no Personal Data recorded, or
- the product has a documented operational necessity for any Personal Data recorded which aligns with the intended purpose of the product.

Otherwise FAIL

6.9.5.5 Evidence

- Policy
- Samples of stored data
- Documentation of the operational reason for samples to contain Personal Data in order to fulfil the intended purpose of the product

6.9.6 [REQ-DM-05](#) No data persistence or storage enabled on exit nodes

6.9.6.1 Objective

Minimisation of data compromise due to equipment compromise, Confidentiality of data.

6.9.6.2 Preparation

- 1) Obtain the technical documentation detailing the server provisioning architecture for the remote data processing solutions.
- 2) Obtain administrative access to a test instance of the VPN exit node configured identically to the production environment.

6.9.6.3 Activities

Perform steps in sequence:

- 1) Examine the server's operating system configuration (e.g. filesystem table/fstab, boot parameters) to verify that all system directories (including /var/log and temporary storage) are mounted exclusively on volatile memory (RAM disks).
- 2) Verify that unencrypted non-volatile swap partitions are disabled.
- 3) Generate network traffic through the test node, then power cycle (reboot) the server and inspect the storage.

6.9.6.4 Verdict

PASS if **any** of the following are fulfilled:

- The server utilizes volatile disk-based storage for system logs, swap, or temporary processing, or
- data does not persist across a power cycle.

Otherwise FAIL

6.9.6.5 Evidence

- Copies of the relevant server configuration files demonstrating the use of RAM disks
- The output of the storage inspection after the power cycle

6.10 Availability protection

6.10.1 Overview

This clause provides assessment for the requirements in [clause 5.10](#) relating to CRA [i.1] Annex I Part I (2) (h).

6.10.2 [REQ-AP-01](#) Fast packet drop

6.10.2.1 Objective

Maintain service availability during denial-of-service attacks.

6.10.2.2 Preparation

Using packet generation software to bypass operating system level interference, create a selection of invalid packets and enable some type of instrumentation or logging in the packet validity checking code.

6.10.2.3 Activities

For each invalid packet:

- 1) send the packet to the product, and
- 2) record the checks it makes and its use of system resources before it drops the packet.

6.10.2.4 Verdict

PASS if **all** of the following are fulfilled:

- For each invalid packet:
 - the packet did not use resources that were not reasonably required to reject the packet, and

- the packet was rejected.

Otherwise FAIL

6.10.2.5 Evidence

- Invalid packets and descriptions
- Logs of processing
- Annotations detailing how the order of operations is the most efficient reasonable way to process the packet

6.10.3 [REQ-AP-02](#) Limit memory usage

6.10.3.1 Objective

Maintain service availability during denial-of-service attacks.

6.10.3.2 Preparation

Identify input fields from untrusted input that are used to calculate the size of memory allocations, and create a set of inputs that, if processed as fast as possible, would significantly degrade the function of the product due to overallocation of memory.

6.10.3.3 Activities

For each set of inputs,

- 1) send the input to the product,
- 2) while simultaneously measuring the availability of the product functions and the functions of the underlying platform.

6.10.3.4 Verdict

PASS if **all** of the following are fulfilled:

- For each set of inputs:
 - the product functions, and
 - the platform functions remain acceptably available.

Otherwise FAIL

6.10.3.5 Evidence

- Set of inputs
- Logs of measurements
- Explanation of availability metrics

6.10.4 [REQ-AP-03](#) Availability protection provided by operational environment

6.10.4.1 Objective

Maintain service availability during denial-of-service attacks.

6.10.4.2 Preparation

None.

6.10.4.3 Activities

Assess the technical documentation provided with the product.

6.10.4.4 Verdict

PASS if the technical documentation describes how the availability protection can be provided by the operational environment.

Otherwise FAIL

6.10.4.5 Evidence

- Documentation
- Analysis of documentation
- Documentation of intended purpose

6.10.5 [REQ-AP-04](#) Rate limit unauthenticated traffic

6.10.5.1 Objective

Maintain service availability during denial-of-service attacks.

6.10.5.2 Preparation

None.

6.10.5.3 Activities

- 1) Start capturing on all interfaces,
- 2) repeatedly flood the node with unauthenticated traffic, and
- 3) observe any traffic rejections or package dropping.

6.10.5.4 Verdict

PASS if **all** of the following are fulfilled:

- Rate limiting can be observed.

Otherwise FAIL

6.10.5.5 Evidence

- Network package capture
- Log messages

6.11 Non-interference

6.11.1 Overview

This clause provides assessment for the requirements in [clause 5.11](#) relating to CRA [i.1] Annex I Part I (2) (i).

6.11.2 [REQ-IM-01](#) No route between different endpoints by default

6.11.2.1 Objective

Prevent unauthorized network access to endpoints.

6.11.2.2 Preparation

None.

6.11.2.3 Activities

Connect two endpoints and attempt to connect to a port on the other endpoint.

6.11.2.4 Verdict

PASS if **any** of the following are fulfilled:

- Connection not possible, or
- connection fails.

Otherwise FAIL

6.11.2.5 Evidence

- Log messages
- Packet capture

6.11.3 [REQ-IM-02](#): Minimise data transmitted to unverified sources

6.11.3.1 Objective

Minimise negative impact on other devices or services.

6.11.3.2 Preparation

Identify interfaces that may transmit data originating from the product itself in reply to incoming data to addresses that have not been verified as requesting the transmitted data. Identify network input that may cause the interface to transmit data in such a manner.

6.11.3.3 Activities

For each identified network input, transmit the input to the interface and record any data the product transmits in response. Analyse the amount of data sent in response in the context of the product function and cybersecurity risk assessment.

6.11.3.4 Verdict

PASS if **all** of the following are fulfilled:

- the response is consistent with reasonable minimisation of data in the response.

Otherwise FAIL

6.11.3.5 Evidence

- List of identified interfaces
- List of methods for identifying interfaces
- Sufficient analysis of methods for identifying interfaces
- List of identified inputs
- Packet captures or other appropriate logs of the data transmitted
- Sufficient analysis of amount of data in response

6.12 Attack surface minimisation

6.12.1 Overview

This clause provides assessment for the requirements in [clause 5.12](#) relating to CRA [i.1] Annex I Part I (2) (j).

6.12.2 [REQ-MAS-01](#) Unnecessary VPN client permissions

6.12.2.1 Objective

Operate on a least privilege principle.

6.12.2.2 Preparation

List all the permissions that may be granted to applications.

6.12.2.3 Activities

- 1) Collect all the permissions that may be requested by the VPN.
- 2) For each permission, lookup the state after the product installation.
- 3) Start the VPN connection.
- 4) Collect the permission states again and compare with previous version.

6.12.2.4 Verdict

PASS if **all** of the following are fulfilled:

- The VPN client did not request permissions beyond those necessary for its documented functionality.

Otherwise FAIL

6.12.2.5 Evidence

- Collected permission states

- Annotations of any permission requests detailing how those permissions are more restricted/secure
- Log messages from tests

6.13 Exploit mitigation

6.13.1 Overview

This clause provides assessment for the requirements in [clause 5.13](#) relating to CRA [i.1] Annex I Part I (2) (k).

6.13.2 [REQ-EMM-01](#) Route traffic from other sources/destination disabled by default

6.13.2.1 Objective

Prevent unauthorized network access to endpoints.

6.13.2.2 Preparation

None.

6.13.2.3 Activities

Connect an endpoint and capture the traffic on all interfaces.

6.13.2.4 Verdict

PASS if **all** of the following are fulfilled:

- There is no traffic originating from the VPN for sources/destinations other than the endpoint.

Otherwise FAIL

6.13.2.5 Evidence

- Packet capture with annotations of origin of packet

6.13.3 [REQ-EMM-02](#) Notify user if routing traffic from other sources/destination

6.13.3.1 Objective

Prevent unauthorized network access to endpoints.

6.13.3.2 Preparation

None.

6.13.3.3 Activities

- 1) Connect an endpoint,
- 2) enable the routing of external traffic through it, and
- 3) observe the UI and system.

6.13.3.4 Verdict

PASS if **any** of the following are fulfilled:

- User receives some alert that clearly indicates forwarding is enabled, or
- the operating environment produces a notification that clearly indicates forwarding is enabled.

Otherwise FAIL

6.13.3.5 Evidence

- Record of UI change

6.13.4 [REQ-EMM-03](#) No routing traffic from other sources/destination if not necessary for services

6.13.4.1 Objective

Prevent unauthorized network access to endpoints.

6.13.4.2 Preparation

None.

6.13.4.3 Activities

- 1) Create a list of services that can only be used if routing of external traffic is enabled, and
- 2) document the reason each service requires routing of external traffic to function.

6.13.4.4 Verdict

PASS if **all** of the following are fulfilled:

- All such services are documented, and
- documentation aligns with the product's functionality.

Otherwise FAIL

6.13.4.5 Evidence

- Documentation of services

6.14 Monitoring

6.14.1 Overview

This clause provides assessment for the requirements in [clause 5.14](#) relating to CRA [i.1] Annex I Part I (2) (l).

6.14.2 [REQ-LOG-01](#) Local event logging

6.14.2.1 Objective

Monitoring and recording cybersecurity-relevant events.

6.14.2.2 Preparation

Review the technical documentation to confirm the scope of cybersecurity-relevant events implemented in the logging mechanism.

6.14.2.3 Activities

For each type of cybersecurity-relevant event mentioned in clause 5.14.1.2:

- 1) trigger the event on the endpoint, and
- 2) collect any locally generated log messages recording the event, and
- 3) capture any packets being transmitted to the manufacturer.

6.14.2.4 Verdict

PASS if **all** of the following are fulfilled:

- at least one log message correlates to a cybersecurity-relevant event as listed in clause 5.14.1.2, and
- for each triggered event:
 - the collected log message reflects the cybersecurity-relevant event,
 - the log message indicating the event does not include any secrets, credentials, network traffic content or connection metadata as defined in clause 5.14.1.3, and
 - the log message indicating the event is not transmitted to the manufacturer without explicit user authorization, or the technical documentation demonstrates the necessity of this transmission in order to fulfill the intended purpose of the product.

Otherwise FAIL

6.14.2.5 Evidence

- Method of triggering events
- Log messages with annotations
- Packet captures demonstrating no unauthorized transmission of logs

6.14.3 [REQ-LOG-02](#) Internal event logging

6.14.3.1 Objective

Monitoring and recording cybersecurity-relevant events.

6.14.3.2 Preparation

Review the manufacturer's documentation to confirm the scope of cybersecurity-relevant events implemented in the logging mechanism.

6.14.3.3 Activities

For each type of cybersecurity-relevant event mentioned in clause 5.14.1.2:

- 1) trigger the event on the endpoint, and
- 2) collect any locally generated log messages recording the event.

6.14.3.4 Verdict

PASS if **all** of the following are fulfilled:

- at least one log message correlates to a cybersecurity-relevant event as listed in clause 5.14.1.2, and
- for each triggered event:
 - the collected log message reflects the cybersecurity-relevant event, and
 - the log message indicating the event does not include any confidential information such as secrets or credentials.

Otherwise FAIL

6.14.3.5 Evidence

- Method of triggering events
- Log messages with annotations
- Packet captures demonstrating no unauthorized transmission of logs

6.14.4 [REQ-LOG-03](#) Remote Logging

6.14.4.1 Objective

Transfer log messages regarding cybersecurity-relevant events to mitigate local tampering.

6.14.4.2 Preparation

List all types of cybersecurity-relevant events.

6.14.4.3 Activities

For each type of cybersecurity-relevant event:

- 1) trigger the event on the endpoint, and
- 2) collect any locally generated log messages recording the event.

6.14.4.4 Verdict

PASS if **all** of the following are fulfilled:

For each triggered event:

- the collected log message reflects the cybersecurity-relevant event, and
- the log message indicating the event does not include any confidential information such as secrets or credentials.

Otherwise FAIL

6.14.4.5 Evidence

- Method of triggering events
- Log messages with annotations

6.14.5 [REQ-LOG-04](#) Privacy-preserving logs policy and traffic anonymization

6.14.5.1 Objective

Data minimisation and Confidentiality of data.

6.14.5.2 Preparation

Gather the technical documentation detailing the logging architecture of the remote data processing solutions, and obtain administrative access to a test instance of the VPN server configured identically to the production environment.

6.14.5.3 Activities

- 1) Examine the server and routing software configuration files to verify that the logging of connection metadata and Personal Data is disabled or discarded,
- 2) start a VPN connection from a client and generate network traffic, and
- 3) inspect the remote server's persistent storage for the client's source IP, destination IPs, or plaintext connection information.

6.14.5.4 Verdict

PASS if **any** of the following are fulfilled:

- The server configuration does not permit the persistent storage of user network traffic data, or
- no Personal Data or connection metadata is found persistently stored on the remote data processing system after generating traffic.

Otherwise FAIL

6.14.5.5 Evidence

- Copies of the relevant server configuration files demonstrating that logging is disabled
- A description of the test traffic generated
- The output of the server storage/log inspection confirming the absence of the specified data

6.15 Factory reset and data portability

6.15.1 Overview

This clause provides assessment for the requirements in [clause 5.15](#) relating to CRA [i.1] Annex I Part I (2) (m).

6.15.2 [REQ-DRT-01](#) Secure deletion via "factory reset"

6.15.2.1 Objective

Secure deletion.

6.15.2.2 Preparation

Document every type of stored data or setting that may be changed by the user on the product, how to store it on the product, and how to read it from the product.

6.15.2.3 Activities

For each type of user data or setting that may be stored and changed by the user on the product:

- 1) write an instance of the data or setting stored on the product that is different from the default, and
- 2) read it from the product.

Once all types of data have been written and read, invoke the "factory reset" or equivalent command to revoke all data and settings and read each type of data again.

6.15.2.4 Verdict

PASS if **all** of the following are fulfilled:

- No data or setting is the same for both of the reads.

Otherwise FAIL

6.15.2.5 Evidence

- Record of each type of data or setting
- What data or setting was written
- What data or setting was returned by the first read
- What data or setting was returned by the second read
- Comparison of each write

6.15.3 [REQ-DRT-02](#) Secure deletion via reinstallation

6.15.3.1 Objective

Secure deletion.

6.15.3.2 Preparation

Document every type of data or setting that may be stored and changed by the user on the product, how to store it on the product, and how to read it from the product.

6.15.3.3 Activities

For each type of user data or setting that may be stored and changed by the user on the product:

- 1) Write an instance of the data or setting stored on the product that is different from the default, and
- 2) read it from the product.

Once a breadth of data points have been written and read, reinstall the product with the secure delete option, and read the data or settings again.

6.15.3.4 Verdict

PASS if **all** of the following are fulfilled:

- No configured data is the same for both of the reads.

Otherwise FAIL

6.15.3.5 Evidence

- Record of each type of data or setting
- What data or setting was written
- What data or setting was returned by the first read
- What data or setting was returned by the second read
- Comparison of each read

6.15.4 [REQ-DRT-03](#) Secure data read from product

6.15.4.1 Objective

Secure data read.

6.15.4.2 Preparation

List all data and settings

6.15.4.3 Activities

For each type of data or setting:

- 1) read the data or setting as an authorized user, then
- 2) attempt read the data or setting as an unauthorized user, if any exists.

6.15.4.4 Verdict

PASS if **all** of the following are fulfilled:

- All data and settings can be read by the authorized user, and
- no data or setting can be read by an unauthorized user.

Otherwise FAIL

6.15.4.5 Evidence

- List of data and settings
- Log message showing success or failure of each read by the authorized user
- The unauthorized user, if applicable

6.15.5 [REQ-DRT-04](#) Secure data export

6.15.5.1 Objective

Secure data export.

6.15.5.2 Preparation

Identify the methods provided by the product to export the data to a local file.

6.15.5.3 Activities

- 1) Authenticate as an authorized user,
- 2) read the data or settings, and
- 3) initiate the export, then
- 4) open and read the exported file.

6.15.5.4 Verdict

PASS if **all** of the following are fulfilled:

- The export completes successfully, and
- the data and settings reflect those on the product from which the export was performed, and
- product displayed warning if private keys or credentials were included in plaintext export.

Otherwise FAIL

6.15.5.5 Evidence

- List of exported data and settings
- Log messages from the export in direct response to user action
- Exported configuration reflecting accurate representation of product settings

Annex A (informative): Relationship between the present document and the essential cybersecurity requirements of EU Regulation (EU) 2024/2847

The present document has been prepared under the Commission's standardisation request C(2025)618 final [i.3] to provide one voluntary means of conforming to the essential requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

**Table A.1: Relationship between the present document and
the requirements of Regulation (EU) 2024/2847 - the Cyber Resilience Act**

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (1)	"Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks."	Clauses 5.2, 6.2 and R.4	
Annex I, Part I, (2)(a)	"Products with digital elements shall be made available on the market without known exploitable vulnerabilities."	Clauses 5.3 and 6.3	
Annex I, Part I, (2)(b)	"Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state."	Clauses 5.4 and 6.4	
Annex I, Part I, (2)(c)	"Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them"	Clauses 5.5 and 6.5	
Annex I, Part I, (2)(d)	"Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access"	Clauses 5.6, 6.6, R.4.2.1 and R.4.3.1	

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (2)(e)	"Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by best practice mechanisms, and by using other technical means."	Clauses 5.7, 6.7, R.4.2.3 and R.4.3.3	
Annex I, Part I, (2)(f)	"Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions."	Clauses 5.8 , 6.8, R.4.2.2 and R.4.3.2	
Annex I, Part I, (2)(g)	"Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)."	Clauses 5.9 and 6.9	
Annex I, Part I, (2)(h)	"Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks."	Clauses 5.10, 6.10, R.4.2.4 and R.4.3.4	
Annex I, Part I, (2)(i)	"Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks."	Clauses 5.11 and 6.11	
Annex I, Part I, (2)(j)	"Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces."	Clauses 5.12, 6.12, R.4.2.1 and R.4.3.1	
Annex I, Part I, (2)(k)	"Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques."	Clauses 5.13, 6.13, R.4.2.4 and R.4.3.4	
Annex I, Part I, (2)(l)	"Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user."	Clauses 5.14 and 6.14	
Annex I, Part I, (2)(m)	"Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner."	Clauses 5.15 and 6.15	

Key to columns:

Description A textual reference to the requirement.

Requirements of Regulation

Identification of point(s) defining the requirement in Regulation (EU) 2024/2847 - the Cyber Resilience Act.

Clause(s) of the present document

Identification of clause(s) addressing the requirement in the present document

Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list published in the Official Journal of the European Union. Users of the present document should consult frequently the latest list published in the Official Journal of the European Union.

Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

Annex B (informative): Security analysis

B.0 Overview

This annex applies state of the art methodology to identify assets, threats, identify and evaluate risks factors in the different use cases identified in the product context. The security analysis in this annex represents a risk assessment done by the standardisers solely for the purpose of informing the applicability of technical requirements.

A list of product assets are used to identify potential threats to the product. The assumptions are used to define the scope of potential threats that are addressed by this security analysis.

Risk factor levels for each use case are determined by using the operational coenvironment of each use case to choose a risk factor level that most accurately represents the highest risk for that use case (see [clause 4](#), product context). The use case is determined by the intended purpose of the product specified by the manufacturer.

For each threat, a formula based on the risk factor levels is used to calculate the likelihood and impact of the threat. This security analysis uses the likelihood and impact of each threat to identify specific technical requirements that treat that risk.

B.1 Assets

B.1.0 Overview

The purpose of cybersecurity is to protect the product assets, which include product data, product functions, digital assets, human-related assets, and hardware. The compromise of each type of asset will have a different impact on the cybersecurity and the functionality of the product. Each asset has a corresponding value to the cybersecurity of the asset.

B.1.1 Data assets

Table B.1.1-1: VPN product data assets

Asset	Compromise impacts	Value
Data transmitted over the VPN network	Confidentiality, integrity, functions	High
Product configuration	Confidentiality, functions	High
CA information, certificates & keys	Authorization/access control	High
Management application certificates	Authorization/access control	Medium
Logs with identifying information	Confidentiality, monitoring	Medium
Configuration audit logs	Monitoring	Low
Network statistics	Monitoring	Low
Debugging logs	Monitoring	Low
Telemetry	Monitoring	Low

B.1.2 Product functions

What follows is a basic overview of VPN functions. See [clause 4.2](#) for a detailed overview of the functions of a VPN product.

Table B.1.2-1: VPN product functions

Asset	Compromise impacts	Value
Authentication/access control of VPN endpoints	Authentication/access control	High
Authentication/access control of VPN servers	Authentication/access control	High
Encryption of network traffic	Confidentiality	High
Privacy protection	Confidentiality	High
Network traffic routing/filtering/forwarding	Access control, functions	Medium

B.1.3 Digital assets

Table B.1.3-1: VPN digital assets

Asset	Compromise impacts	Value
VPN server applications	Everything	Astronomical
VPN endpoint applications	All endpoint assets, some VPN network assets	High

B.1.4 Human-associated assets

Table B.1.4-1: VPN human-associated assets

Asset	Compromise impacts	Value
Credentials	Authorization/access control	High
Identity	Confidentiality	High
Location	Confidentiality	Medium
Personal data	Confidentiality	Medium
VPN usage data	Confidentiality	Low

B.1.5 Hardware assets

None for the products in the scope of the present document.

B.2 Risk factors

B.2.1 General

Risk factors influence the likelihood or impact of a threat to a product asset. Thus, risk factors determine which mitigation(s) satisfy each of the cybersecurity requirements in [clause 5](#).

The creator of a product risk assessment determines the level of each risk factor via the development of a threat model and risk profile based on the intended purpose and foreseeable use of the VPN.

Risk factors may increase one or both of the likelihood and impact of a compromise. As a result, different mitigation strategies may be more or less relevant to different risk factors.

The overall risk related to each use case should be considered as a result of combining risk factors affecting both likelihood and impact of an incident.

See [clause B.4.2](#) for the definition of risk factor levels.

B.2.2 RF-CFG: Endpoint configuration

Description: Complexity of endpoint configuration.

Rationale: More complex endpoint configuration increases the likelihood of compromise via accidental misconfiguration.

- **[CFG-0]** Endpoint requires no configuration
- **[CFG-1]** Endpoint requires simple configuration, such as selecting an established VPN protocol or selecting a region to which to connect
- **[CFG-2]** Endpoint requires configuration by a skilled administrator

B.2.3 RF-AUT: Account management and authentication of endpoints

Description: Type of account management and authentication for endpoints.

Rationale: The type of account management and authentication changes the likelihood and impact of threats targeting authentication.

- **[AUT-0]** User employs a third party identity and authentication provider
- **[AUT-1]** Identity and authentication are managed through a user-owned and managed centralized identity system
- **[AUT-2]** Each system utilized by the user involves its own set of account information and secrets

B.2.4 RF-DTX: Sensitivity of data transmitted

Description: Importance of protecting confidentiality and integrity of data transmitted.

Rationale: More sensitive data increases both likelihood and impact of compromise.

- **[FUN-0]** Compromise of data would be a minor annoyance (e.g. preventing accessing unimportant websites)
- **[FUN-1]** Compromise of data would impede daily activities
- **[FUN-2]** Compromise of data would threaten human rights of user or business continuity

B.2.5 RF-DST: Sensitivity of data stored

Description: Importance of protecting confidentiality and integrity of data stored.

Rationale: More sensitive data increases both likelihood and impact of compromise.

- **[FUN-0]** Compromise of data would be a minor annoyance (e.g. preventing accessing unimportant websites)
- **[FUN-1]** Compromise of data would impede daily activities
- **[FUN-2]** Compromise of data would threaten human rights of user or business continuity

B.2.6 RF-FUN: Sensitivity of functions

Description: Importance of protecting availability of product functions.

Rationale: More sensitive functions increases both likelihood and impact of compromise.

- **[FUN-0]** Loss of function would be a minor annoyance (e.g. preventing accessing unimportant websites)

- **[FUN-1]** Loss of function would impede daily activities
- **[FUN-2]** Loss of function would threaten human rights of user or business continuity

B.2.7 RF-ADM: Availability and skill of administration

Description: Availability and skill of administration for the product.

Rationale: Skilled, fully resourced administration allows proactive risk assessment and mitigation and can reduce the impact of incidents.

- **[ADM-0]** Skilled administration, fully resourced
- **[ADM-1]** Skilled administration, partially resourced
- **[ADM-2]** Unskilled administration

B.2.8 RF-RDP: Manufacturer infrastructure isolation

Description: Exposure of manufacturer RDPS infrastructure responsible for essential functions of the product.

Rationale: More users accessing manufacturer infrastructure increases likelihood of an attack via hardware interfaces.

- **[RDP-0]** Manufacturer does not provide any remote data processing
- **[RDP-1]** Manufacturer provides RDPS via self-hosted infrastructure
- **[RDP-2]** Manufacturer infrastructure located in a multi-tenant SaaS system

B.2.9 RF-DNC: Difficulty of network configuration

Description: Difficulty of configuring, controlling, and monitoring the configuration of the network connection on the platform the product is running on.

Rationale: The more difficult it is to configure the network connection, maintain control over that configuration, and learn about changes to the configuration, the more likely it is that the configuration will become insecure.

- **[DNC-0]** Product has complete control over the network configuration
- **[DNC-1]** Product is using a well-defined, reliable platform service to configure the network connection but does not have total control of the configuration
- **[DNC-2]** Other software can change network configuration without notification or permission from the product

B.2.10 RF-COM: Complexity of feature set

Description: Complexity of the features necessary for the product's foreseeable use

Rationale: More features mean more code and more interfaces mean attack surface.

- **[COM-0]** Usage requires only basic features to tunnel encrypted traffic
- **[COM-1]** Usage requires a few additional features related to tunnelling encrypted traffic
- **[COM-2]** Usage requires many additional features

Guidance: At present, the complexity of the implementation and the exposed interfaces are accounted for in a single risk factor. This is sufficient for the security analysis in the present document but may need to be separated into two risk factors for future versions.

B.2.11 RF-MSH: Mesh connectivity offered

Description: Whether the VPN connects different endpoints to each other via a private network or simply provides a tunnel from a single endpoint to a public network.

Rationale: More endpoints able to connect to each other within the private network means more risk of compromise via the shared private network connectivity and greater privileges often granted to endpoints sharing the private network.

- **[MSH-0]** Usage is a single endpoint connecting only to a public network
- **[MSH-1]** Usage is one endpoint connecting a private network to a public network
- **[MSH-2]** Usage is multiple endpoints connecting to a shared private network in addition to connecting to a public network

B.2.12 RF-PRI: Consequences of compromise of privacy

Description: How important protecting the privacy of the VPN user is.

Rationale: Affects both likelihood and impact of attempts to compromise the privacy of the user.

- **[PRI-0]** Loss of privacy has no impact or user's identity is already known
- **[PRI-1]** Loss of privacy has moderate impact, such as minor loss of reputation
- **[PRI-2]** Loss of privacy has high consequences, such as loss of employment, life, or human rights

B.2.13 RF-UAP: Consequences of unauthorized access to private network

Description: How important protecting access to the connected private network, if any.

Rationale: Affects both likelihood and impact of attempts to get unauthorized access to the private network.

- **[UAP-0]** Does not provide access to a private network
- **[UAP-1]** Access to private network has moderate consequences, such as allowing unauthorized use of network resources
- **[UAP-2]** Access to private network has high consequences, such as breach of critical enterprise data

B.2.14 RF-NUM: Number of nodes in private network

Description: How many nodes are in the private network.

Rationale: A larger number of nodes increases the attack surface and the consequences of an attack.

- **[NUM-0]** No private network, such as single-node VPN for public network access
- **[NUM-1]** Small number of nodes in the private network, such as a home network or small business
- **[NUM-2]** Large number of nodes in the private network, such as a medium or large enterprise

B.2.15 RF-NET: Public accessibility of network

Description: How publicly accessible the underlying network is.

Rationale: The more unrestricted the access to underlying network is, the more likely a threat actor can send packets to the device.

- **[NET-0]** Foreseeable use is in an isolated private network
- **[NET-1]** Foreseeable use is in a private network with filtered connection to public network
- **[NET-2]** Foreseeable use is in a public network

B.3 Assumptions

B.3.0 Overview

Assumptions limit the scope of threats considered by this security analysis. A manufacturer's cybersecurity risk assessment may have a different scope.

B.3.1 Platform

The platform the product is running on is trustworthy.

B.3.2 Proper administrator

The product administrator is not intentionally hostile and is engaging in good faith efforts to administer the product properly.

B.3.3 Attacker has limited physical access to product

An attacker will have only temporary physical access to the platform running the product.

B.3.4 Attacker has limited resources

An attacker will use limited resources in proportion to the value of the assets of the product in each use case.

B.4 Threats and security analysis

B.4.1 General

The approach to listing threats is to separate by mitigation so that each may be associated with risk factors more directly.

For the purposes of the list of threats, the product includes:

- VPN software operating on an end-user node
- VPN software operating as a VPN server on any hardware
- software used to manage VPN network topology

B.4.2 Security analysis methodology

Risk factor levels are determined by reading the descriptions for each risk factor and choosing the level that most accurately represents the highest risk for the use case being analysed.

For each threat, a formula based on the risk factor levels is used to calculate the Likelihood and Impact of the threat, on a scale of Low, Medium, and High.

For each threat, both likelihood and impact should be Low before the risk is considered sufficiently mitigated. If the calculated levels are not already Low, then mitigations should be applied until both likelihood and impact are Low. The mitigation sets that will accomplish this are listed in each threat description.

B.4.3 TH-UEVU: Unknown exploitable vulnerabilities

Attacker may use unknown exploitable vulnerabilities in the product implementation to get unauthorized access to product assets.

Table B.4.3-1: Unknown exploitable vulnerabilities

Risk factors	Likelihood	Use cases
any of (COM, FUN, PRI, UAP) = 2	High	UC-3, UC-4, UC-5, UC-6, UC-7
all others	Medium	UC-1, UC-2

Table B.4.3-2: Unknown exploitable vulnerabilities

Risk factors	Impact	Use cases
FUN = 2	High	UC-3, UC-5, UC-6
all others	Medium	UC-2, UC-4, UC-7
FUN = 0	Low	UC-1

Mitigations for Likelihood:

- Medium to Low:
 - REQ-SSD-01 OR REQ-SSD-02
 - REQ-MAS-01
- High to Low:
 - REQ-SSD-01 OR REQ-SSD-02
 - REQ-MAS-01

Mitigations for Impact:

- Medium to Low:
 - REQ-LOG-01 OR REQ-LOG-02
 - REQ-CON-14
- High to Low:
 - REQ-LOG-01 OR REQ-LOG-02
 - REQ-CON-14

B.4.4 TH-KEVU: Known exploitable vulnerabilities

Attacker may use known exploitable vulnerabilities in the product implementation to get unauthorized access to product assets.

Table B.4.4-1: Known exploitable vulnerabilities

Risk factors	Likelihood	Use cases
ADM > 0	High	UC-1, UC-2, UC-3, UC-4, UC-6, UC-7
all others	Medium	UC-5

Table B.4.4-2: Known exploitable vulnerabilities

Risk factors	Impact	Use cases
FUN = 2 OR NUM = 2	High	UC-3, UC-5, UC-6
all others	Medium	UC-1, UC-2, UC-4, UC-7

All mitigations from TH-UEVU apply (using that requirement's risk formula), **in addition to:**

Mitigations for Likelihood for products updated by their operational environment:

- Medium to Low:
 - REQ-KEV-01
 - REQ-SU-02
 - REQ-SU-05 OR REQ-SU-06
- High to Low:
 - REQ-KEV-01
 - REQ-SU-02
 - REQ-SU-06

Mitigations for Likelihood for products updated by the product:

- Medium to Low:
 - REQ-KEV-01
 - REQ-SU-01
 - REQ-SU-03 OR REQ-SU-04
- High to Low:
 - REQ-KEV-01
 - REQ-SU-01
 - REQ-SU-04
 - REQ-SU-07
 - REQ-SU-08
 - REQ-SU-09
 - REQ-SU-10
 - REQ-SU-11

- REQ-SU-12
- REQ-SU-13
- REQ-SU-14

Mitigations for Impact:

- Medium to Low:
 - REQ-LOG-01 OR REQ-LOG-02
 - REQ-CON-14
- High to Low:
 - REQ-LOG-01 OR REQ-LOG-02
 - REQ-CON-14

B.4.5 TH-UEAC: Unauthorized endpoint access

Attacker may gain unauthorized access to an endpoint.

Table B.4.5-1: Unauthorized endpoint access

Risk factors	Likelihood	Use cases
any of (NUM, FUN, COM) = 2	High	UC-3, UC-4, UC-5, UC-6, UC-7
all others	Medium	UC-1, UC-2

Table B.4.5-2: Unauthorized endpoint access

Risk factors	Impact	Use cases
FUN = 2	High	UC-3, UC-5, UC-6
all others	Medium	UC-1, UC-2, UC-4, UC-7

Mitigations for Likelihood:

- Medium to Low:
 - REQ-AAC-01
 - REQ-AAC-02
 - REQ-AAC-06
 - REQ-AAC-07
- High to Low:
 - REQ-AAC-01
 - REQ-AAC-02
 - REQ-AAC-06
 - REQ-AAC-07
 - If MSH = 2: REQ-AAC-08

Mitigations for Impact:

- Medium to Low:
 - If UAP > 0: REQ-AAC-05
 - REQ-CON-14
- High to Low:
 - REQ-AAC-03
 - REQ-AAC-04
 - If UAP > 0: REQ-AAC-05
 - REQ-CON-14

B.4.6 TH-DOSA: Denial of service attack

Denial-of-service attack on product reduces availability of functions.

NOTE: Denial-of-service attack on any associated RDPS or the product's interaction with it is handled in Annex R.

Table B.4.6-1: Denial of service attack

Risk factors	Likelihood	Use cases
NET = 2 AND FUN = 2	High	UC-3, UC-5, UC-6
all others	Medium	UC-1, UC-2, UC-4, UC-7

Table B.4.6-2: Denial of service attack

Risk factors	Impact	Use cases
NET = 2 AND FUN = 2	High	UC-3, UC-5, UC-6
all others	Medium	UC-2, UC-4
NET = 0 OR FUN = 0	Low	UC-1

Mitigations for Likelihood:

- Medium to Low:
 - REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02)
- High to Low:
 - REQ-AP-03 OR (REQ-AP-01 AND REQ-AP-02 AND REQ-AP-04)

Mitigations for Impact:

- Medium to Low:
 - REQ-LOG-01 OR REQ-LOG-02
 - REQ-INT-04 OR REQ-INT-05
- High to Low:
 - REQ-LOG-01 OR REQ-LOG-02
 - REQ-INT-04 OR REQ-INT-05

B.4.7 TH-MITM: Machine-in-the-middle

Attacker may read or modify traffic by capturing and relaying activity to and from endpoints.

Table B.4.7-1: Machine-in-the-middle

Risk factors	Likelihood	Use cases
NET = 2 AND DTX > 0 AND ADM > 0	High	UC-2, UC-3, UC-4, UC-6, UC-7
all others	Medium	UC-1, UC-5
NET = 0	Low	none

Table B.4.7-2: Machine-in-the-middle

Risk factors	Impact	Use cases
DTX = 2 OR PRI = 2	High	UC-3, UC-5, UC-6
all others	Medium	UC-2, UC-4, UC-7
DTX = 0 AND PRI = 0	Low	UC-1

Mitigations for Likelihood:

- Medium to Low:
 - REQ-AAC-01
 - REQ-AAC-02
 - REQ-AAC-07
 - REQ-CON-13
- High to Low:
 - REQ-AAC-01
 - REQ-AAC-02
 - REQ-AAC-03
 - REQ-AAC-04
 - REQ-AAC-05
 - REQ-AAC-07
 - REQ-CON-13

Mitigations for Impact:

- Medium to Low:
 - REQ-DM-01
- High to Low:
 - REQ-DM-01

B.4.8 TH-DLEK: Sensitive DNS query leaks

Attacker may read sensitive DNS queries sent outside the VPN connection.

Table B.4.8-1: Sensitive DNS query leaks

Risk factors	Likelihood	Use cases
NET = 2 AND PRI = 2 AND DNC = 2	High	UC-3
all others	Medium	UC-2, UC-7
NET = 0 OR PRI = 0 OR DNC = 0	Low	UC-1, UC-4, UC-5, UC-6

Table B.4.8-2: Sensitive DNS query leaks

Risk factors	Impact	Use cases
PRI = 2	High	UC-3
all others	Medium	UC-2, UC-7
PRI = 0	Low	UC-1, UC-4, UC-5, UC-6

Mitigations for Likelihood:

- Medium to Low:
 - REQ-CON-01
 - REQ-CON-02
 - if MSH = 2: REQ-CON-04
 - REQ-CON-05
 - REQ-CON-06
- High to Low:
 - REQ-CON-01
 - REQ-CON-02
 - REQ-CON-03
 - if MSH = 2: REQ-CON-04
 - REQ-CON-05
 - REQ-CON-06
 - REQ-CON-07
 - REQ-CON-08
 - REQ-CON-09
 - REQ-CON-10
 - REQ-CON-11
 - REQ-CON-12

Mitigations for Impact:

- Medium to Low:
 - REQ-LOG-01
- High to Low:
 - REQ-LOG-01

B.4.9 TH-PLNS: Transmitting sensitive data in the clear in a single endpoint VPN

Attacker may read sensitive data transmitted without encryption in a single endpoint VPN.

Table B.4.9-1: Transmitting sensitive data in the clear in a single endpoint VPN

Risk factors	Likelihood	Use cases
UAP = 0 AND NET = 2 AND DTX = 2	High	UC-3
all others	Medium	UC-2
UAP > 0 OR NET = 0 OR DTX = 0	Low	UC-1, UC-4, UC-5, UC-6, UC-7

Table B.4.9-2: Transmitting sensitive data in the clear in a single endpoint VPN

Risk factors	Impact	Use cases
UAP = 0 AND (FUN = 2 OR PRI = 2)	High	UC-3
all others	Medium	UC-2
UAP > 0 OR (FUN = 0 AND PRI = 0)	Low	UC-1, UC-4, UC-5, UC-6, UC-7

Mitigations for Likelihood:

- Medium to Low:
 - REQ-AAC-01
 - REQ-AAC-02
 - REQ-AAC-06
 - REQ-CON-01
 - REQ-CON-13
 - REQ-IM-01
- High to Low:
 - REQ-AAC-01
 - REQ-AAC-02
 - REQ-AAC-06
 - REQ-AAC-07
 - REQ-CON-01
 - REQ-CON-02
 - REQ-CON-03
 - REQ-CON-13
 - REQ-IM-01

Mitigations for Impact:

- Medium to Low:
 - REQ-LOG-01 OR REQ-LOG-02
- High to Low:
 - REQ-LOG-01 OR REQ-LOG-02

B.4.10 TH-PLNM: Transmitting sensitive data in the clear in multi-endpoint VPN

Attacker may read sensitive data transmitted without encryption in a VPN which connects multiple endpoints to each other.

Table B.4.10-1: Transmitting sensitive data in the clear in multi-endpoint VPN

Risk factors	Likelihood	Use cases
UAP > 0 AND NET = 2 AND DTX = 2	High	UC-5, UC-6
all others	Medium	UC-4, UC-7
UAP = 0 OR NET = 0 OR DTX = 0	Low	UC-1, UC-2, UC-3

Table B.4.10-2: Transmitting sensitive data in the clear in multi-endpoint VPN

Risk factors	Impact	Use cases
UAP > 0 AND (FUN = 2 OR PRI = 2)	High	UC-5, UC-6
all others	Medium	UC-4, UC-7
UAP = 0 OR (FUN = 0 AND PRI = 0)	Low	UC-1, UC-2, UC-3

Mitigations for Likelihood:

- Medium to Low:
 - REQ-AAC-01
 - REQ-AAC-02
 - REQ-CON-01
 - REQ-CON-13
 - If MSH = 2: REQ-AAC-08
 - If MSH = 2: REQ-CON-04
- High to Low:
 - REQ-AAC-01
 - REQ-AAC-02
 - REQ-AAC-03
 - REQ-AAC-04
 - REQ-AAC-05
 - REQ-AAC-07
 - If MSH = 2: REQ-AAC-08
 - REQ-CON-01
 - REQ-CON-02
 - REQ-CON-03
 - REQ-CON-13

Mitigations for Impact:

- Medium to Low:
 - REQ-LOG-01 OR REQ-LOG-02
- High to Low:
 - REQ-LOG-01 OR REQ-LOG-02
 - REQ-LOG-03

B.4.11 TH-LDEL: Unknown compromise of endpoint

Attacker may compromise endpoint without the user learning of it.

Table B.4.11-1: Unknown compromise of endpoint

Risk factors	Likelihood	Use cases
ADM = 2	High	UC-1, UC-3
all others	Medium	UC-2, UC-4, UC-5, UC-6, UC-7

Table B.4.11-2: Unknown compromise of endpoint

Risk factors	Impact	Use cases
RDP = 2 AND (DTX = 2 OR DST = 2 OR FUN is > 0 OR PRI = 2)	High	UC-3, UC-4, UC-5
all others	Medium	UC-1, UC-2, UC-6, UC-7

Mitigations for Likelihood:

- Medium to Low:
 - REQ-LOG-01 OR REQ-LOG-02
- High to Low:
 - REQ-LOG-01 OR REQ-LOG-02
 - If PRI = 0: REQ-LOG-03

Mitigations for Impact:

- Medium to Low:
 - REQ-CON-14
 - REQ-DM-01
- High to Low:
 - REQ-CON-14
 - REQ-DM-01
 - REQ-DM-02
 - REQ-DM-03

B.4.12 TH-CNFS: Access to assets via configuration errors in single endpoint VPN

Attacker may use configuration errors to get unauthorized access to product assets in a single endpoint VPN.

Table B.4.12-1: Access to assets via configuration errors in single endpoint VPN

Risk factors	Likelihood	Use cases
UAP = 0 AND NET = 2 AND (CFG = 2 OR ADM = 2)	High	UC-1, UC-3
all others	Medium	UC-2
UAP > 0 OR NET = 0 OR CFG = 0 OR ADM = 0	Low	UC-4, UC-5, UC-6, UC-7

Table B.4.12-2: Access to assets via configuration errors in single endpoint VPN

Risk factors	Impact	Use cases
UAP = 0 AND (DTX = 2 OR DST = 2 OR FUN = 2 OR PRI = 2)	High	UC-3
all others	Medium	UC-2
UAP > 0 OR (DTX = 0 AND DST = 0 AND FUN = 0 AND PRI = 0)	Low	UC-1, UC-4, UC-5, UC-6, UC-7

Mitigations for Likelihood:

- Medium to Low:
 - REQ-SBD-01
 - REQ-CON-11
 - REQ-CON-12
 - REQ-EMM-01
 - REQ-EMM-02
 - REQ-EMM-03
- High to Low:
 - REQ-SBD-01
 - REQ-CON-11
 - REQ-CON-12
 - REQ-EMM-01
 - REQ-EMM-02
 - REQ-EMM-03

Mitigations for Impact:

- Medium to Low:
 - REQ-CON-14
 - REQ-LOG-01 OR REQ-LOG-02
- High to Low:
 - REQ-AAC-03
 - REQ-INT-02
 - REQ-CON-14
 - REQ-LOG-01 OR REQ-LOG-02
 - If PRI = 0: REQ-LOG-03

B.4.13 TH-CNFM: Access to assets via configuration errors in a multi-endpoint VPN

Attacker may use configuration errors to get unauthorized access to product assets in a multi-endpoint VPN.

Table B.4.13-1: Access to assets via configuration errors in a multi-endpoint VPN

Risk factors	Likelihood	Use cases
UAP > 0 AND NET = 2 AND (CFG = 2 OR ADM = 2)	High	UC-4, UC-5, UC-7
all others	Medium	UC-6
UAP = 0 OR NET = 0 OR (CFG = 0 AND ADM = 0)	Low	UC-1, UC-2, UC-3,

Table B.4.13-2: Access to assets via configuration errors in a multi-endpoint VPN

Risk factors	Impact	Use cases
UAP > 0 AND DTX = 2 OR DST = 2 OR FUN = 2 OR PRI = 2	High	UC-5, UC-6
all others	Medium	UC-4, UC-7
UAP = 0 OR (DTX = 0 AND DST = 0 AND FUN = 0 AND PRI = 0)	Low	UC-1, UC-2, UC-3

Mitigations for Likelihood:

- Medium to Low:
 - REQ-SBD-01
 - REQ-EMM-01
 - REQ-EMM-02
 - REQ-EMM-03
 - REQ-CON-11
 - REQ-CON-12
- High to Low:
 - REQ-SBD-01
 - REQ-INT-04 OR REQ-INT-05
 - REQ-EMM-01
 - REQ-EMM-02
 - REQ-EMM-03
 - REQ-CON-11
 - REQ-CON-12

Mitigations for Impact:

- Medium to Low:
 - REQ-AAC-03
 - REQ-CON-14
 - REQ-LOG-01 OR REQ-LOG-02
- High to Low:
 - REQ-AAC-03

- REQ-AAC-04
- REQ-AAC-05
- REQ-CON-14
- REQ-LOG-01 OR REQ-LOG-02
- REQ-LOG-03

B.4.14 TH-META: Compromise of privacy due to metadata and traffic analysis

Attacker may use user metadata such as IP addresses and traffic analysis to compromise user privacy.

Table B.4.14-1: Compromise of privacy due to metadata and traffic analysis

Risk factors	Likelihood	Use cases
PRI = 2 AND NET = 2 AND ADM = 2	High	UC-3
all others	Medium	UC-2, UC-7
PRI = 0 OR NET = 0 OR ADM = 0	Low	UC-1, UC-4, UC-5, UC-6

Table B.4.14-2: Compromise of privacy due to metadata and traffic analysis

Risk factors	Impact	Use cases
PRI = 2	High	UC-3
PRI = 1	Medium	UC-2, UC-7
PRI = 0	Low	UC-4, UC-5, UC-6

Requirements that mitigate this threat:

Mitigations for Likelihood:

- Medium to Low:
 - REQ-CON-15
- High to Low:
 - REQ-CON-15

Mitigations for Impact:

- Medium to Low:
 - REQ-CON-14
- High to Low:
 - REQ-CON-14

B.4.15 TH-RCOM: Compromise of privacy via RDPS

Attacker may compromise privacy of user via the product's remote data processing systems.

Table B.4.15-1: Compromise of privacy via RDPS

Risk factors	Likelihood	Use cases
RDP = 2 AND UAP = 0 AND PRI > 0	High	UC-3
all others	Medium	UC-1, UC-2, UC-4, UC-5, UC-7
RDP = 0 AND UAP = 2	Low	UC-6

Table B.4.15-2: Compromise of privacy via RDPS

Risk factors	Impact	Use cases
RDP > 0 AND PRI > 0	High	UC-2, UC-3, UC-7
all others	Medium	UC-1, UC-4, UC-5, UC-6

Mitigations for Likelihood:

- Medium to Low:
 - REQ-DM-05
 - REQ-SSD-03
- High to Low:
 - REQ-DM-05
 - REQ-SSD-03

Mitigations for Impact:

- Medium to Low:
 - REQ-DM-01
- High to Low:
 - REQ-DM-01
 - REQ-DM-02
 - REQ-DM-03
 - REQ-DM-04
 - REQ-LOG-04

B.4.16 TH-DSTR: Unauthorized access to data stored on product

Attacker may get unauthorized access to confidential data stored on the product.

Table B.4.16-1: Unauthorized access to data stored on product

Risk factors	Likelihood	Use cases
ADM = 2	High	UC-1, UC-3
all others	Medium	UC-2, UC-4, UC-5, UC-6, UC-7

Table B.4.16-2: Unauthorized access to data stored on product

Risk factors	Impact	Use cases
DST = 2	High	UC-3
DST = 1	Medium	UC-2, UC-4, UC-5, UC-6, UC-7
DST = 0	Low	UC-1

Mitigations for Likelihood:

- Medium to Low:
 - REQ-DRT-01
 - REQ-DRT-03

- REQ-DRT-04
- High to Low:
 - REQ-DRT-01
 - REQ-DRT-02
 - REQ-DRT-03
 - REQ-DRT-04

Mitigations for Impact:

- Medium to Low:
 - REQ-CON-14
- High to Low:
 - REQ-CON-14

B.4.17 TH-HINT: Interference with host

Product may unintentionally damage security of host.

Table B.4.17-1: Interference with host

Risk factors	Likelihood	Use cases
DNC = 2	High	UC-1, UC-2, UC-3, UC-4, UC-5, UC-7
all others	Medium	UC-6

Table B.4.17-2: Interference with host

Risk factors	Impact	Use cases
FUN = 2	High	UC-3, UC-5, UC-6
FUN = 1	Medium	UC-2, UC-4, UC-7
FUN = 0	Low	UC-1

Mitigations for Likelihood:

- Medium to Low:
 - REQ-INT-01
 - REQ-INT-02
 - REQ-INT-03
 - REQ-IM-02
- High to Low:
 - REQ-INT-01
 - REQ-INT-02
 - REQ-INT-03
 - REQ-IM-02

Mitigations for Impact:

- Medium to Low:
 - REQ-LOG-01 OR REQ-LOG-02
- High to Low:
 - REQ-LOG-01 OR REQ-LOG-02

B.5 Mapping of use cases to risk factors

Table B.5-1: Mapping of use cases to risk factors

Use case	Description	CF G	DT X	DS T	FU N	PRI	UA P	AD M	RD P	DN C	CO M	MS H	NU M	NE T
UC-1	Individual consumer	0	0	0	0	0	0	2	2	2	0	0	0	2
UC-2	Privacy conscious household	1	1	1	1	1	0	1	1	2	1	0	0	2
UC-3	Journalist or activist	1	2	2	2	2	0	2	2	2	1	0	0	2
UC-4	Small organization	2	1	1	1	0	1	1	2	2	2	1	1	2
UC-5	Large enterprise	2	2	1	2	0	2	0	2	2	2	1	2	2
UC-6	Enterprise-owned VPN infra	1	2	1	2	0	2	1	0	0	2	1	2	2
UC-7	Mesh network	2	1	1	1	1	1	1	1	2	2	2	1	2

B.6 Risks not treated by the requirements

For each risk untreated by the product itself in any applicable use case, a corresponding mitigation has been created to explicitly permit the risk to be transferred to the user or operational environment. These are:

- REQ-SU-02
- REQ-SU-05
- REQ-SU-06
- REQ-AAC-06
- REQ-CON-05
- REQ-CON-15
- REQ-AP-03

B.7 Mapping of risks to requirements

Table B.7-1: Mapping of risks to requirements

Threat	Requirements
TH-UEVU	REQ-SSD-01, REQ-SSD-02, REQ-MAS-01, REQ-LOG-01, REQ-LOG-02, REQ-CON-14
TH-KEVU	REQ-KEV-01, REQ-SU-01, REQ-SU-02, REQ-SU-03, REQ-SU-04, REQ-SU-05, REQ-SU-06, REQ-SU-07, REQ-SU-08, REQ-SU-09, REQ-SU-10, REQ-SU-11, REQ-SU-12, REQ-SU-13, REQ-SU-14, REQ-LOG-01, REQ-LOG-02, REQ-CON-14
TH-UEAC	REQ-AAC-01, REQ-AAC-02, REQ-AAC-03, REQ-AAC-04, REQ-AAC-05, REQ-AAC-06, REQ-AAC-07, REQ-AAC-08, REQ-CON-14
TH-DOSA	REQ-AP-01, REQ-AP-02, REQ-AP-03, REQ-AP-04, REQ-LOG-01, REQ-LOG-02, REQ-INT-04, REQ-INT-05
TH-MITM	REQ-AAC-01, REQ-AAC-02, REQ-AAC-03, REQ-AAC-04, REQ-AAC-05, REQ-AAC-07, REQ-CON-13, REQ-DM-01
TH-DLEK	REQ-CON-01, REQ-CON-02, REQ-CON-03, REQ-CON-04, REQ-CON-05, REQ-CON-06, REQ-CON-07, REQ-CON-08, REQ-CON-09, REQ-CON-10, REQ-CON-11, REQ-CON-12, REQ-LOG-01
TH-PLNS	REQ-AAC-01, REQ-AAC-02, REQ-AAC-06, REQ-AAC-07, REQ-CON-01, REQ-CON-02, REQ-CON-03, REQ-CON-13, REQ-IM-01, REQ-LOG-01, REQ-LOG-02
TH-PLNM	REQ-AAC-01, REQ-AAC-02, REQ-AAC-03, REQ-AAC-04, REQ-AAC-05, REQ-AAC-07, REQ-AAC-08, REQ-CON-01, REQ-CON-02, REQ-CON-03, REQ-CON-04, REQ-CON-13, REQ-LOG-01, REQ-LOG-02, REQ-LOG-03
TH-LDEL	REQ-LOG-01, REQ-LOG-02, REQ-LOG-03, REQ-CON-14, REQ-DM-01, REQ-DM-02, REQ-DM-03
TH-CNFS	REQ-SBD-01, REQ-CON-11, REQ-CON-12, REQ-CON-14, REQ-EMM-01, REQ-EMM-02, REQ-EMM-03, REQ-AAC-03, REQ-LOG-01, REQ-LOG-02, REQ-LOG-03, REQ-INT-02, REQ-CON-14
TH-CNFM	REQ-SBD-01, REQ-EMM-01, REQ-EMM-02, REQ-EMM-03, REQ-CON-11, REQ-CON-12, REQ-CON-14, REQ-INT-04, REQ-INT-05, REQ-LOG-01, REQ-LOG-02, REQ-LOG-03, REQ-AAC-03, REQ-AAC-04, REQ-AAC-05
TH-META	REQ-CON-14, REQ-CON-15
TH-RCOM	REQ-DM-01, REQ-DM-02, REQ-DM-03, REQ-DM-04, REQ-DM-05, REQ-SSD-03, REQ-LOG-04
TH-DSTR	REQ-DRT-01, REQ-DRT-02, REQ-DRT-03, REQ-DRT-04, REQ-CON-14
TH-HINT	REQ-INT-01, REQ-INT-02, REQ-INT-03, REQ-IM-02, REQ-LOG-01, REQ-LOG-02

B.8 Accounting of requirements for each use case

B.8.0 Introduction

The applicability of requirements for each use case is defined in Table 5.1.

The following clauses B.8.1 to B.8.7 provide a list of the applicable requirements for each use case, for the reader's convenience.

NOTE: The present annex is informative. In case of inconsistency, Table 5.1 governs.

B.8.1 UC-1 Individual consumer

- REQ-SSD-01
- REQ-SSD-02
- REQ-SSD-03

- REQ-KEV-01
- REQ-SBD-01
- REQ-SU-01
- REQ-SU-02
- REQ-SU-04
- REQ-SU-06
- REQ-SU-07
- REQ-SU-08
- REQ-SU-09
- REQ-SU-10
- REQ-SU-11
- REQ-SU-12
- REQ-SU-13
- REQ-SU-14
- REQ-AAC-01
- REQ-AAC-02
- REQ-AAC-06
- REQ-AAC-07
- REQ-CON-11
- REQ-CON-12
- REQ-CON-13
- REQ-CON-14
- REQ-INT-01
- REQ-INT-02
- REQ-INT-03
- REQ-DM-01
- REQ-DM-05
- REQ-AP-01
- REQ-AP-02
- REQ-AP-03
- REQ-IM-02
- REQ-EMM-01
- REQ-EMM-02
- REQ-EMM-03

- REQ-LOG-01
- REQ-LOG-02
- REQ-LOG-03
- REQ-DRT-01
- REQ-DRT-02
- REQ-DRT-03
- REQ-DRT-04

B.8.2 *UC-2* Privacy conscious household

- REQ-SSD-01
- REQ-SSD-02
- REQ-SSD-03
- REQ-KEV-01
- REQ-SBD-01
- REQ-SU-01
- REQ-SU-02
- REQ-SU-04
- REQ-SU-06
- REQ-SU-07
- REQ-SU-08
- REQ-SU-09
- REQ-SU-10
- REQ-SU-11
- REQ-SU-12
- REQ-SU-13
- REQ-SU-14
- REQ-AAC-01
- REQ-AAC-02
- REQ-AAC-03
- REQ-AAC-04
- REQ-AAC-06
- REQ-AAC-07
- REQ-CON-01
- REQ-CON-02

- REQ-CON-05
- REQ-CON-06
- REQ-CON-11
- REQ-CON-12
- REQ-CON-13
- REQ-CON-14
- REQ-CON-15
- REQ-INT-01
- REQ-INT-02
- REQ-INT-03
- REQ-INT-04
- REQ-INT-05
- REQ-DM-01
- REQ-DM-02
- REQ-DM-03
- REQ-DM-04
- REQ-DM-05
- REQ-AP-01
- REQ-AP-02
- REQ-AP-03
- REQ-IM-01
- REQ-IM-02
- REQ-MAS-01
- REQ-EMM-01
- REQ-EMM-02
- REQ-EMM-03
- REQ-LOG-01
- REQ-LOG-02
- REQ-LOG-04
- REQ-DRT-01
- REQ-DRT-03
- REQ-DRT-04

B.8.3 *UC-3* Journalist, activist, legal professionals

- REQ-SSD-01
- REQ-SSD-02
- REQ-SSD-03
- REQ-KEV-01
- REQ-SBD-01
- REQ-SU-01
- REQ-SU-02
- REQ-SU-04
- REQ-SU-06
- REQ-SU-07
- REQ-SU-08
- REQ-SU-09
- REQ-SU-10
- REQ-SU-11
- REQ-SU-12
- REQ-SU-13
- REQ-SU-14
- REQ-AAC-01
- REQ-AAC-02
- REQ-AAC-03
- REQ-AAC-04
- REQ-AAC-06
- REQ-AAC-07
- REQ-AAC-08
- REQ-CON-01
- REQ-CON-02
- REQ-CON-03
- REQ-CON-05
- REQ-CON-06
- REQ-CON-07
- REQ-CON-08
- REQ-CON-09

- REQ-CON-10
- REQ-CON-11
- REQ-CON-12
- REQ-CON-13
- REQ-CON-14
- REQ-CON-15
- REQ-INT-01
- REQ-INT-02
- REQ-INT-03
- REQ-INT-04
- REQ-INT-05
- REQ-DM-01
- REQ-DM-02
- REQ-DM-03
- REQ-DM-04
- REQ-DM-05
- REQ-AP-01
- REQ-AP-02
- REQ-AP-03
- REQ-AP-04
- REQ-IM-01
- REQ-IM-02
- REQ-MAS-01
- REQ-EMM-01
- REQ-EMM-02
- REQ-EMM-03
- REQ-LOG-01
- REQ-LOG-02
- REQ-LOG-04
- REQ-DRT-01
- REQ-DRT-02
- REQ-DRT-03
- REQ-DRT-04

B.8.4 *UC-4* Small enterprise, small not-for-profit organization

- REQ-SSD-01
- REQ-SSD-02
- REQ-SSD-03
- REQ-KEV-01
- REQ-SU-01
- REQ-SU-02
- REQ-SU-04
- REQ-SU-06
- REQ-SU-07
- REQ-SU-08
- REQ-SU-09
- REQ-SU-10
- REQ-SU-11
- REQ-SU-12
- REQ-SU-13
- REQ-SU-14
- REQ-AAC-01
- REQ-AAC-02
- REQ-AAC-03
- REQ-AAC-04
- REQ-AAC-05
- REQ-AAC-06
- REQ-AAC-07
- REQ-AAC-08
- REQ-CON-01
- REQ-CON-11
- REQ-CON-12
- REQ-CON-13
- REQ-CON-14
- REQ-INT-01
- REQ-INT-02
- REQ-INT-03

- REQ-INT-04
- REQ-INT-05
- REQ-DM-01
- REQ-DM-02
- REQ-DM-03
- REQ-DM-05
- REQ-AP-01
- REQ-AP-02
- REQ-AP-03
- REQ-IM-02
- REQ-MAS-01
- REQ-EMM-01
- REQ-EMM-02
- REQ-EMM-03
- REQ-LOG-01
- REQ-LOG-02
- REQ-DRT-01
- REQ-DRT-03
- REQ-DRT-04

B.8.5 *UC-5* Large enterprise

- REQ-SSD-01
- REQ-SSD-02
- REQ-SSD-03
- REQ-KEV-01
- REQ-SBD-01
- REQ-SU-01
- REQ-SU-02
- REQ-SU-03
- REQ-SU-04
- REQ-SU-05
- REQ-SU-06
- REQ-AAC-01
- REQ-AAC-02

- REQ-AAC-03
- REQ-AAC-04
- REQ-AAC-05
- REQ-AAC-06
- REQ-AAC-07
- REQ-AAC-08
- REQ-CON-01
- REQ-CON-02
- REQ-CON-03
- REQ-CON-11
- REQ-CON-12
- REQ-CON-13
- REQ-CON-14
- REQ-INT-01
- REQ-INT-02
- REQ-INT-03
- REQ-INT-04
- REQ-INT-05
- REQ-DM-01
- REQ-DM-02
- REQ-DM-03
- REQ-AP-01
- REQ-AP-02
- REQ-AP-03
- REQ-AP-04
- REQ-IM-02
- REQ-MAS-01
- REQ-EMM-01
- REQ-EMM-02
- REQ-EMM-03
- REQ-LOG-01
- REQ-LOG-02
- REQ-LOG-03
- REQ-DRT-01

- REQ-DRT-03
- REQ-DRT-04

B.8.6 *UC-6* Enterprise with independent VPN infrastructure

- REQ-SSD-01
- REQ-SSD-02
- REQ-KEV-01
- REQ-SBD-01
- REQ-SU-01
- REQ-SU-02
- REQ-SU-04
- REQ-SU-06
- REQ-SU-07
- REQ-SU-08
- REQ-SU-09
- REQ-SU-10
- REQ-SU-11
- REQ-SU-12
- REQ-SU-13
- REQ-SU-14
- REQ-AAC-01
- REQ-AAC-02
- REQ-AAC-03
- REQ-AAC-04
- REQ-AAC-05
- REQ-AAC-06
- REQ-AAC-07
- REQ-AAC-08
- REQ-CON-01
- REQ-CON-02
- REQ-CON-03
- REQ-CON-11
- REQ-CON-12
- REQ-CON-13

- REQ-CON-14
- REQ-INT-01
- REQ-INT-02
- REQ-INT-03
- REQ-INT-04
- REQ-INT-05
- REQ-DM-01
- REQ-AP-01
- REQ-AP-02
- REQ-AP-03
- REQ-AP-04
- REQ-IM-02
- REQ-MAS-01
- REQ-EMM-01
- REQ-EMM-02
- REQ-EMM-03
- REQ-LOG-01
- REQ-LOG-02
- REQ-LOG-03
- REQ-DRT-01
- REQ-DRT-03
- REQ-DRT-04

B.8.7 UC-7 Mesh Network

- REQ-SSD-01
- REQ-SSD-02
- REQ-SSD-03
- REQ-KEV-01
- REQ-SU-01
- REQ-SU-02
- REQ-SU-04
- REQ-SU-06
- REQ-SU-07
- REQ-SU-08

- REQ-SU-09
- REQ-SU-10
- REQ-SU-11
- REQ-SU-12
- REQ-SU-13
- REQ-SU-14
- REQ-AAC-01
- REQ-AAC-02
- REQ-AAC-03
- REQ-AAC-04
- REQ-AAC-05
- REQ-AAC-06
- REQ-AAC-07
- REQ-AAC-08
- REQ-CON-01
- REQ-CON-02
- REQ-CON-04
- REQ-CON-05
- REQ-CON-06
- REQ-CON-11
- REQ-CON-12
- REQ-CON-13
- REQ-CON-14
- REQ-CON-15
- REQ-INT-01
- REQ-INT-02
- REQ-INT-03
- REQ-INT-04
- REQ-INT-05
- REQ-DM-01
- REQ-DM-02
- REQ-DM-03
- REQ-DM-04
- REQ-DM-05

- REQ-AP-01
- REQ-AP-02
- REQ-AP-03
- REQ-IM-02
- REQ-MAS-01
- REQ-EMM-01
- REQ-EMM-02
- REQ-EMM-03
- REQ-LOG-01
- REQ-LOG-02
- REQ-LOG-04
- REQ-DRT-01
- REQ-DRT-03
- REQ-DRT-04

Annexes C to J:
Void

Annex K (normative):

Generic requirements and assessment criteria for the use of state of the art cryptography

K.1 Cryptography

K.1.1 Requirement

The product's default configuration shall only use cryptographic mechanisms that meet at least one of the following criteria:

- 1) ACM-listed: the cryptographic mechanism is listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1];
- 2) ACM-extended: the cryptographic mechanism is not listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1] and meets at least one of the following conditions:
 - a) the cryptographic mechanism is listed in [clause K.3.2](#) as an ACM-extended cryptographic mechanism for the specific product function(s), following consideration of the criteria specified in item 2)b);
 - b) where the cryptographic mechanism is not listed in [clause K.3.2](#), the cryptographic mechanism meets all the following criteria:
 - i) the cryptographic mechanism, or where applicable the ACM-listed cryptographic mechanism on which it is based, is not deprecated per the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1];
 - ii) the cryptographic mechanism has been specified, developed or maintained through a transparent process by a recognized European, international or sector-specific standards development organization, or by an industry specification organization accountable for the relevant specification, including CEN, CENELEC, ETSI, ISO, IEC, ISO/IEC JTC 1, IETF, IEEE, ITU-T, NIST, 3GPP, O-RAN Alliance, BSI, ACN, [C2SP](#); or the cryptographic mechanism is listed as suitable in a publicly available cryptographic catalogue maintained by a recognized national or governmental cybersecurity authority, where the catalogue is maintained under a documented revision and retirement process, including BSI TR-02102-1, BSI TR-02102-2, BSI TR-02102-3 and BSI TR-02102-4;
 - iii) the cryptographic mechanism is described in a valid, publicly available and uniquely referenceable specification;
 - iv) the cryptographic properties of the cryptographic mechanism are known;
 - v) no known weakness affects the cryptographic mechanism in a way that affects its cryptographic properties;
 - vi) the cryptographic mechanism is required for a specific set of product functions.

NOTE 1: The reference to the product's default configuration is intended to define a clear and assessable baseline, corresponding to the configuration in which the product is placed on the market. The product can provide several configurations that fulfil the requirement.

NOTE 2: For products supplied as hardware platforms or components to be configured by an integrator, references in this annex to the product's default configuration refer to the configuration specified for the intended operational use of the product after integration, including the relevant integration assumptions and configuration constraints.

NOTE 3: The applicable ACM catalogue version is identified in the normative references of the present document. The lifecycle treatment of mechanisms affected by ACM deprecation dates, expiry dates, migration conditions or usage limitations is addressed in [clause K.2](#).

NOTE 4: In this clause, an external specification or external requirement means a specification or requirement that is imposed on the product, and which requires the use of a specific cryptographic mechanism for the product to interoperate with an identified system, platform or operational context. An external requirement can be a regulatory requirement, operational constraint, technical interoperability constraint, or platform compatibility requirement.

EXAMPLE: Examples of product functions include secure communication based on TLS 1.3; authenticated encryption of communicated data based on AES-GCM; storage confidentiality based on AES-XTS; firmware signature verification based on Ed25519; and key derivation based on HKDF.

K.1.2 Assessment of product cryptographic configuration

K.1.2.1 General

The assessment in [clause K.1.2](#) verifies the cryptographic mechanisms used in the product's default configuration against [clause K.1.1](#).

For ACM-extended cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is either listed in [clause K.3.2](#) or fulfils the criteria specified in [clause K.1.1](#) item 2)b. The assessment also verifies that the product uses the cryptographic mechanism in accordance with the relevant characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in the present document.

K.1.2.2 Assessment of ACM-listed cryptographic mechanisms

K.1.2.2.1 Objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with [clause K.1.1](#) item 1) and used in the product's default configuration are listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1].

K.1.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under [clause K.1.1](#) item 1), including the related product function, relevant parameters where applicable, and the relevant ACM entry.

K.1.2.2.3 Assessment activities

The assessment shall include verification that:

- a) each cryptographic mechanism claimed under [clause K.1.1](#) item 1) is identified by reference to a relevant ACM entry;
- b) the ACM entry corresponds to the cryptographic mechanism used in the product's default configuration, including relevant parameters where applicable;
- c) where the ACM entry includes lifecycle information, such as expiry date, deprecation date, migration condition or usage limitation, this information is reflected in the documentation.

K.1.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) description of the product's default configuration;
- b) list of cryptographic mechanisms claimed under [clause K.1.1](#) item 1);
- c) references to the relevant ACM entries;

- d) relevant parameters, profiles, cipher suites or configuration constraints, where applicable;
- e) relevant lifecycle information from the ACM catalogue, where applicable.

K.1.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with [clause K.1.1](#) item 1).
- The verdict FAIL shall be assigned otherwise.

K.1.2.3 Assessment of ACM-extended cryptographic mechanisms

K.1.2.3.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with [clause K.1.1](#) item 2) and used in the product's default configuration are either listed as ACM-extended cryptographic mechanisms in [clause K.3.2](#) or fulfil the criteria specified in [clause K.1.1](#) item 2)b), and are used for the claimed product function(s).

K.1.2.3.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under [clause K.1.1](#) item 2), including the related product function, use case where applicable, relevant parameters where applicable, and at least one of the following:
 - a) the relevant entry in [clause K.3.2](#); or
 - b) evidence that the cryptographic mechanism fulfils all applicable criteria in [clause K.1.1](#) item 2)b).

K.1.2.3.3 Assessment activities

The assessment shall include verification that:

- a) each cryptographic mechanism claimed under [clause K.1.1](#) item 2) is either listed in [clause K.3.2](#) as an ACM-extended cryptographic mechanism or supported by evidence demonstrating fulfilment of the applicable criteria in [clause K.1.1](#) item 2)b);
- b) the cryptographic mechanism used by the product corresponds to the mechanism listed in [clause K.3.2](#) or described in the evidence provided under [clause K.1.1](#) item 2)b);
- c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in [clause K.3.2](#) or justified under [clause K.1.1](#) item 2)b);
- d) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in [clause K.3.2](#) or justified under [clause K.1.1](#) item 2)b), where applicable;
- e) where [clause K.3.2](#) or the justification under [clause K.1.1](#) item 2)b) defines conditions or limitations for the use of the cryptographic mechanism, these conditions or limitations are reflected in the product's default configuration;
- f) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.3.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) description of the product's default configuration;

- b) list of cryptographic mechanisms claimed under [clause K.1.1](#) item 2);
- c) reference to the relevant entry in [clause K.3.2](#), where the mechanism is listed in [clause K.3.2](#);
- d) evidence that the cryptographic mechanism fulfils the criteria in [clause K.1.1](#) item 2)b), where compliance with [clause K.1.1](#) item 2) is claimed on the basis of those criteria;
- e) identification of the related product function using the cryptographic mechanism and the use case where applicable;
- f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;
- g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in [clause K.3.2](#) or in the justification under [clause K.1.1](#) item 2)b), where applicable.

K.1.2.3.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with [clause K.1.1](#) item 2).
- The verdict FAIL shall be assigned otherwise.

K.2 Crypto agility

K.2.1 Requirement

Where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue, or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product shall provide means for addressing the affected cryptographic mechanism by one or more of the following:

- a) updating the cryptographic mechanism;
- b) using another cryptographic mechanism that complies with [clause K.1.1](#) and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation;
- c) disabling the use of the affected cryptographic mechanism; or
- d) limiting the use of the affected product functions accordingly.

EXAMPLE: Where a security mechanism uses a hybrid cryptographic construction, for example a hybrid key-encapsulation mechanism combining a classical and a post-quantum primitive, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridization can be used as part of a planned migration strategy where permitted by the ACM catalogue or by the present document. However, hybridization does not, by itself, extend the recommended usage lifetime of a constituent primitive that has been deprecated.

NOTE 1: Where a hybrid cryptographic construction includes multiple cryptographic primitives, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridization is not assumed to mitigate the deprecation of a constituent primitive unless the ACM catalogue or the present document classifies the hybrid construction as suitable for the corresponding product function.

NOTE 2: Crypto agility supports maintaining appropriate cryptographic protection within the intended lifetime of the product, in addition to the capability of updating cryptographic mechanisms on the product in accordance with secure update and secure communication mechanisms.

NOTE 3: Deprecation information from sources other than the ACM catalogue or the present document can be considered as input to vulnerability management or security risk assessment but does not by itself trigger the requirement in [clause K.2.1](#).

NOTE 4: Where the product provides cryptographic capabilities for use by other products, components or layers, the mechanism required by [clause K.2.1](#) can consist of update, configuration, disabling, deprecation or limitation capabilities usable by the integrating product, system operator or user, where applicable.

NOTE 5: The applicability condition of this requirement can express exceptions based on product characteristics, e.g. cryptographic implementation based on immutable hardware co-processor(s) or hardware-based root of trust, or long-lived silicon used in a long-lived non-updatable environment.

K.2.2 Assessment of crypto-agility

K.2.2.1 Assessment objective

The purpose of this assessment case is to verify whether, where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue, or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product provides means to address the affected cryptographic mechanism in accordance with [clause K.2.1](#).

K.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall identify:
 - a) the intended lifetime of the product;
 - b) the cryptographic mechanisms used in the product's default configuration;
 - c) the related product function(s) for each cryptographic mechanism;
 - d) the lifecycle information applicable to each cryptographic mechanism, where specified by the ACM catalogue or the present document, including any deprecation date, expiry date, migration condition or usage limitation.

K.2.2.3 Assessment activities

The assessment shall include verification that:

- a) for each cryptographic mechanism used in the product's default configuration, the lifecycle information specified by the ACM catalogue or the present document has been identified, where such information is specified;
- b) where the ACM catalogue or the present document specifies a deprecation date, expiry date, migration condition or usage limitation for a cryptographic mechanism, this information is reflected in the documentation;
- c) where a deprecation date, expiry date, migration condition or usage limitation falls within the intended lifetime of the product, the product provides an applicable mechanism for updating the cryptographic mechanism, using another cryptographic mechanism that complies with [clause K.1.1](#) and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation, disabling the use of the affected cryptographic mechanism, or limiting the use of the affected product functions accordingly;
- d) where another cryptographic mechanism is used, that cryptographic mechanism complies with [clause K.1.1](#) and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation.

K.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) documentation of the intended lifetime of the product;
- b) list of cryptographic mechanisms used in the product's default configuration;

- c) identification of the related product function(s) for each cryptographic mechanism;
- d) references to the ACM catalogue entry or to the provision of the present document used to determine lifecycle information, where applicable;
- e) identification of any deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product;
- f) description of the means provided by the product, such as update of the cryptographic mechanism, use of another cryptographic mechanism that complies with [clause K.1.1](#) and is not subject to the relevant lifecycle constraint, disabling the use of the affected cryptographic mechanism, or limitation of the use of the affected product functions.

K.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with [clause K.2.1](#).
- The verdict FAIL shall be assigned otherwise.

K.3 ACM-extended cryptographic mechanisms

K.3.1 Requirement

Where the product's default configuration uses ACM-extended cryptographic mechanisms, these mechanisms shall comply with the ACM-extended criterion in [clause K.1.1](#) item 2).

K.3.2 List of ACM-extended cryptographic mechanisms

Table K.3.2 lists the ACM-extended cryptographic mechanisms specified by the present document.

Table K.3.2: ACM-extended cryptographic mechanisms

ACM-extended cryptographic mechanism	Type of cryptographic mechanism	Characteristics / parameters	Related product function(s) / use case(s), where applicable	Cryptographic properties	Specification / reference	Conditions or limitations, where applicable
Curve25519	Primitive	-	-	Confidentiality, Authentication, Key Establishment	IRTF RFC 7748 [i.11]	
X25519	Primitive	256 bit	TLS, IPC, VPN protocols, key agreement	Key establishment	IRTF RFC 7748 [i.11]	
Ed25519	Primitive	256 bit	Package Signature, TLS, IPC, VPN protocols, data signature	Authentication	IRTF RFC 8032 [i.12], NIST FIPS 186-5 [i.13]	
Curve448	Primitive	-	-	Confidentiality, Authentication, Key Establishment	IRTF RFC 7748 [i.11]	

ACM-extended cryptographic mechanism	Type of cryptographic mechanism	Characteristics / parameters	Related product function(s) / use case(s), where applicable	Cryptographic properties	Specification / reference	Conditions or limitations, where applicable
X448	Primitive	448 bit	TLS, IPC, VPN protocols	Key establishment	IRTF RFC 7748 [i.11]	
Ed448	Primitive	456 bit	Package Signature, TLS, IPC, VPN protocols	Authentication	IRTF RFC 8032 [i.12], NIST FIPS 186-5 [i.13]	
Argon2id	Algorithm	Refer to 4. Parameter Choice in IRTF RFC 9106 [i.14]. Minimum allowed configuration for password hashing is argon2id with iteration=2, parallization=1 and memory=19MiB, salt=128bit, digest=128bit as ACN's guidance.	Password-based hashing, Key derivation	Cryptographic hashing, Integrity, Authentication	IRTF RFC 9106 [i.14], BSI TR-02102-1 [i.15], ACN	
scrypt	Algorithm	Refer to 2. scrypt Parameters in IETF RFC 7914 [i.16] and the ACN's guidance.	Password-based hashing, Key derivation	Cryptographic hashing, Integrity, Authentication	IETF RFC 7914 [i.16], ACN	
ChaCha20	Algorithm	Key: 256 bit Nonce: 96bit or 192 bit (XChaCha),	TLS, data encryption, VPN protocols	confidentiality	IRTF RFC 8439 [i.17]	
Salsa20	Algorithm	Key: 256 bit Nonce: 64 bit, 192 bit (XSalsa20)	data encryption, VPN protocols	confidentiality	IRTF RFC 8439 [i.17]	20 rounds
Poly1305	Algorithm	256 bit	MAC, VPN protocols	Authentication, Integrity	IRTF RFC 8439 [i.17]	
AEGIS	Algorithm	256 bit, 128 bit AEGIS-128, AEGIS-128L, AEGIS-256, AEGIS-256X	Authenticated data encryption, VPN protocols	Authentication, confidentiality, integrity	RFC-AEGIS [i.20]	
Blake2	Algorithm	Blake2s, Blake2b	Key derivation, Generic hashing, MAC	Authentication, integrity	IETF RFC 7693 [i.18] NIST IR 7896	
Blake3	Algorithm		Key derivation, Generic hashing, MAC	Authentication, integrity	BLAKE3 [i.23], C2SP	
UMAC	Algorithm	128 bit	MAC	Authentication, Integrity	IETF RFC 4418 [i.19]	

NOTE 1: The combination of the mechanism mentioned in Table K.3.2: ACM-extended cryptographic mechanisms together with the mechanisms in ACM that is appropriate for the cryptographic use-case to form a cryptographic protocol are allowed. For example ChaCha20-Poly1305, HMAC-blake2s or X25519ML-KEM768.

NOTE 2: The use-case defined in Table K.3.2 marked in "Related product function(s) / use case(s), where applicable" is a non-exhaustive list and listed algorithm can be used for other appropriate use-cases as well.

K.3.3 Assessment

Compliance with the ACM-extended criterion in [clause K.1.1](#) item 2 is assessed in [clause K.1.2.2](#).

K.4 Interoperability-based cryptographic mechanisms

There are no interoperability-based cryptographic mechanisms specified as permissible for use as a default setting in VPNs.

Annexes L to Q:
Void

Annex R (normative): Remote Data Processing Solutions

R.1 Scope & Applicability

This annex specifies additional technical requirements and assessment provisions for products with digital elements that rely on Remote Data Processing Solutions ("RDPS") for the provision or support of one or more product functions.

The requirements applicable to the product functions remain specified in the core part of the concerned standard and continue to apply to the product as a whole, including where a product function is performed locally, supported by an RDPS, or performed in part through an RDPS.

This annex specifies supplementary requirements and assessment provisions for the product-facing RDPS boundary, i.e. for the additional attack surface, interactions, and dependency conditions introduced where a product function is performed or supported across the local product side and the RDPS side.

Where the product does not rely on remote data processing solutions for the provision or support of any product function, this annex is not applicable.

This annex does not extend to the full remote service environment or underlying third-party infrastructure, except to the extent necessary to define assumptions, dependencies, and assessment conditions relevant to the product-facing RDPS boundary and the secure operation of the RDPS-dependent product function.

R.2 RDPS as a product-boundary extension

When a product relies on RDPS for the provision or support of one or more product functions, the use of RDPS is considered, for the purposes of the present annex, to introduce an additional product-facing boundary and interface between the local product side and the RDPS side.

The present annex does not restate or replace the requirements applicable to the product function as such. It specifies only the supplementary requirements needed to address the increased attack surface introduced by the RDPS boundary.

The present annex therefore addresses the security implications introduced by that additional boundary and interface, including:

- a) the exchanged interactions across the RDPS boundary;
- b) the relevant product-side and RDPS-side endpoints; and
- c) the dependency conditions arising where the secure operation of the product function relies on interactions across that boundary.

The scope of the present annex is limited to the RDPS interface between the local product side and the RDPS side.

For the purposes of the present annex:

- local product side means the product elements within the product boundary that participate in the interaction with the RDPS;
- RDPS means the remote data processing solution performing or supporting operations relevant to the RDPS-dependent product function;
- RDPS interface means the communication boundary between the product-side endpoint and the RDPS-side endpoint.

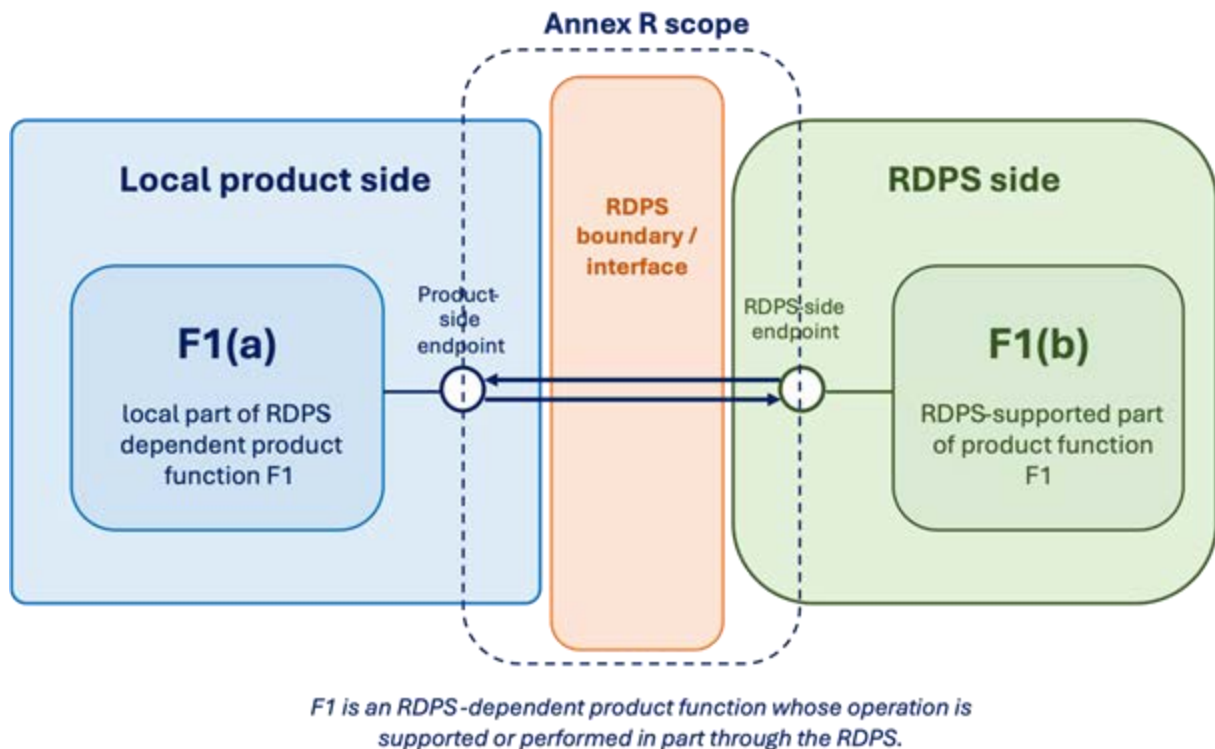


Figure R.2: RDPS model for Annex R - scope focused on the product ↔ RDPS boundary

R.3 Threat Model

R.3.1 Introduction

This clause does not restate or replace threats for local product components that are already defined in the main clauses of the standard. Instead, it focuses on:

- threats introduced by the local product ↔ RDPS interface, and
- threats introduced by the RDPS as a remote service capability.

The threat model:

- identifies RDPS assets; and
- defines a set of threats applicable to RDPS.

R.3.2 Assets

The threat model considers the following assets:

DA-RDPS-001 - RDPS interaction content: The information exchanged across the RDPS boundary, including, as applicable, requests, commands, responses, decisions, configuration data, secrets, update-related data, and Personal Data where such data is exchanged.

For the purposes of DA-RDPS-001, Table R.3.2-1 identifies potential categories of RDPS interaction content and indicates the security properties to be considered for each category when determining the applicable Annex R requirement families.

Table R.3.2-1: Security properties for DA-RDPS-001

Content type	Data authenticity	Integrity	Confidentiality
Commands / requests & Responses / decisions	X	X	
Configuration data	X	X	
Secrets (e.g. keys)	X	X	X
Code or update data	X	X	
Confidential code or update data	X	X	X
Personal data		X	X

NOTE: In Table R.3.2-1, "data authenticity" refers to the authenticity or trusted origin of the exchanged interaction content. It does not refer to authentication of the RDPS boundary endpoint.

DA-RDPS-002 – RDPS-dependent product function: product function for which one or more operations depend on an RDPS, including the associated security-relevant state, decisions, outputs, or configuration.

For the purposes of DA-RDPS-002, Table R.3.2-2 identifies the security property relevant to the RDPS-dependent product function.

Table R.3.2-2: Security property for DA-RDPS-002

Content type	Availability
RDPS-dependent product function	X

R.3.3 Threat catalogue

R.3.3.1 Overview

The following threats constitute the baseline threat set considered for the RDPS boundary within the scope of Annex R, covering the RDPS interaction content exchanged across the boundary and the availability of the RDPS-dependent product function.

R.3.3.2 T-RDPS-01 Loss of data authenticity of interactions across the RDPS boundary

An attacker causes an endpoint to accept interaction content across the RDPS boundary whose claimed source or origin is not genuine.

Threat type

Spoofing / impersonation

Security impact

The receiving endpoint may rely on interaction content that does not originate from the intended source, which can affect the behaviour, state, configuration, or security of the RDPS-dependent product function.

R.3.3.3 T-RDPS-02 Loss of integrity of interactions across the RDPS boundary

An interaction exchanged across the RDPS boundary is modified, substituted, injected, corrupted, or replayed before it is processed by the receiving endpoint.

Threat type

Tampering

Security impact

The receiving endpoint may act upon interaction content whose contents no longer correspond to what was sent or intended by the legitimate source, which can affect the behaviour, state, configuration, or security of the RDPS-dependent product function.

R.3.3.4 T-RDPS-03 Unauthorized disclosure of interactions across the RDPS boundary

Data exchanged across the RDPS boundary is disclosed to an unauthorized party.

Threat type

Information disclosure

Security impact

An attacker may obtain interaction content whose disclosure can affect the security or secure operation of the RDPS-dependent product function.

R.3.3.5 T-RDPS-04 Unavailability, unacceptable delay, or intolerable degradation of interactions across the RDPS boundary

The local product side or the RDPS side is unable to send, receive, or process interactions across the RDPS boundary, or receives interactions only after an unacceptable delay, or experiences degradation of communication performance across the RDPS boundary to an extent that is not tolerable for the successful operation of the RDPS-dependent product function.

Threat type

Denial of service

Security impact

The RDPS-dependent product function may fail to operate as intended, may operate with incomplete, outdated, or degraded information, may remain blocked, or may continue without the required interaction being available when needed.

R.3.4 Assets to Threats mapping

Table R.3.4: Assets to Threats mapping

Threat ID	Threat title	Related asset(s)
T-RDPS-01	Loss of data authenticity of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-02	Loss of integrity of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-03	Unauthorized disclosure of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-04	Unavailability, unacceptable delay, or intolerable degradation of interactions across the RDPS boundary	DA-RDPS-002

R.4 Security Requirements

R.4.1 Applicability of Annex R requirements

The requirements in the present clause address the protection of the security properties identified for the assets in [clause R.3.2](#).

Where a security property is identified as relevant for a given asset in the asset tables of [clause R.3.2](#), the corresponding requirement family or families in the present clause shall be considered for applicability to that asset.

For **DA-RDPS-001**, the primary requirement families considered for applicability are:

- a) data authenticity of interactions;
- b) integrity of interactions; and
- c) confidentiality of exchanged data.

For **DA-RDPS-002**, the primary requirement family considered for applicability is availability.

R.4.2 Local product side requirements

R.4.2.1 REQ-RDPS-L-AUTH Data authenticity of interactions received from the RDPS side

Before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the local product side shall:

- verify that the interaction originates from the intended RDPS-side endpoint using mechanisms that provide assurance of origin commensurate with the security needs of the function, and
- detect and reject replayed or stale interactions where replay or reuse could affect secure operation.

Rationale

This requirement consolidates origin assurance and, where needed, replay protection into a single requirement.

R.4.2.2 REQ-RDPS-L-INTEG Integrity of interactions received from the RDPS side

The local product side shall verify that a received interaction has not been modified, substituted, corrupted, injected, or replayed in an unauthorized manner using integrity-protection mechanisms before acting upon it in a way that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function.

Rationale

This requirement provides stronger protection by requiring cryptographic integrity protection bound to the authenticated source, protects against loss of integrity of received interaction content, and protects from unauthorized modification or substitution of received interactions.

R.4.2.3 REQ-RDPS-L-CONF Confidentiality of data exchanged with the RDPS side

The local product side shall protect the confidentiality of data during exchange with the RDPS side where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function.

Rationale

Confidentiality is not required for every exchange. However, where disclosure of data exchanged with the RDPS side could affect the security or secure operation of the RDPS-dependent product function, confidentiality protection is required.

R.4.2.4 REQ-RDPS-L-AVAIL Availability

The local product side shall detect unavailability of the RDPS side or unacceptable delay of an expected interaction where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the concerned product function, and apply a defined behaviour for the concerned product function.

NOTE 1: The defined behaviour may include, as defined for the concerned product function, denial of the affected interaction, limitation of the affected function, entry into a defined degraded mode, or transition to a secure state.

NOTE 2: Examples of such conditions include loss of connectivity to the RDPS side, failure to receive an expected response within the acceptable time, or repeated timeout of interactions required for the concerned product function.

Rationale

Where secure operation of the concerned product function depends on the availability or timely receipt of RDPS-side interactions, the local product side needs to detect unavailability or unacceptable delay and respond in a defined and secure manner.

R.4.3 RDPS side requirements

R.4.3.1 REQ-RDPS-R-AUTH Data authenticity of interactions received from the local product side

Before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the RDPS side shall:

- verify that the interaction originates from the intended local product-side endpoint using mechanisms that provide assurance of origin commensurate with the security needs of the function, and
- detect and reject replayed or stale interactions where replay or reuse could affect secure operation.

Rationale

This requirement protects against acceptance of interaction content whose claimed source or origin is not genuine.

R.4.3.2 REQ-RDPS-R-INTEG Integrity of interactions received from the local product side

The RDPS side shall use integrity-protection mechanisms to verify that a received interaction has not been modified, substituted, corrupted, injected, or replayed in an unauthorized manner before acting upon it if that interaction could influence the behaviour, state, configuration, or security of the RDPS-dependent product function.

Rationale

This requirement protects against loss of integrity of received interaction content.

R.4.3.3 REQ-RDPS-R-CONF Confidentiality of data exchanged with the local product side

Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall protect the confidentiality of that data during exchange with the local product side.

Rationale

This requirement ensures confidentiality where disclosure of exchanged data could affect the security or secure operation of the RDPS-dependent product function.

R.4.3.4 REQ-RDPS-R-AVAIL Availability

The RDPS side shall detect unavailability of the local product side or unacceptable delay of an expected interaction and apply a defined behaviour for the concerned product function where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the concerned product function.

NOTE 1: The defined behaviour may include, as defined for the concerned product function, rejection of the affected interaction, limitation of the service, termination of the affected exchange, or transition of the affected interaction to a secure state.

NOTE 2: Examples of such conditions include loss of connectivity to the local product side, failure to receive an expected request or input within the acceptable time, or repeated timeout of interactions required for the concerned product function.

Rationale

Where secure operation of the concerned product function depends on the availability or timely receipt of local product-side interactions, the RDPS side needs to detect unavailability or unacceptable delay and respond in a defined and secure manner.

R.4.4 Threats ↔ Requirements mapping

Table R.4.4: Threats ↔ Requirements mapping

Threat ID	Requirement(s) – Local product side	Requirement(s) – RDPS side
T-RDPS-01	REQ-RDPS-L-AUTH	REQ-RDPS-R-AUTH
T-RDPS-02	REQ-RDPS-L-INTEG	REQ-RDPS-R-INTEG
T-RDPS-03	REQ-RDPS-L-CONF	REQ-RDPS-R-CONF
T-RDPS-04	REQ-RDPS-L-AVAIL	REQ-RDPS-R-AVAIL

R.5 Conformity assessment

R.5.1 Overview

The assessment cases in the present clause are aligned with the requirements in [clause R.4](#). Each assessment case follows a common structure: assessment reference, assessment objective, assessment preparation, assessment activities, assessment verdict, and assessment evidence.

R.5.2 Local product side assessments

R.5.2.1 REQ-RDPS-L-AUTH assessment

R.5.2.1.1 Objective

The objective of the assessment is to verify that the local product side verifies origin assurance for relevant received interactions using mechanisms commensurate with the security needs of the function and rejects replayed or stale interactions where required.

R.5.2.1.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the intended RDPS-side endpoint for those interactions;
- the mechanism used by the local product side to determine or verify the origin of the received interaction.

R.5.2.1.3 Activities

- inspect the design and configuration of the mechanism used by the local product side to verify the origin or data authenticity of the relevant interaction;
- verify that the origin or authenticity check is performed before the interaction is acted upon;
- verify that interactions from the intended RDPS-side endpoint are accepted;
- verify that interactions not originating from the intended RDPS-side endpoint, or lacking required assurance of origin, are rejected or not acted upon;
- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

R.5.2.1.4 Verdict

Pass:

- the local product side verifies origin or data authenticity of the relevant interaction before acting upon it;
- interactions lacking the required assurance of origin are rejected or not acted upon.

Fail:

- the local product side acts upon a relevant interaction without verifying required origin or authenticity; or
- the required rejection of invalid, misbound, replayed, or stale interactions is not enforced.

R.5.2.1.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.2.2 REQ-RDPS-L-INTEG assessment

R.5.2.2.1 Objective

The objective of the assessment is to verify that the local product side verifies integrity of relevant received interactions using mechanisms commensurate with the security needs of the function and rejects modified, substituted, corrupted, injected, duplicated, or replayed interactions where required.

R.5.2.2.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the mechanism used by the local product side to detect modification, substitution, corruption, injection, duplication, or replay as applicable.

R.5.2.2.3 Activities

- inspect the design and configuration of the integrity-protection mechanism used by the local product side;
- verify that integrity verification is performed before the interaction is acted upon;

- verify that a valid interaction is accepted;
- verify that modified, substituted, corrupted, or injected interactions are rejected or not acted upon;
- verify that integrity protection is bound to the authenticated source where required, and that replayed or duplicated interactions are rejected where replay or reuse could affect secure operation.

R.5.2.2.4 Verdict

Pass:

- the local product side verifies integrity of relevant interactions before acting upon those interactions;
- modified, substituted, corrupted, injected, duplicated, or replayed interactions are rejected or not acted upon where required.

Fail:

- the local product side acts upon a relevant interaction without verifying required integrity; or
- the required rejection of altered, invalid, misbound, duplicated, or replayed interactions is not enforced.

R.5.2.2.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.2.3 REQ-RDPS-L-CONF assessment

R.5.2.3.1 Objective

The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side protects the confidentiality of that data during exchange with the RDPS side.

R.5.2.3.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk;
- the mechanism used by the local product side to protect confidentiality during exchange.

R.5.2.3.3 Activities

- inspect the design and configuration of the confidentiality-protection mechanism used by the local product side;
- verify that the identified data is protected during exchange;
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner.

R.5.2.3.4 Verdict

Pass:

- the local product side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk;
- such data is not exchanged in an unprotected manner.

Fail:

- the local product side exchanges relevant confidential data without the required confidentiality protection; or
- protected data is disclosed to an unintended endpoint.

R.5.2.3.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.2.4 REQ-RDPS-L-AVAIL assessment

R.5.2.4.1 Objective

The objective of the assessment is to verify that the local product side detects unavailability, unacceptable delay, or intolerable degradation of required RDPS-side interactions, and applies a defined behaviour, including recovery or continuity measures where necessary.

R.5.2.4.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the acceptable timing or service conditions for those interactions;
- the defined behaviour to be applied when the required interactions are unavailable, delayed, or degraded;
- the degraded behaviour, secure state, recovery support, or continuity mechanism required by the selected requirement.

R.5.2.4.3 Activities

- inspect the design and configuration of the timeout, timeliness, degradation-detection, or equivalent controls used by the local product side;
- verify that unavailability, unacceptable delay, or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur;
- verify that a defined degraded behaviour or secure state is applied where required;
- verify that recovery support is available and can be used to restore secure operation where required.
- where failover, redundancy, or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed, or degraded.

R.5.2.4.4 Verdict

Pass:

- the local product side detects the specified failure, delay, or degradation conditions;
- a defined behaviour is applied when the identified conditions occur;
- recovery or continuity support is available and effective where required.

Fail:

- the local product side does not detect the relevant failure, delay, or degradation condition; or
- the required defined behaviour, recovery support, or continuity mechanism is absent or ineffective.

R.5.2.4.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.3 RDPS side assessments

R.5.3.1 REQ-RDPS-R-AUTH assessment

R.5.3.1.1 Objective

The objective of the assessment is to verify that the RDPS side verifies origin assurance for relevant received interactions using mechanisms commensurate with the security needs of the function and rejects replayed or stale interactions where required.

R.5.3.1.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the intended local product-side endpoint for those interactions;
- the mechanism used by the RDPS side to determine or verify the origin of the received interaction.

R.5.3.1.3 Activities

- inspect the design and configuration of the mechanism used by the RDPS side to verify the origin or data authenticity of the relevant interaction;
- verify that the origin or authenticity check is performed before the interaction is acted upon;
- verify that interactions from the intended local product-side endpoint are accepted;
- verify that interactions not originating from the intended local product-side endpoint, or lacking required assurance of origin, are rejected or not acted upon;
- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

R.5.3.1.4 Verdict

Pass:

- the RDPS side verifies origin or data authenticity of the relevant interaction before acting upon it;
- interactions lacking the required assurance of origin are rejected or not acted upon.

Fail:

- the RDPS side acts upon a relevant interaction without verifying required origin or authenticity; or
- the required rejection of invalid, misbound, replayed, or stale interactions is not enforced.

R.5.3.1.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.3.2 REQ-RDPS-R-INTEG assessment

R.5.3.2.1 Objective

The objective of the assessment is to verify that the RDPS side verifies integrity of relevant received interactions using mechanisms commensurate with the security needs of the function and rejects modified, substituted, corrupted, injected, duplicated, or replayed interactions where required.

R.5.3.2.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the mechanism used by the RDPS side to detect modification, substitution, corruption, injection, duplication, or replay as applicable.

R.5.3.2.3 Activities

- inspect the design and configuration of the integrity-protection mechanism used by the RDPS side;
- verify that integrity verification is performed before the interaction is acted upon;
- verify that a valid interaction is accepted;
- verify that modified, substituted, corrupted, or injected interactions are rejected or not acted upon;
- verify that integrity protection is bound to the authenticated source where required, and that replayed or duplicated interactions are rejected where replay or reuse could affect secure operation.

R.5.3.2.4 Verdict

Pass:

- the RDPS side verifies integrity of relevant interactions before acting upon those interactions;
- modified, substituted, corrupted, injected, duplicated, or replayed interactions are rejected or not acted upon where required.

Fail:

- the RDPS side acts upon a relevant interaction without verifying required integrity; or
- the required rejection of altered, invalid, misbound, duplicated, or replayed interactions is not enforced.

R.5.3.2.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.3.3 REQ-RDPS-R-CONF assessment

R.5.3.3.1 Objective

The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side protects the confidentiality of that data during exchange with the local product side.

R.5.3.3.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk;
- the mechanism used by the RDPS side to protect confidentiality during exchange.

R.5.3.3.3 Activities

- inspect the design and configuration of the confidentiality-protection mechanism used by the RDPS side;
- verify that the identified data is protected during exchange;
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner.

R.5.3.3.4 Verdict

Pass:

- the RDPS side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk;
- such data is not exchanged in an unprotected manner.

Fail:

- the RDPS side exchanges relevant confidential data without the required confidentiality protection; or
- protected data is disclosed to an unintended endpoint.

R.5.3.3.5 Evidence

- design and configuration evidence for the relevant protection mechanism;

- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

R.5.3.4 REQ-RDPS-R-AVAIL assessment

R.5.3.4.1 Objective

The objective of the assessment is to verify that the RDPS side detects unavailability, unacceptable delay, or intolerable degradation of required local product-side interactions, and applies a defined behaviour, including recovery or continuity measures where necessary.

R.5.3.4.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security, or availability of that function;
- the acceptable timing or service conditions for those interactions;
- the defined behaviour to be applied when the required interactions are unavailable, delayed, or degraded;
- the degraded behaviour, secure state, recovery support, or continuity mechanism required by the selected requirement.

R.5.3.4.3 Activities

- inspect the design and configuration of the timeout, timeliness, degradation-detection, or equivalent controls used by the RDPS side;
- verify that unavailability, unacceptable delay, or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur;
- verify that a defined degraded behaviour or secure state is applied where required;
- verify that recovery support is available and can be used to restore secure operation where required;
- where failover, redundancy, or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed, or degraded.

R.5.3.4.4 Verdict

Pass:

- the RDPS side detects the specified failure, delay, or degradation conditions;
- a defined behaviour is applied when the identified conditions occur;
- recovery or continuity support is available and effective where required.

Fail:

- the RDPS side does not detect the relevant failure, delay, or degradation condition; or
- the required defined behaviour, recovery support, or continuity mechanism is absent or ineffective.

R.5.3.4.5 Evidence

- design and configuration evidence for the relevant protection mechanism;

- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery, or continuity behaviour for invalid or failure conditions, as applicable.

Annex S (informative): Change history

Version	Information about changes
V0.0.1	Preliminary draft distributed to all ETSI-EUSR Rapporteurs for comments
V0.0.2	Contributed and presented to CYBEREUSR#30, including comments received from consumer IoT and Hypervisor rapporteurs
V0.0.3	Contributed to CYBEREUSR#31, including comments from previous meeting and additional guidance received from EC and new introduction clause
V0.0.4	Resolution of inconsistencies, links errors and editorials

History

Version	Date	Status
V1.0.0	August 2026	SRdAP process EV 20261105: 2026-08-13 to 2026-11-05